
IT IN THE ENERGY SECTOR

***Managing Infrastructure, Security, and
Digital Transformation in Critical
Energy Environments***

- ▶ **Endpoint & Mobile Device Management**
- ▶ **Identity, Active Directory & Zero Trust**
- ▶ **NERC CIP, SOX & Regulatory Compliance**
- ▶ **Application Lifecycle & Microsoft 365**
- ▶ **Field IT Operations & Remote Support**
- ▶ **AI, IoT, and the Energy Transition**

IT IN THE ENERGY SECTOR

***Managing Infrastructure, Security, and
Digital Transformation in Critical
Energy Environments***

- ▶ **Endpoint & Mobile Device Management**
- ▶ **Identity, Active Directory & Zero Trust**
- ▶ **NERC CIP, SOX & Regulatory Compliance**
- ▶ **Application Lifecycle & Microsoft 365**
- ▶ **Field IT Operations & Remote Support**
- ▶ **AI, IoT, and the Energy Transition**

IT IN THE ENERGY SECTOR

*Managing Infrastructure, Security, and
Digital Transformation in Critical Energy
Environments*

VILAS SHEWALE

Lead Specialist, Energy Transfer
Houston, Texas

About the Author



Vilas Shewale is a Houston-based enterprise IT leader with more than two decades of experience managing large-scale technology infrastructure in some of the world's most demanding and regulated industries. He currently serves as a Lead Specialist at Energy Transfer, one of North America's largest energy infrastructure companies, where he is responsible for enterprise-wide endpoint management, mobile device security, and IT infrastructure across a fleet of more than 11,000 devices spanning corporate offices and field operations across the United States. Born in Nashik, India, Vilas earned a Bachelor of Science in Computer Science from KTHM College and a Master of Science in Computer Science from Modern College, Pune, before building a career that has taken him from Mumbai and Singapore to Houston. Along the way, he has worked with financial giants such as Morgan Stanley and JP Morgan Chase, global energy companies ConocoPhillips and Energy Transfer, and financial services leader TD Ameritrade, gaining an unusually broad perspective on enterprise IT across industries, geographies, and organizational scales.

IT in the energy sector is not just about keeping the lights on inside the office. It is about ensuring that the infrastructure managing the physical infrastructure never fails.

Vilas Shewale

Vilas is recognized as a cybersecurity expert for critical infrastructure, a designation that reflects both his hands-on technical depth and his ability to connect security architecture to operational risk. He is a published author his first book, *Cybersecurity in the Modern World: Protecting Data, Privacy, and Systems*, addressed broad cybersecurity principles for a wide audience. *IT in the Energy Sector* is his second book, and it draws on the niche, practitioner-specific knowledge that no existing publication has fully captured.

Credentials & Roles



Lead Specialist Energy Transfer, Houston TX (2022–Present)

Enterprise endpoint management, mobile device security, SCCM/MCEM, Microsoft Intune, BeyondTrust EPM across 11,000+ devices



Desktop Engineer / Lead VLink Inc., Energy Transfer & ConocoPhillips (2013–2022)

Application packaging, SCCM deployment, Windows migrations, UAT/QA leadership

**Manager Morgan Stanley, Mumbai India (2005–2010)**

Application packaging and deployment for 70,000+ desktops globally across Citrix and SCCM environments

**Lead Desktop Engineer JP Morgan Chase, Singapore (2011)**

Windows 7 migration lead for the Asia-Pacific region covering laptops, desktops, and VDI infrastructure

**Certified Azure Administrator Associate (Microsoft)**

Cloud infrastructure, hybrid identity, and endpoint management via Azure and Microsoft 365

**IT Tech Expo Award Morgan Stanley (2008)**

Recognized for exemplary projects presented at the Technology Exhibition, Mumbai

Technical Expertise

Vilas' technical toolkit spans the full spectrum of enterprise endpoint and security management:

- Endpoint Management: SCCM/MCEM, Microsoft Intune, Autopilot, Co-management, Azure AD
- Security: BeyondTrust EPM, LAPS, Workstation Hardening, WSUS, System Center Endpoint Protection
- Mobile: Microsoft Intune MDM/MAM, Android Zero Touch, Apple Business Manager
- Packaging & Deployment: AdminStudio, InstallShield, Wise Package Studio, App-V, MSI

- Scripting & Automation: PowerShell, VBScript, Group Policy (GPO), Active Directory
- Cloud: Azure, Cloud Management Gateway, Microsoft 365, SharePoint, Teams
- Tools: ServiceNow, Remedy, BeyondTrust, Orchestrator, MDT, ProcMon, Orca

A Note on This Book

This book was not written from a whiteboard or a framework document. It was written from a server room, a change management meeting, a field operations call at 6 a.m., and two decades of decisions made under pressure in environments where failure is not an abstract risk it is a safety, environmental, and financial event. Every chapter reflects real challenges Vilas has encountered, real solutions he has implemented, and real lessons he has drawn from success and failure alike.

It is written for the IT professional who is already in the trenches or about to enter them and who needs not just theory, but the kind of context that only experience can provide.

Preface

Every book has a moment of origin—a specific frustration, realization, or conversation that makes an author think: someone needs to write this. For me, that moment came early in my tenure at Energy Transfer, when I was tasked with implementing a company-wide endpoint management upgrade across a sprawling infrastructure of more than 11,000 devices. I had done large-scale deployments before—at Morgan Stanley, at JP Morgan Chase in Singapore, at ConocoPhillips. But this was different.

The challenge was not technical. The technical pieces—SCCM, Intune, co-management—I knew well. The challenge was contextual. Energy infrastructure does not operate on the same clock as a financial services firm or a technology company. It does not have the same tolerance for downtime, the same regulatory framework, the same relationship between IT and operations, or the same consequences when something goes wrong. A failed deployment at a bank means someone cannot access their email for a few hours. A failed deployment at a pipeline compressor station can mean something far worse.

There is no book for this. You just have to learn it.

A colleague, early in the author's energy sector career

A colleague said that to me in my first year. He meant it kindly. He was telling me that the knowledge I needed existed only in the heads of people who had been doing it for years—that there was no textbook, no certification curriculum, no guide that combined the IT depth with the energy-sector context I was

trying to navigate simultaneously. That observation has stayed with me ever since. This book is my attempt to change it.

IT in the Energy Sector is not a book about oil and gas. It is not a book about renewable energy or grid management or the energy transition. It is a book about the people who manage the technology that runs the businesses that run the energy infrastructure the desktop engineers, sysadmins, endpoint managers, security architects, and IT directors who work behind the scenes of one of the world's most consequential industries. Their work is rarely visible. When it goes well, nobody notices. When it goes wrong, everyone does.

This book is also not a vendor manual or a framework document. It does not advocate for any specific product or platform. Where I discuss Microsoft Intune or SCCM or BeyondTrust EPM, it is because those are the tools I have used extensively in real enterprise energy environments not because they are the only tools that exist or the best tools for every situation. The principles this book teaches can be applied regardless of your specific vendor choices.

Who This Book Is For

I wrote this book with several readers in mind, and I want to be honest about who will get the most out of it:

- The IT professional who is new to the energy sector and finds that their existing knowledge transfers only partially to this new environment. This is the reader I was, years ago.
- The experienced energy sector IT practitioner who has never seen their hard-won knowledge written down and validated. This book is for you, too.
- The IT manager or director trying to build or lead a team in an energy company and looking for a framework that matches their reality.

- The cybersecurity professional focused on critical infrastructure who wants a grounded, operational perspective beyond the policy frameworks.
- The computer science student or early-career IT professional who is considering a career in the energy sector and wants to know what they are walking into.

What this book assumes: a working knowledge of enterprise IT concepts endpoints, active directory, software deployment, networking basics. It does not require deep expertise in any specific tool. Each chapter builds on the previous ones, but the chapters are also designed to be readable independently if you are looking for guidance on a specific topic.

How This Book Is Organized

The book is organized in four parts. Part I (Chapters 1–3) establishes the foundational context: the energy sector IT landscape, the unique characteristics of working in critical infrastructure, and the regulatory environment that shapes every decision. Part II (Chapters 4–7) covers the core technical disciplines: endpoint management, mobile device management, identity and security, and cloud integration. Part III (Chapters 8–10) addresses the operational realities: application lifecycle management, Office 365 deployment, and supporting remote and field environments. Part IV (Chapters 11–12) covers the human and strategic dimensions: IT project management in energy organizations and the future of energy sector IT.

Each chapter includes real-world case studies drawn from my experience, architectural diagrams and deployment frameworks, citations from industry research and regulatory guidance, and practical checklists and templates at the end. Where I have made mistakes, I say so. Where a standard industry approach fails in energy-sector contexts, I explain why and offer an alternative.

A Word on Confidentiality

All case studies in this book are based on real events and real decisions. Where details have been altered to protect organizational confidentiality, I have noted this. The lessons drawn from each case study are real and unaltered. No proprietary company information has been included. The goal is not to expose any organization's vulnerabilities it is to give readers the benefit of pattern recognition that only comes from accumulated experience.

Acknowledgments

This book would not exist without the colleagues, engineers, administrators, and operations professionals I have worked alongside over the past two decades. To the teams at Energy Transfer, ConocoPhillips, Morgan Stanley, JP Morgan Chase Singapore, and TD Ameritrade: you taught me more than any textbook could. To the IT professionals who are doing this work every day, in every energy company, in every corner of the world this book is for you.

To my family: thank you for the patience and support that every author owes to the people who live with the project.

Introduction: IT in the Last Frontier

On May 7, 2021, a ransomware attack on Colonial Pipeline the largest fuel pipeline in the United States forced the company to halt pipeline operations for six days. The attack did not compromise the pipeline's operational technology directly. It compromised the IT network. The decision to shut down operations was made proactively, out of concern that the attack might spread. The result: panic buying across the Southeast, fuel shortages at thousands of gas stations, a national emergency declaration, and \$4.4 million in ransom paid. The entire cascade began with an IT failure.

That incident changed the conversation about IT in the energy sector forever. It made viscerally clear what energy sector IT professionals had known for years: that the technology systems managing pipelines, refineries, power grids, and compressor stations are not a back-office function. They are critical infrastructure. And the people managing those systems carry a weight of responsibility that most IT professionals in other industries never have to consider.

60%	of energy/oil/gas organizations reported a ransomware attack in 2022 (Sophos, 2022)
\$3.12M	average ransomware recovery cost per energy sector incident in 2022
80%	increase in ransomware attacks on energy & utilities sector in 2022 vs. prior year (TrustWave, 2022)
11%	of all global cyberattacks targeted the energy & utilities sector (IBM X-Force, 2022)

This book is about the IT professionals who work in this environment the ones who manage the endpoints, the identity infrastructure, the mobile device fleets, the software deployments, and the security architecture that keeps energy companies running. It is about what makes their work different from IT work in other sectors, and how to do it well.

Why the Energy Sector Is Unlike Any Other IT Environment

When I moved from financial services IT managing systems for tens of thousands of users at Morgan Stanley into the energy sector, I expected the technical work to be largely similar. The tools were the same. The concepts were the same. What I did not expect was how different the context would be.

In financial services, a failed software deployment might mean a trader cannot access their Bloomberg terminal for an hour. That is a serious problem. In the energy sector, a failed deployment at the wrong time, on the wrong system, at the wrong location, can trigger a chain of events that no IT professional wants to be responsible for. The stakes are not higher in degree. They are higher in kind.

Several characteristics make energy sector IT fundamentally distinct:

1. The Consequence Asymmetry

In most enterprise IT environments, system failures cost money and productivity. In energy environments, they can cost lives, cause environmental damage, or trigger regulatory consequences that dwarf anything IT-related. This asymmetry shapes every decision: change management processes are more rigorous, testing is more exhaustive, and rollback planning is more detailed than in almost any other sector.

2. The OT/IT Boundary

Energy companies operate two parallel technology worlds: Information Technology (IT) and Operational Technology (OT). IT manages business systems endpoints, email, ERP, collaboration tools. OT manages physical processes SCADA systems, distributed control systems (DCS), pipeline monitoring, flow control. Historically, these worlds were separate. Increasingly, they are not. As energy companies digitalize, the boundary between IT and OT becomes porous and the IT professional who does not understand where that boundary lies, and what crosses it, creates risk they may not even be aware of.

3. Geographic Dispersion

A large energy company might have corporate headquarters in Houston, regional offices in Denver and Calgary, and operational sites at hundreds of compressor stations, pumping stations, refineries, and field locations many of them remote, with limited connectivity and no on-site IT staff. Managing endpoints, deploying software, and providing support across this geography is a fundamentally different challenge than managing a campus or a set of urban office buildings.

4. The Regulatory Burden

Energy companies operate under a dense web of regulatory requirements that directly constrain IT decisions. NERC CIP (North American Electric Reliability Corporation Critical Infrastructure Protection) standards impose specific requirements on systems that interact with the bulk electric system. CISA (Cybersecurity and Infrastructure Security Agency) guidelines shape security architecture. SOX (Sarbanes-Oxley) governs financial systems. These are not guidelines that can be treated as aspirational they carry legal and financial consequences for non-compliance.

5. The Production-First Culture

In energy companies, production is the mission. Everything else including IT is in service of production. This cultural reality shapes how IT projects are planned, scheduled, and communicated. A maintenance window that would be routine in a corporate office requires weeks of coordination with operations teams in an energy environment. An upgrade that causes even a brief disruption to a production system will be remembered long after the upgrade's benefits have been forgotten.

In the energy sector, IT is not the business. IT enables the business. The distinction matters enormously when things go wrong.

Vilas Shewale

The State of Energy Sector Digitalization

The energy sector is in the middle of a profound digital transformation. According to the International Energy Agency, grid-related investment in digital technologies has grown by over 50% since 2015. The cloud computing market in the energy sector was projected to reach \$15.5 billion by 2027, growing at a compound annual rate of 23%. Digital twins, IoT sensors, predictive analytics, and AI-driven grid management are no longer experimental they are becoming operational reality.

This transformation creates enormous opportunity and enormous risk simultaneously. Every new digital connection point is a potential attack surface. Every cloud migration is a potential exposure. Every IoT sensor added to a pipeline or substation is a potential entry point for an adversary. The IT professional in the energy sector is not just managing a more complex environment than ever before they are doing so while the environment itself is actively changing underneath them.

The cybersecurity dimension of this challenge cannot be overstated. According to IBM Security's 2022 X-Force Threat Intelligence Index, the energy and utilities sector sustained roughly 11% of all global cyberattacks. Recent TrustWave research found that ransomware attacks targeting energy and utilities companies increased by 80% year-over-year compared to the prior year. The average ransomware recovery cost in the energy sector reached \$3.12 million per incident. Nation-state actors are increasingly targeting energy infrastructure as a vector for geopolitical leverage a trend that shows no sign of reversing.

What This Book Will Give You

Reading this book will not make you an instant expert in energy sector IT. Nothing will do that except time, experience, and a willingness to learn from failure. What it will give you is a map a structured understanding of the terrain, the hazards, the best-known routes, and the places where you will need to find your own path.

Specifically, you will gain:

- A clear conceptual framework for understanding the energy sector IT environment and how it differs from other enterprise contexts.
- Practical, implementation-tested guidance on the core technical disciplines: endpoint management, mobile devices, identity and security, cloud integration.
- Real-world case studies that illustrate both best practices and cautionary tales from actual energy sector deployments.
- Regulatory orientation enough to understand what NERC CIP, CISA, and SOX require of IT, without requiring a law degree.

- Strategic frameworks for IT project management and stakeholder communication in production-first organizations.
- A forward-looking perspective on where energy sector IT is heading and what skills will matter most.

This is a practitioner's book, written by a practitioner, for practitioners. The goal is not to impress you with frameworks it is to make you more effective at a job that matters more than most people realize.

A Note on the Industry's Future

The energy sector is changing faster than at any point in its history. The transition to renewable energy, the electrification of transportation, the rise of distributed energy resources, and the increasing integration of AI into grid management are all transforming the operational landscape that energy IT serves. The IT professional who understands only the legacy fossil fuel infrastructure will be increasingly ill-equipped for what is coming.

Throughout this book, I try to connect the current state of energy IT to where it is heading not to make predictions, but to equip you with the mental models that will allow you to adapt as the industry evolves. The core principles of good enterprise IT rigorous change management, defense in depth, operational resilience, stakeholder communication, and continuous learning do not change with the energy mix. The specific technologies and regulatory requirements will. This book aims to give you both.

References & Sources:

IBM Security X-Force Threat Intelligence Index 2022. IBM Corporation.

Sophos State of Ransomware in Energy, Oil/Gas and Utilities 2022. Sophos Ltd.

International Energy Agency. Digitalization and Energy. IEA Publications, 2022.

U.S. Department of Energy, Office of Cybersecurity, Energy Security, and Emergency Response (CESER). Cyber Baselines. DOE, 2022.

KPMG. Cybersecurity Considerations for Energy and Natural Resources. KPMG LLP, 2022.

SC Media. Critical Infrastructure Sectors Hit Hardest by Cyberattacks. SC Media, 2022.

INDEX TBALE

Chapter	Title	Page
1	Understanding the Energy IT Landscape	22
2	Endpoint Management at Scale	44
3	Mobile Device Management in the Field	73
4	Active Directory, Group Policy, and Identity Management	100
5	Cybersecurity in Critical Infrastructure	130
6	Cloud Integration and Azure in Energy Environments	155
7	Regulatory Compliance and IT Governance	178
8	Application Lifecycle Management	199
9	Office 365 and Collaboration Tools in Energy	222
10	IT Operations in Field and Remote Environments	243
11	IT Project Management and Stakeholder Communication	265
12	The Future of IT in the Energy Sector	287

CHAPTER 1

Understanding the Energy IT Landscape

Corporate, Field, and Everything In Between

Energy companies don't run on oil and gas alone. They run on data and someone has to manage the systems that carry it.

Industry observation, Energy Sector IT Forum, 2022

Opening: A Tale of Two Worlds

Imagine two IT professionals, both with ten years of enterprise experience, both proficient in Microsoft endpoint management, both skilled in security architecture. One takes a role at a large financial services firm. The other accepts an offer from a major pipeline company. Six months in, they compare notes over coffee.

The financial services professional describes a dense urban campus, a well-staffed IT department, clear service-level agreements, and users who while sometimes demanding are mostly in the same building when something goes wrong. The energy sector professional describes something else entirely: endpoints scattered across hundreds of locations spanning three time zones, field sites with connectivity measured in kilobits per second, users who are sometimes a four-hour drive from the

nearest IT staff member, and a change management process so rigorous that a software deployment requires sign-off from operations leadership.

Same tools. Same certifications. Entirely different world.

This chapter is your orientation to that world. It maps the landscape of enterprise IT in energy companies the geography, the organizational structures, the technology layers, the stakeholders, and the cultural context that shapes every decision an energy sector IT professional will make. If you are new to the sector, this chapter will help you understand what you are walking into. If you have been in it for years, it will give you language and frameworks to describe what you already know intuitively.

1.1 What Makes an Energy Company's IT Environment Unique

Before diving into specifics, it is worth establishing a clear-eyed understanding of why energy sector IT is categorically different not just marginally harder than IT in most other industries. Several fundamental characteristics drive this distinction.

Scale and Geographic Dispersion

Large energy companies operate across vast geographies. A single midstream pipeline company might have corporate headquarters in Houston, regional operations centers in Denver, Calgary, or Tulsa, and hundreds of compressor stations, pumping stations, metering sites, and terminals distributed across the continental United States. Each of these locations represents an endpoint management challenge: devices that must be maintained, secured, and updated often without IT staff physically present.

This geography creates what IT professionals in the sector sometimes call the 'last mile problem': the challenge of deploying software, managing configurations, and providing support to endpoints that are connected via satellite links, cellular networks, or aging MPLS circuits with limited bandwidth and high latency. A deployment strategy that works perfectly in a corporate office can fail completely when applied to a remote compressor station with a 256 kbps satellite connection.

The Consequence Asymmetry

In most IT environments, the consequences of system failure are measured in lost productivity and user frustration. In energy environments, they can extend to production disruption, safety incidents, environmental events, and regulatory penalties. This consequence asymmetry fundamentally shapes how IT decisions are made.

When an IT professional in a corporate environment patches a system and something breaks, the response is measured in hours of troubleshooting. When an IT decision affects a system adjacent to operational technology at a processing plant, the response can involve emergency response teams, regulatory notifications, and executive escalation. This is not a reason to avoid change it is a reason to manage change with an order of magnitude more rigor than most IT environments require.

The OT/IT Boundary

Every energy company operates two parallel technology worlds: Information Technology (IT) and Operational Technology (OT). Understanding the boundary between them and respecting it is one of the most critical competencies an energy sector IT professional can develop.

OT encompasses the systems that directly monitor and control physical processes: SCADA (Supervisory Control and Data Acquisition) systems, Distributed Control Systems (DCS), Programmable Logic Controllers (PLCs), Remote Terminal Units

(RTUs), and Human Machine Interfaces (HMIs). These systems operate in real-time, often running 24 hours a day, 365 days a year, with zero tolerance for unplanned downtime. They frequently run older, specialized operating systems sometimes versions of Windows that would be considered end-of-life in a corporate environment and they are connected to physical equipment where a software error is not a user complaint, but a potential safety event.

IT manages the business systems: endpoints, email, ERP, financial systems, collaboration tools, and the network infrastructure that connects them. The convergence of IT and OT the gradual removal of the air gap between these worlds is one of the defining challenges of the current era in energy sector IT, and it is covered in depth in Chapter 5.

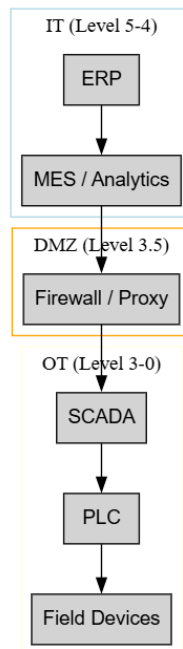


Figure 1.1 IT and OT layers in a typical energy company, based on the Purdue Enterprise Reference Architecture (PERA / IEC 62443). The DMZ

boundary zone enforced by firewalls, data diodes, and historian servers separates business IT from operational technology.

The Production-First Culture

Energy companies are operations-driven organizations. Production whether measured in barrels of oil, cubic feet of natural gas, or megawatts of electricity is the primary objective of everything the company does. IT is a service function: essential, but always subordinate to operations. This cultural reality has profound practical implications for IT professionals.

Maintenance windows must be negotiated with operations teams, often weeks in advance. Software updates that require system reboots need approval from production schedulers. Major changes to network infrastructure may require coordination with SCADA operations teams to ensure that control system communications are not disrupted. A deployment that would take a few hours in a corporate environment can take weeks to schedule in an energy company not because of bureaucracy, but because of legitimate operational risk management.

IT professionals who understand and respect this dynamic become trusted partners to operations. Those who do not who push through changes on corporate timelines without operations coordination can cause incidents that take years to recover from in terms of organizational trust.

1.2 The Energy Sector IT Landscape: A Taxonomy

To navigate the energy IT landscape effectively, it helps to have a clear taxonomy of the different environments you will

encounter. Not all energy companies are the same, and not all locations within a single energy company are the same.

Corporate Headquarters and Regional Offices

Corporate headquarters is typically where the IT function is centralized and best resourced. In a large energy company, the HQ might house the primary data center, the core IT operations team, the help desk, endpoint management infrastructure, and the majority of business applications. Users here are mostly knowledge workers: finance, legal, HR, business development, and executive teams.

Regional offices are scaled-down versions of HQ, typically connected via dedicated WAN circuits (MPLS or SD-WAN), with local infrastructure managed centrally and limited on-site IT staff. The bandwidth and latency at regional offices is generally sufficient for standard enterprise application use, though large deployments may need to be throttled or scheduled during off-peak hours.

Industrial Operations Sites

This category includes refineries, processing plants, compressor stations, pumping stations, terminals, and storage facilities. These locations are characterized by a heavy OT presence, limited IT staff (often none), and connectivity that varies from reasonable (large refineries with dedicated circuits) to marginal (remote compressor stations on cellular or satellite links).

The IT footprint at these locations is typically limited to a small number of desktops or laptops used by site supervisors, control room operators, and maintenance personnel for business tasks. These endpoints are physically separated from the OT environment or should be and managed remotely via the enterprise endpoint management infrastructure.

The challenge at industrial operations sites is not complexity of the IT environment it is the operational context. Any IT activity that could potentially affect production systems must be

coordinated carefully. Even apparently routine activities, such as restarting a workstation or applying a software update, require communication with site operations personnel.

Remote and Unmanned Sites

At the far end of the spectrum are remote or unmanned sites: small metering stations, remote valve stations, and monitoring points that may have no IT presence at all beyond an RTU or a small industrial computer. IT's role at these locations is minimal, but the OT security implications are significant, and IT may be involved in managing the communication infrastructure that connects these sites to the wider network.

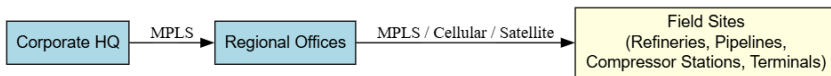


Figure 1.2 The geographic topology of a typical large energy company's IT environment. The connectivity, IT staffing, and operational risk profile vary significantly across site types. Field sites represent the greatest management challenge for enterprise IT.

1.3 The Cast of Stakeholders: Who IT Works With

One of the most important orientation tasks for a new energy sector IT professional is mapping the stakeholder landscape understanding who the key players are, what they care about, and how they relate to IT. This landscape is considerably more complex than in most IT environments.

Operations Teams

Operations is IT's most important stakeholder in any energy company. Operations teams manage the physical assets pipelines, compressor stations, plants, terminals and their

primary concern is production reliability and safety. When IT approaches operations with a change request, the first question is almost always: 'What is the risk to production?' IT professionals who can answer this question clearly, demonstrate that they have considered operational implications, and propose changes with minimal production impact will earn operations' trust. Those who cannot will find every change request met with resistance.

Operations teams often include OT engineers and SCADA specialists who have deep expertise in control systems but limited familiarity with enterprise IT. Building effective relationships with these professionals learning enough of their language to have informed conversations about the IT/OT boundary is one of the most valuable investments an energy sector IT professional can make.

The CISO and Security Team

In energy companies, the Chief Information Security Officer (CISO) holds a position of unusual authority, reflecting the sector's heightened threat environment. The CISO's team is responsible for enterprise security architecture, threat intelligence, vulnerability management, incident response, and regulatory compliance particularly NERC CIP in electric utilities and TSA Pipeline Security Directives in pipeline companies.

IT professionals working in endpoint management, network infrastructure, and application deployment will interact frequently with the security team. Security requirements shape deployment decisions (which Group Policy settings are mandatory), endpoint configurations (workstation hardening standards), and change management processes (security review gates). Understanding the security team's priorities and incorporating security requirements into IT work from the start rather than treating security review as a final hurdle will dramatically improve the speed and quality of IT project delivery.

Compliance and Legal

Energy companies operate under a dense web of regulatory requirements, and the compliance function exists to ensure that the company meets them. For IT, this means that certain decisions are not purely technical they have compliance implications that require legal or compliance review. Decisions about data retention, endpoint configuration baselines, access control policies, and change management documentation can all have compliance dimensions in an energy company context.

Building a working relationship with the compliance team understanding which regulatory requirements most directly affect IT operations is essential for effective energy sector IT work. This relationship is explored in depth in Chapter 7.

Business Application Owners

Energy companies run a complex portfolio of business applications: ERP systems (SAP, Oracle), financial systems, production reporting tools, geographic information systems (GIS), pipeline management systems, and trading and scheduling platforms, among others. Each of these applications has an 'owner' typically a business unit or functional team who is responsible for defining requirements and approving changes.

IT's relationship with application owners is often one of the most delicate in the organization. Application owners care deeply about availability and functionality. They may resist IT-initiated changes patches, upgrades, platform migrations that could affect their applications, even when those changes are necessary for security or supportability. Managing these relationships effectively requires a combination of technical credibility, clear communication, and a genuine understanding of business priorities.

Vendors and Managed Service Providers

Large energy companies rely heavily on external vendors and managed service providers for everything from endpoint

management tooling to network operations to application development. Managing these vendor relationships holding them to service level agreements, coordinating their activities with internal operations, and ensuring that vendor access to systems complies with security policies is a significant operational function for energy sector IT.

Vendor access management is a particular concern in energy environments. Third-party vendors who require remote access to operational systems represent a significant attack surface, and managing that access ensuring it is time-limited, logged, and appropriately controlled is both an IT and a security responsibility.

1.4 The IT Organizational Structure in Energy Companies

IT organizational structures vary significantly across energy companies, but some common patterns are worth understanding. These patterns reflect the unique characteristics of the sector: the need to balance enterprise IT management with specialized operational technology support, the geographic distribution of the workforce, and the regulatory requirements that shape governance structures.

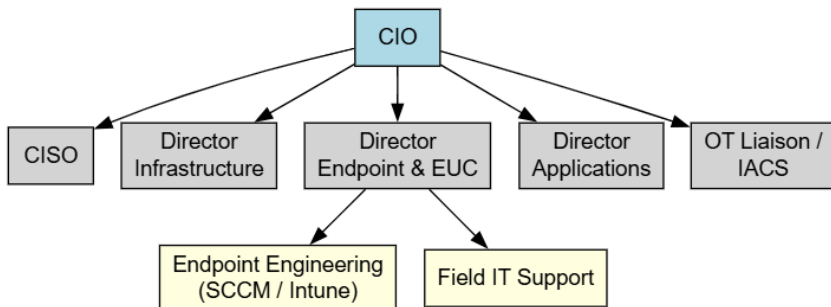


Figure 1.3 A representative IT organizational structure for a large energy company. The OT Liaison or IACS (Industrial Automation and Control Systems) function whether housed in IT or Operations plays a critical bridging role. Structure varies significantly by company size and business model.

The CIO and the IT Leadership Team

In large energy companies, the Chief Information Officer (CIO) or VP of IT typically reports to either the Chief Executive Officer (CEO) or the Chief Financial Officer (CFO). The reporting line matters: a CIO who reports to the CEO generally has more organizational authority and a closer relationship with strategic decision-making than one who reports to the CFO where IT may be viewed primarily as a cost center.

Below the CIO, the leadership team typically includes functional directors responsible for infrastructure, endpoint and end-user computing (EUC), applications, and increasingly, an OT liaison or Industrial Automation and Control Systems (IACS) function that manages the IT/OT boundary. The CISO may report to the CIO or directly to the CEO or the board, depending on the company's governance model.

The End-User Computing (EUC) / Endpoint Function

The endpoint and end-user computing function is where much of the day-to-day IT work happens in energy companies. This team is responsible for managing the enterprise endpoint fleet deploying and maintaining laptops and desktops, managing mobile devices, packaging and deploying software, configuring and enforcing Group Policy settings, and providing escalated support for endpoint-related issues.

In energy companies, the EUC function faces challenges that are largely invisible in other sectors: managing endpoints at remote sites with limited connectivity, coordinating deployments around production schedules, supporting field users who may

not have reliable internet access, and maintaining security compliance across a geographically dispersed device fleet. The tools and practices used to meet these challenges SCCM/MCEM, Microsoft Intune, co-management, Cloud Management Gateway, mobile device management are the subject of detailed treatment in Chapters 2 and 3.

Field IT: The Often-Overlooked Function

Many large energy companies have a field IT function a team of IT professionals, often organized regionally, whose primary responsibility is to support technology users at operational sites. Field IT professionals occupy a unique and demanding position: they must have sufficient technical breadth to troubleshoot a wide range of issues, sufficient operational awareness to work safely and effectively at industrial sites, and sufficient relationship skills to earn the trust of operations teams who often view IT with suspicion.

Field IT is frequently under-resourced relative to the scale of its responsibilities, and the knowledge held by experienced field IT professionals who understand both the technical environment and the operational context of dozens of sites is often underdocumented. Building institutional knowledge management systems for field IT is one of the highest-leverage investments a well-run energy IT organization can make.

1.5 Key Technology Concepts for Energy Sector IT

Before closing this chapter, it is worth establishing a clear understanding of some key technology concepts and terms that will appear throughout the rest of the book. This is not a comprehensive technical reference each concept is addressed in depth in subsequent chapters. But grounding the reader in

these concepts early will make the rest of the book more accessible.

SCADA	Supervisory Control and Data Acquisition. A system used to monitor and control industrial equipment and processes. In energy, SCADA systems manage pipelines, power grids, and processing plants.
DCS	Distributed Control System. A process control system used in refineries and processing plants to control continuous processes with high reliability and precision.
PLC	Programmable Logic Controller. An industrial computer used to automate specific processes, such as controlling pumps, valves, or compressors at field sites.
RTU	Remote Terminal Unit. A device that monitors field conditions at remote sites and transmits data to the SCADA master station.
HMI	Human Machine Interface. The operator interface to a SCADA or DCS system the screen and controls that a process operator uses to monitor and interact with the physical process.
SCCM / MCEM	System Center Configuration Manager / Microsoft Configuration and Endpoint Manager. The primary enterprise endpoint management platform used in most large energy companies for software deployment, patch management, and device configuration.
MDM	Mobile Device Management. A platform (typically Microsoft Intune in enterprise environments) used to manage, configure, and secure mobile devices including smartphones, tablets, and laptops.
GPO	Group Policy Object. A configuration mechanism in Active Directory environments that allows IT to enforce settings across large numbers of Windows devices.

NERC CIP	North American Electric Reliability Corporation Critical Infrastructure Protection standards. The primary cybersecurity regulatory framework for the bulk electric system in North America.
Purdue Model	The Purdue Enterprise Reference Architecture (PERA), a framework for organizing industrial control system networks into hierarchical levels (0–5). Widely used in energy to define the IT/OT boundary.
DMZ	Demilitarized Zone. In IT/OT contexts, a network segment that sits between the IT and OT networks, allowing controlled data exchange while preventing direct connectivity between the two environments.
Air Gap	A physical or logical separation between the IT and OT networks that prevents any direct network communication between them. Increasingly difficult to maintain as energy systems digitalize.

1.6 Real-World Context: The Colonial Pipeline Incident as a Lesson in IT Basics

No chapter on the energy IT landscape would be complete without acknowledging the Colonial Pipeline ransomware attack of May 2021, which stands as the defining case study of what can happen when IT security fails in an energy context. The incident is well-documented through public sources, congressional testimony, and regulatory filings, making it an appropriate reference point for this book.

CASE STUDY | Colonial Pipeline Ransomware Attack (May 2021) Public Record Summary

Background

Colonial Pipeline operates the largest fuel pipeline in the United States, transporting approximately 45% of the fuel consumed on

the East Coast. In May 2021, the company's IT network was compromised by the DarkSide ransomware group through a single compromised VPN account that lacked multi-factor authentication.

What Happened

The attackers accessed Colonial's IT network and deployed ransomware that encrypted approximately 100 GB of data. Critically, the operational technology (OT) systems that actually control the pipeline were not directly compromised the pipeline was shut down proactively by management out of concern that the IT compromise might spread to OT systems.

The Cascade

The six-day shutdown caused widespread fuel shortages across the Southeast United States, a declaration of regional emergency by the federal government, panic buying at gas stations, and an estimated \$4.4 million in ransom payment. The economic and social disruption was caused entirely by the IT failure not by any OT system compromise.

The IT Lesson

The compromised VPN credential was reportedly from an account that was no longer in active use but had not been decommissioned. Multi-factor authentication was not enforced on the VPN. These are basic IT hygiene failures the kind that endpoint and identity management professionals are directly responsible for preventing. The Colonial Pipeline incident is not a lesson about exotic attack techniques. It is a lesson about the consequences of basic IT failures in a critical infrastructure context.

Source

U.S. Senate Committee on Homeland Security and Governmental Affairs hearing testimony, June 2021. DOJ press release, June 7, 2021 (partial ransom recovery). CISA Alert AA21-131A.

The Colonial Pipeline incident illustrates a principle that runs throughout this book: in energy sector IT, the stakes of getting basic IT practices right are higher than in almost any other environment. The attack techniques were not sophisticated. The IT failures were not exotic. What made the outcome catastrophic was the context—critical energy infrastructure with cascading dependencies. This is the context in which every energy sector IT professional works.

1.7 The IT Professional's Mindset in the Energy Sector

Closing this chapter, it is worth reflecting on the mindset that effective energy sector IT professionals develop over time. This mindset is not taught in certification courses or vendor training programs. It is developed through experience—and reading accounts like this can accelerate it.

Think in Consequences, Not Just Probability

In most IT environments, risk is assessed primarily in terms of probability: how likely is this failure? In energy environments, consequences must be weighted as heavily as probability. A low-probability event that could affect a production system or create a safety hazard deserves more attention than a high-probability event with minor consequences. This consequence-weighted thinking shapes how energy IT professionals approach change management, security architecture, and incident response.

Earn the Right to Make Changes

In energy companies, the trust of operations teams is not given—it is earned. IT professionals who demonstrate that they understand operational context, communicate clearly about the implications of changes, and follow through on commitments

earn the latitude to operate effectively. Those who treat operations coordination as bureaucratic overhead learn, often through costly experience, that it is anything but.

Know Where the Boundaries Are

Understanding where IT's responsibility ends and OT's begins and never crossing that boundary without explicit coordination and authorization is a non-negotiable competency in energy sector IT. This means understanding the Purdue model, knowing which systems in any given location are IT versus OT, and having clear escalation paths when work approaches the IT/OT boundary.

Document Everything

Field knowledge in energy IT is often tribal: held in the heads of experienced individuals who have been on-site, know the quirks of specific locations, and understand the organizational history of particular systems. When those individuals leave, that knowledge walks out with them. Energy sector IT organizations that invest in systematic documentation of site configurations, deployment procedures, known issues, and escalation contacts are significantly more resilient than those that do not.

The best energy IT professionals are not the ones who know the most about Microsoft. They are the ones who understand the most about the business they are serving.

Senior IT Director, Large Midstream Energy Company
(Anonymous)

This chapter has established the foundational context for everything that follows in this book. The key points:

- Energy sector IT is categorically different from IT in other industries due to geographic dispersion, consequence asymmetry, the OT/IT boundary, the production-first culture, and a dense regulatory environment.
- Energy companies have multiple distinct IT environments corporate offices, industrial operations sites, and remote field locations each with different requirements, constraints, and risk profiles.
- The stakeholder landscape in energy IT is more complex than in most sectors, including operations teams, the CISO organization, compliance and legal, application owners, and external vendors.
- The IT/OT boundary is one of the most important concepts in energy sector IT. Understanding the Purdue model and respecting the boundary between IT and OT systems is a core competency.
- The Colonial Pipeline incident of 2021 demonstrates that basic IT failures compromised credentials, lack of MFA, poor account lifecycle management can have catastrophic consequences in energy sector contexts.
- Effective energy sector IT professionals develop a consequence-weighted risk mindset, earn operational trust through demonstrated competence and communication, and invest in documentation as a resilience strategy.

Chapter 1 Checklist: Orientation for Energy Sector IT

Use this checklist when joining an energy company or taking on a new role in energy sector IT:

- ☐ Understand the geographic scope of your organization map corporate, regional, and field locations and their connectivity profiles
- ☐ Identify which locations have on-site IT staff and which rely entirely on remote management
- ☐ Map the IT/OT boundary at your organization understand which systems are IT, which are OT, and where the DMZ sits
- ☐ Identify the key OT systems in use (SCADA platform, DCS vendor, PLC types) and the teams responsible for them
- ☐ Meet the OT engineering and SCADA operations teams establish working relationships before you need them
- ☐ Understand your organization's change management process and when operations coordination is required
- ☐ Know the applicable regulatory frameworks NERC CIP, TSA Pipeline Security Directives, CISA guidelines that govern your environment

- ☐ Identify your CISO and understand the security team's current priorities and mandatory baseline configurations
- ☐ Map the application portfolio understand which applications are business-critical and who the application owners are
- ☐ Identify the enterprise endpoint management platform in use (SCCM/MCEM, Intune, or both) and the team responsible for it
- ☐ Understand the connectivity profiles of remote and field sites bandwidth, latency, and available management protocols
- ☐ Review existing documentation for the environments you manage assess where gaps exist
- ☐ Establish contact with field IT staff, regional IT leads, and vendor contacts for key systems

References and Further Reading

The following sources were consulted in the preparation of this chapter and are recommended for further reading:

Regulatory and Government Sources

CISA Alert AA21-131A: Darkside Ransomware: Best Practices for Preventing Business Disruption from Ransomware Attacks. Cybersecurity and Infrastructure Security Agency, 2021.

U.S. Senate Committee on Homeland Security and Governmental Affairs. Hearing: Cyber Threats in the Pipeline: Using Lessons from the Colonial Pipeline Cyber Attack to Strengthen Resilience. June 8, 2021.

U.S. Department of Energy, Office of Cybersecurity, Energy Security, and Emergency Response (CESER). Cyber Baselines for Electric Distribution Systems and DER. DOE, 2022.

IEC 62443 Series: Security for Industrial Automation and Control Systems. International Electrotechnical Commission.

NERC CIP Standards (CIP-002 through CIP-014). North American Electric Reliability Corporation. Available at: nerc.com

Industry Research and Analysis

Protiviti. Energy and Utility OT and IT Convergence Efforts Bring Opportunity Amid Challenges and Risk. Protiviti Inc., 2022.

IBM Security. X-Force Threat Intelligence Index 2022. IBM Corporation, 2022.

International Energy Agency (IEA). Digitalization and Energy. IEA Publications, 2022.

KPMG. Cybersecurity Considerations for Energy and Natural Resources. KPMG LLP, 2022.

Technical References

Williams, T.J. The Purdue Enterprise Reference Architecture. Computers in Industry, 24(2-3), 141-158. Elsevier, 1994.

Stouffer, K., Falco, J., & Scarfone, K. Guide to Industrial Control Systems (ICS) Security. NIST Special Publication 800-82, Rev. 2. NIST, 2015.

CHAPTER 2

Endpoint Management at Scale

Managing Thousands of Devices Across the Enterprise

The endpoint is where IT policy meets operational reality. Every configuration decision you make at the management console eventually runs on a device that someone depends on to do their job sometimes in a place where you cannot reach them.

Enterprise Endpoint Architect, Energy Sector

2.1 The Endpoint Management Challenge in Energy Companies

Managing endpoints in an energy company is, at its core, a logistics problem with a security constraint and an operational risk overlay. The logistics problem: how do you consistently deploy, configure, patch, and support thousands of Windows devices distributed across dozens or hundreds of locations many with limited connectivity and no on-site IT staff? The security constraint: every unpatched or misconfigured endpoint is a potential entry point for a threat actor targeting your environment. The operational risk overlay: any endpoint management action that disrupts production systems carries consequences that go well beyond a help desk ticket.

The tools that energy sector IT professionals use to address this challenge are the same ones found in most large enterprises: Microsoft Configuration Manager (widely known as SCCM, and now formally named Microsoft Endpoint Configuration Manager or MECM), Microsoft Intune, and the increasingly common co-management architecture that bridges the two. But the way these tools must be configured and operated in an energy context is shaped by the sector's unique characteristics and most of the documentation for these tools was not written with energy sector constraints in mind.

This chapter covers the full lifecycle of enterprise endpoint management in energy environments: the architecture of SCCM/MECM and its relationship with Intune, deployment strategies for low-bandwidth and remote sites, application packaging standards and the tools used to implement them, patch management in production-adjacent environments, and the operational practices that separate effective energy sector endpoint teams from struggling ones.

2.2 SCCM / MECM: The Backbone of Enterprise Endpoint Management

Microsoft Configuration Manager which has gone through several name changes in its history, from Systems Management Server (SMS) to SCCM to MECM has been the dominant enterprise endpoint management platform in large organizations for more than two decades. In most large energy companies, it remains the authoritative system for Windows device management, software deployment, operating system imaging, and patch management.

Understanding SCCM's architecture is essential for anyone working in enterprise IT in the energy sector. The platform is powerful and flexible, but it rewards those who invest in

understanding it deeply and punishes those who treat it as a black box.

Core Architecture Components

A large-scale SCCM deployment consists of several key components that work together to manage devices across the enterprise:

- **Primary Site Server:** The central management authority for a defined set of devices. In most large energy companies, there is a single primary site server located at headquarters, with secondary sites at major regional locations. The primary site hosts the central SQL database, the site server role, and typically the Management Point and Distribution Point for HQ.
- **Secondary Sites:** Lightweight child sites deployed at regional offices or large operational sites. Secondary sites provide local Management Points and Distribution Points, reducing WAN traffic for content delivery and policy retrieval. They replicate summary data to the primary site.
- **Management Point (MP):** The site system role that acts as the primary interface between SCCM clients and the site. Clients contact the Management Point to download policy, report status, and request software deployments. In large environments, multiple MPs are deployed for load balancing.
- **Distribution Point (DP):** The site system role that stores content software packages, OS images, scripts and delivers it to SCCM clients. Distribution Points can be deployed at remote sites to cache content locally, eliminating the need to pull large files over WAN links during deployments.
- **Software Update Point (SUP):** The WSUS-integrated role that manages patch deployment. The SUP synchronizes with Microsoft Update, hosts approved updates, and

delivers them to SCCM clients according to configured deployment schedules.

- Cloud Management Gateway (CMG): An Azure-hosted SCCM component that enables management of internet-based devices laptops used by remote workers, devices that are rarely on the corporate network without VPN. The CMG is increasingly important in energy companies with large field operations and remote workers.

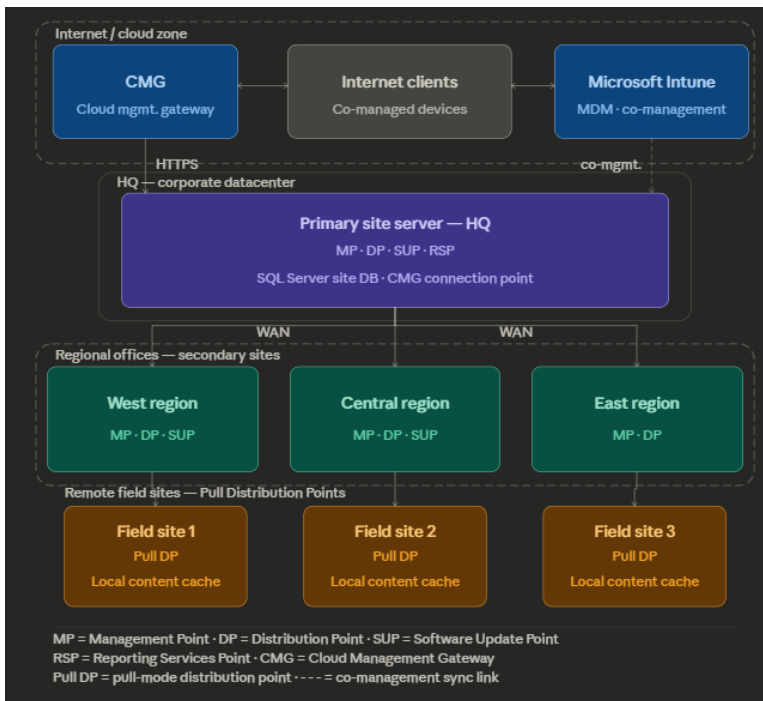


Figure 2.1 A representative SCCM/MCEM architecture for a large energy company. Secondary sites reduce WAN traffic at regional offices. Pull Distribution Points at field sites cache content locally. The Cloud Management Gateway (CMG) and Microsoft Intune extend management to internet-based and co-managed devices. MP=Management Point, DP=Distribution Point, SUP=Software Update Point.

Sizing and Boundary Design

One of the most consequential architectural decisions in any SCCM deployment is boundary design the configuration that tells the SCCM client which site system (Management Point, Distribution Point) it should contact based on its network location. Poor boundary design leads to clients contacting distant site systems over WAN links, causing slow policy downloads, failed deployments, and increased network utilization.

In energy company environments, boundary design must account for the full range of location types: corporate offices with reliable LAN connectivity, regional offices connected via MPLS, and field sites on cellular or satellite links. The general principle is that every location should have a local or regionally proximate Distribution Point for content delivery, and boundaries should be configured to ensure clients resolve to the nearest available content source.

PRACTITIONER TIP: Pull Distribution Points for Remote Sites



For remote field sites with limited bandwidth, configure Pull Distribution Points rather than standard DPs. A Pull DP copies content from a parent DP on a scheduled basis typically during off-peak hours rather than receiving pushed content. This allows the administrator to control when large content transfers consume the limited WAN link, and ensures that content is available locally for deployment without impacting operational communications during business hours.



COMMON MISTAKE: Single-Site Architecture for Multi-Site Environments

One of the most common endpoint management mistakes in growing energy companies is maintaining a single-site SCCM architecture long after the device fleet has grown to include

remote and field locations. A single primary site without secondary sites or regional DPs forces all clients to contact HQ for policy and content which works acceptably for corporate devices on the LAN, but creates deployment failures, timeouts, and bandwidth saturation at remote sites. The time to architect for geographic distribution is before you have hundreds of devices at remote sites, not after.

Collections: The Foundation of Targeted Deployment

Collections are one of the most important and most misunderstood components of SCCM. A collection is a group of resources devices or users defined by membership rules. Collections are the targeting mechanism for deployments, policies, and reports. Effective collection design is the difference between a deployment that reaches exactly the right devices at the right time and one that either misses devices or impacts unintended systems.

In energy environments, collection design should reflect the organizational structure and operational risk profile. Key collection categories include: site-based collections (devices at specific locations), role-based collections (devices performing specific functions field supervisor workstations, control room desktops), OS-based collections (devices on specific Windows versions for upgrade targeting), and compliance collections (devices that are missing patches or failing compliance baselines).

Limiting collections particularly for software deployments are a best practice that energy sector teams should embrace. A limiting collection constrains the maximum membership of a child collection, ensuring that a deployment can never inadvertently reach devices outside the intended scope. This is particularly important in energy environments where a deployment reaching the wrong device an engineering

workstation adjacent to the OT environment, for example could have unintended consequences.

PRACTITIONER TIP: Use Limiting Collections to Prevent Scope Creep



Always define deployments against a specifically scoped collection, and set a limiting collection that reflects the boundaries of your intended scope. For any deployment that could affect operationally sensitive systems, create an explicit exclusion collection for those devices and subtract it from your target collection. Document the logic of every production deployment collection in your change management system.

2.3 The Move to Co-Management: SCCM + Intune

The most significant shift in enterprise endpoint management over the past five years has been the move toward co-management the simultaneous management of Windows devices by both SCCM and Microsoft Intune. Co-management is Microsoft's bridging architecture for organizations transitioning from purely on-premises management toward cloud-native management, and it is the current standard deployment model for most large energy companies.

Understanding co-management requires understanding what each platform brings to the table and why the answer for most large energy companies is not one or the other, but both.

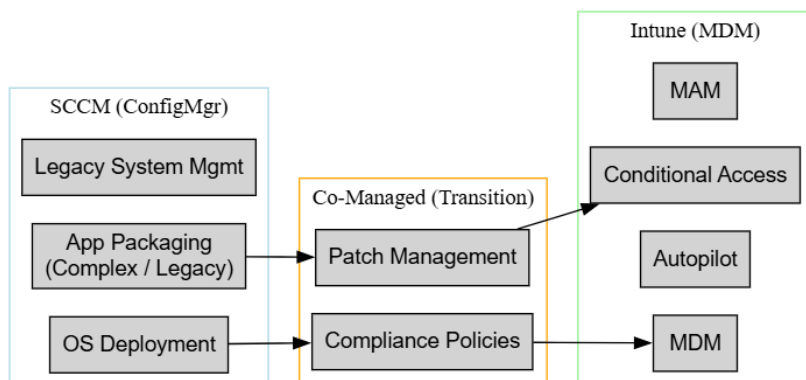


Figure 2.2 — Co-management workload distribution. The center column represents workloads whose authority can be set to either SCCM or Intune and migrated over time. In energy environments, the migration should be gradual and validated at each stage before proceeding. Source: Microsoft documentation / industry practice.

What SCCM Does Best in Energy Environments

Despite the industry's momentum toward cloud-native management, SCCM retains clear advantages for specific use cases that are particularly relevant in energy environments:

- **Operating System Deployment (OSD):** SCCM's task sequence engine for imaging and deploying Windows is significantly more powerful than Intune's Autopilot for complex deployment scenarios. In energy environments with diverse hardware across field and corporate sites, OSD via SCCM remains the most reliable mechanism for large-scale Windows deployments and upgrades.
- **Complex Application Packaging:** Large enterprise applications with complex dependencies, multi-step installation sequences, and pre/post-installation scripts are better handled by SCCM's application model than by Intune. Applications that require reboot chaining, driver installation, or interaction with existing software are typically deployed via SCCM.

- **Low-Bandwidth Site Management:** SCCM's Distribution Point architecture, with its local content caching and scheduled transfer capabilities, is purpose-built for the bandwidth-constrained environments common at energy field sites. Intune's content delivery model is more dependent on internet connectivity and is less suitable for sites with unreliable or limited bandwidth.
- **Detailed Hardware and Software Inventory:** SCCM's hardware and software inventory capabilities are richer and more customizable than Intune's, providing detailed asset data that is essential for software license management, hardware refresh planning, and compliance reporting in large enterprises.

What Intune Adds in Energy Environments

Intune's value in energy environments is primarily in scenarios that SCCM was not designed for:

- **Internet-Based Device Management:** Energy companies increasingly have users executives, field supervisors with laptops, remote engineers who are rarely on the corporate network. Intune manages these devices natively without requiring VPN, and the Cloud Management Gateway provides a bridge for devices that need to remain in the SCCM inventory as well.
- **Mobile Device Management:** SCCM has no mobile device management capability. Intune is the platform of choice for managing iOS and Android devices, which are increasingly deployed in energy field operations for inspection apps, communication, and data collection.
- **Conditional Access Integration:** Intune's integration with Microsoft Entra ID (formerly Azure AD) enables Conditional Access policies that enforce device compliance as a condition of accessing corporate resources. This is an important security control for

energy companies managing access to sensitive systems.

- Zero-Touch Provisioning via Autopilot: For new device deployments, Windows Autopilot eliminates the need for IT to manually image and configure devices, allowing devices to be shipped directly to end users and self-configure on first boot. This is particularly valuable for field site deployments where IT staff cannot be physically present.

PRACTITIONER PERSPECTIVE | Senior Endpoint Engineer | Large Midstream Energy Company (Anonymous)

"What was the hardest part of planning your co-management rollout?"

The hardest part was not the technology it was the governance. We had to decide who owned which workload: the desktop team that had managed SCCM for years, or the newer cloud team that owned the Intune tenant. We also had to define what 'done' looked like for each workload migration. Our advice: define workload ownership and success criteria before you enable co-management on a single device. The technology is flexible. The organizational alignment is what takes time.

Co-Management Rollout Strategy for Energy Companies

Rolling out co-management in an energy environment requires a phased approach that respects the production-first culture and manages organizational change carefully. A recommended sequence:

- Enable Tenant Attach First: Before enabling co-management, enable Tenant Attach, which uploads SCCM device data to the Intune portal without

transferring workload authority. This gives your team visibility into the Intune console and allows you to validate the integration before making any management changes.

- **Start with a Pilot Collection:** Define a small, controlled pilot collection of corporate devices at HQ typically IT department devices and volunteers. Enable co-management for this collection only, with all workloads initially pointing to SCCM. Validate that devices are dual-enrolled and appearing correctly in both consoles.
- **Migrate Low-Risk Workloads First:** Compliance Policies and Endpoint Protection (Defender) are typically the first workloads to migrate to Intune, as they have minimal impact on production systems and provide immediate security benefits. Validate compliance reporting in Intune before proceeding.
- **Expand Geographically in Stages:** After validating the pilot, expand co-management to regional offices, then to field sites. Each expansion should be monitored for at least two weeks before proceeding to the next tier. Pay particular attention to bandwidth impact at remote sites.
- **Migrate Remaining Workloads Cautiously:** Windows Update policies, Resource Access, and Device Configuration workloads should be migrated only after extensive validation. In energy environments, patch deployment schedules and maintenance windows are often tied to production schedules ensure that Intune's Windows Update for Business configurations replicate the same windows before migrating.

!

COMMON MISTAKE: Migrating All Workloads at Once

The most dangerous co-management mistake is treating workload migration as a single cutover event rather than a gradual process. Organizations that migrate all workloads from SCCM to Intune simultaneously lose the ability to fall back to SCCM if issues arise, and may find that critical deployment capabilities particularly for field-site low-bandwidth scenarios do not work as expected in the cloud-native model. In energy environments, a failed patch deployment is not just an IT problem; it can leave systems vulnerable at sites where the next IT visit may be weeks away.

2.4 Application Packaging: Standards, Tools, and the Art of Repeatability

Application packaging is one of the most specialized disciplines in enterprise IT and one of the most important in energy environments, where hundreds of applications must be deployed to thousands of devices, often without user interaction and at scheduled times that minimize production impact. A well-packaged application installs silently, consistently, and cleanly on any compliant endpoint. A poorly packaged application generates help desk tickets, failed deployments, and user frustration.

The tools used for enterprise application packaging have evolved over the years, but the core workflow capture, package, test, deploy remains consistent. In energy environments, this workflow must be combined with rigorous documentation, version control, and approval processes that reflect the organization's change management requirements.

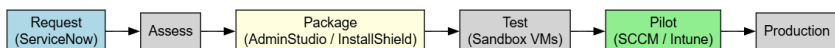


Figure 2.3 The enterprise application packaging lifecycle in an energy company context. Total cycle time typically ranges from 2 to 4 weeks for standard packages and 4 to 8 weeks for complex enterprise applications. The feedback loop from Test back to Package reflects the rework cycle when issues are discovered during QA.

The Windows Installer (MSI) Standard

The Microsoft Windows Installer (MSI) format has been the standard for enterprise application deployment for more than two decades. An MSI package is a relational database that contains all of the files, registry entries, shortcuts, and installation logic required to install, repair, or remove an application. Its transactional installation model means that if an installation fails, the system is returned to its pre-installation state—a critical property for enterprise deployments where a partially installed application can be worse than no installation at all.

In enterprise environments, most commercial software is delivered by vendors in one of three forms: as a native MSI, as an EXE installer that wraps an MSI, or as a legacy installer that predates Windows Installer. The packaging engineer's job is to transform these into consistently deployable, silently installable packages that comply with the organization's deployment standards.

Key MSI concepts every endpoint professional in an energy environment should understand include: transforms (MST files that customize an MSI without modifying the original), patches (MSP files that update an existing installation), properties (variables that control installation behavior, such as install directory and license key), and custom actions (scripts or executables that run during installation to perform operations the MSI engine cannot handle natively).

AdminStudio: The Enterprise Packaging Platform

Flexera AdminStudio is the industry-standard tool for enterprise application packaging in large organizations. It combines several capabilities into a single platform: application repackaging (converting legacy installers to MSI format), MSI editing and customization, compatibility testing (checking applications against operating system changes and other applications in the portfolio), and integration with deployment platforms including SCCM and Intune.

AdminStudio's Repackager captures the changes an installer makes to a clean machine files, registry entries, services, shortcuts and converts them into an MSI package. The Tuner component creates MST transform files that customize existing MSI packages, allowing IT to configure settings such as installation directory, license keys, and feature selection without modifying the vendor's original installer.

The Test Center component, available in the Enterprise edition, automates compatibility testing against Windows OS versions and other applications in the catalog a significant time saver in environments where compatibility must be validated before any deployment to production. The Application Catalog provides a centralized repository of all packaged applications, with version tracking and deployment readiness status.

PRACTITIONER TIP: Clean Machine Standards



Always repackage applications on a clean, standardized baseline machine a virtual machine with only the OS, runtime prerequisites, and monitoring tools installed. Repackaging on a machine with existing software increases the risk of capturing unrelated registry entries and files in the package, which can cause conflicts in production. Document and maintain clean machine images as part of your packaging infrastructure. When the OS baseline changes (e.g., a major Windows update), rebuild your clean machines and re-validate your most critical packages.

InstallShield: Deep Package Authoring

InstallShield is the most widely used tool for creating and editing MSI packages from scratch or making significant modifications to existing ones. Unlike AdminStudio's Repackager, which captures changes from an installation, InstallShield is a full MSI authoring environment that allows packaging engineers to construct packages with precise control over every aspect of the installation: file placement, registry entries, custom actions, user interface dialogs, prerequisites, and upgrade logic.

In enterprise environments, InstallShield is typically used for: creating installation wrappers around applications that have no MSI; customizing vendor MSI packages that require modifications beyond what a transform can accomplish; creating pre/post-installation scripts that interact with the Windows environment; and managing complex upgrade scenarios where the major upgrade logic needs to be customized.

Wise Package Studio: Legacy Expertise

Wise Package Studio (now largely superseded by AdminStudio in most enterprise environments) was the dominant application packaging platform for many years before Flexera's tools became the industry standard. Many energy companies with long-established IT operations still maintain Wise Package Studio skills and legacy packages in Wise format. The Wise Script programming language, used in Wise packages, provides capabilities for complex custom installation logic that some packaging engineers prefer for specific scenarios.

IT professionals joining an energy company with a mature application portfolio may encounter Wise Package Studio packages dating back a decade or more. Migrating these legacy packages to modern MSI or MSIX format is a long-running project at many organizations one that requires both packaging skill and careful regression testing.

CASE STUDY | Windows 10 Migration at a Large Pipeline Operator Illustrative Composite

Scenario

A large pipeline operator with approximately 8,000 managed endpoints needed to migrate from Windows 7 to Windows 10 across corporate offices, regional locations, and dozens of field sites. The application portfolio included over 400 packaged applications, many of which had been in production since the Windows XP era and had unknown compatibility with Windows 10.

Approach

The IT team used AdminStudio's compatibility testing module to assess the application portfolio against Windows 10. The assessment identified approximately 60 applications requiring remediation either repackaging, compatibility fixes, or vendor-supplied updates. A dedicated packaging lab with clean Windows 10 VMs was established. Applications were remediated in batches, with business-critical and field-site applications prioritized.

Field Site Challenge

The most complex aspect of the deployment was field sites with satellite connectivity averaging 512 kbps. The team configured Pull Distribution Points at each field site, with content transfer scheduled between midnight and 4 a.m. local time. OS deployment was performed using SCCM Task Sequences triggered manually by site supervisors from a pre-staged boot USB, with the actual installation completing from the local DP cache.

Outcome

The migration was completed over 18 months, with zero production incidents at field sites. The packaging team documented all remediation procedures and created a library of reusable custom actions that reduced packaging time for subsequent projects. The field site deployment model became the standard template for all subsequent large-scale deployments.

Key Lesson

The investment in pre-staging content at field Distribution Points and scheduling transfers during off-peak hours was the single most important factor in the success of the field site deployments. Any team managing endpoints at remote sites should establish this pattern as standard practice, not a workaround.

2.5 Patch Management in Production-Adjacent Environments

Patch management is where endpoint management intersects most directly with operational risk in energy environments. Every IT professional knows that unpatched systems are vulnerable systems. Every energy operations team knows that a patch that requires a reboot at the wrong time can disrupt production monitoring, interrupt communication with field systems, or cause a SCADA historian to miss data. Managing this tension—the urgency of patching versus the risk of disruption—is one of the defining challenges of energy sector endpoint IT.

The Maintenance Window Framework

The fundamental mechanism for managing patch-related risk in SCCM is the maintenance window—a defined time period during which software deployments and restarts are permitted. Maintenance windows in energy companies must be defined in close coordination with operations teams, and they typically reflect the operational schedules of the sites they cover.

Common maintenance window patterns in energy environments include: extended overnight windows at corporate offices (e.g., midnight to 4 a.m. on weekdays), weekend windows at operational sites where shift changes reduce the impact of disruption, and exception windows for critical security patches that need to be deployed outside the standard schedule.

The critical discipline in maintenance window management is consistency: windows must be defined, communicated, and respected. Deployments that execute outside defined maintenance windows whether through misconfiguration or emergency response erode the trust of operations teams and create pressure to restrict IT access to systems. The long-term cost of an ad hoc patch deployed outside the maintenance window is almost always higher than the short-term benefit.

PRACTITIONER TIP: Separate Emergency Patch Procedures from Standard Operations



Establish a documented emergency patch procedure distinct from your standard deployment process for critical vulnerabilities that require deployment faster than your standard maintenance window schedule allows. This procedure should define the criteria for invoking it (e.g., CVSS score above 9.0 and active exploitation), the approval chain required, the notification process for operations teams, and the rollback procedure if issues are encountered. Having this procedure written down and approved in advance means you can execute it quickly when needed, without improvising.

The WSUS Integration and Patch Compliance Reporting

SCCM's Software Update Point integrates with Windows Server Update Services (WSUS) to synchronize Microsoft patches and provide patch compliance reporting. The compliance reporting capability showing which devices have and have not applied each patch is one of SCCM's most valuable features in regulated environments where patch compliance must be demonstrated to auditors.

Configuring SCCM patch compliance reporting for an energy environment requires decisions about: classification and product

synchronization (which types of updates and which Microsoft products to synchronize), automatic deployment rules (ADRs) for automating the creation and deployment of patch bundles on a defined schedule, and software update groups for organizing patches by compliance period.

For environments subject to NERC CIP or other regulatory frameworks, patch compliance reporting must be maintained at a higher level of rigor than in unregulated environments. This typically means monthly compliance reports that show patch status per device, per site, and per regulatory classification, with documented exceptions for devices that cannot be patched within the standard window due to operational constraints.

COMMON MISTAKE: Treating All Endpoints the Same for Patching

!

A common and consequential mistake is applying the same patch deployment configuration to all devices regardless of their operational context. A laptop used by a corporate accountant can be patched on a Tuesday night without operational consequence. A workstation used by a control room operator at a processing plant needs a patching window that aligns with shift changes and has been coordinated with the operations supervisor. Failing to differentiate can result in a reboot at a workstation that a field operator is actively using, creating an operational disruption and destroying the IT team's credibility with operations.

Third-Party Patch Management

SCCM's native patch management covers Microsoft products. Third-party applications Adobe, Google Chrome, 7-Zip, Java, and the dozens of specialized engineering and business applications in a typical energy company portfolio require either manual patching, a third-party patch catalog solution (such as

those from Flexera or Ivanti), or PowerShell-based remediation scripts deployed via SCCM.

Third-party patch management is frequently the weakest link in energy sector endpoint security. The combination of a large application portfolio, limited packaging bandwidth, and rigorous change management processes creates a situation where third-party applications often lag significantly behind current versions. Addressing this requires a dedicated effort: cataloging the application portfolio, assigning ownership for patching each application, and establishing a regular cadence for third-party patch deployment separate from the Microsoft Patch Tuesday cycle.

2.6 Proof of Concept Environments: Testing Before Mass Deployment

One practice that distinguishes effective endpoint management teams in energy environments from their less mature counterparts is the systematic use of Proof of Concept (POC) environments for testing changes before they reach production. In most IT environments, POC testing is good practice. In energy environments, it is essential.

A well-designed POC environment for energy sector endpoint management should include: virtual machines that replicate the hardware profiles of production endpoints at different site types (corporate laptop, field site workstation, mobile device); representative application installations that mirror a production device; network simulation capabilities that can throttle bandwidth to replicate remote site connectivity; and a process for documenting and tracking test results.

POC environments serve multiple purposes: they allow IT teams to validate that software packages install correctly before deployment to production; they allow security teams to assess the impact of new configurations before they are applied

enterprise-wide; and they provide a documented record of pre-deployment testing that can be referenced during change management reviews or post-incident investigations.

PRACTITIONER TIP: Maintain a 'Mirror of Worst Case'



Your POC environment should include at least one machine that mirrors your most constrained production environment typically a virtual machine throttled to the bandwidth available at your least-connected field site. If a deployment works in your lab but fails in production, the first thing you will be asked is whether you tested it under the conditions it failed in. Maintaining a worst-case mirror means you can answer that question confidently, and you are more likely to catch bandwidth-sensitive failures before they reach production.

2.7 Windows 10/11 Management and the Modern Endpoint

Windows 10 and Windows 11 introduce a management model variously called Modern Management or Cloud-First Management that differs significantly from the Group Policy-centric management of earlier Windows versions. The modern management model emphasizes MDM-based configuration via OMA-URI settings and Intune Configuration Profiles over traditional GPO, and Autopilot-based provisioning over imaging-based deployment.

For energy companies, the transition to modern management is gradual and uneven. Most large energy companies are in a hybrid state: corporate laptops may be fully cloud-managed via Intune, regional office workstations may be co-managed, and field site desktops may still be managed entirely via SCCM with traditional GPO. This hybrid state is stable and sustainable as

long as the management boundaries are clearly defined and consistently enforced.

Windows Hello for Business in Energy Environments

Windows Hello for Business (WHfB) replaces password-based authentication with certificate-based or biometric authentication, providing a significantly stronger authentication mechanism for Windows devices. The deployment of WHfB in energy environments requires coordination between the endpoint team (who configures the client-side policy), the identity team (who provisions the certificate infrastructure), and the security team (who defines the authentication requirements).

In energy environments, the adoption of Windows Hello for Business is often uneven: it works well for corporate and regional office users with reliable connectivity, but may encounter challenges at field sites where local domain controllers are not available and network connectivity for certificate validation is intermittent. Planning the WHfB deployment to account for these variations using hybrid key trust or certificate trust models appropriate for the connectivity profile of each site type is essential for a successful rollout.

BeyondTrust Endpoint Privilege Management (EPM)

BeyondTrust Endpoint Privilege Management addresses one of the most persistent challenges in enterprise endpoint management: the tension between security (users should not have local administrator rights) and operations (many enterprise applications require elevated privileges to install, update, or run correctly). EPM resolves this tension by allowing specific applications to run with elevated privileges on demand, without granting the user permanent local administrator rights.

In energy environments, EPM is particularly valuable because the application portfolio often includes specialized engineering tools, field data collection software, and legacy applications that were designed with the assumption of local administrator

access. EPM allows these applications to function correctly while the endpoint operates in a standard-user security context a significant security improvement that also satisfies audit requirements for least-privilege enforcement.

The deployment of EPM requires a thorough application portfolio analysis to identify which applications need elevation and what type of elevation they require. This analysis sometimes called an elevation catalog becomes the basis for EPM policy configuration. In large energy companies, building the elevation catalog is typically a multi-month effort, but the security improvement and audit documentation it provides are well worth the investment.

COMMON MISTAKE: Granting Blanket Local Admin Rights as a Workaround

!

The most common EPM anti-pattern in energy environments is using local administrator rights as the solution to every application installation problem. When an engineering team reports that their specialized software will not install without local admin, the path of least resistance is to add their workstations to the local administrators group. Over time, this creates a large population of devices with excessive privilege every one of which is a higher-value target for an attacker who gains a foothold on the network. EPM exists specifically to eliminate this tradeoff. The upfront investment in cataloging elevation requirements pays for itself the first time a targeted attack on a privileged endpoint is stopped.

2.8 PowerShell: The Endpoint Manager's Force Multiplier

PowerShell is the scripting and automation backbone of enterprise Windows management. For endpoint management

professionals in energy companies, PowerShell fluency is not optional it is essential. Nearly every repetitive task in SCCM, Intune, Active Directory, and Windows administration can be automated with PowerShell, and the ability to write reliable, readable PowerShell scripts is one of the most valuable skills an endpoint manager can develop.

Common PowerShell use cases in energy sector endpoint management include: querying SCCM collections and device inventory for compliance reporting; deploying configuration changes to groups of devices; automating the creation and management of SCCM packages and deployments; interacting with the Intune Graph API for device management tasks; generating audit-ready compliance reports; and running pre/post-installation scripts as part of complex application deployments.

SCCM-Specific PowerShell Patterns

SCCM exposes a comprehensive PowerShell module (ConfigurationManager.psd1) that provides cmdlets for nearly every management function. Key patterns include: using Get-CMDevice and related cmdlets to query device collections and inventory data; using New-CMPackage, New-CMProgram, and Start-CMContentDistribution to automate package creation and distribution; and using Invoke-CMQuery to run custom WQL queries against the SCCM database for reporting.

Intune Graph API Automation

Microsoft Intune is managed via the Microsoft Graph API, which can be accessed via PowerShell using the Microsoft.Graph module. Automation patterns via Graph include: bulk device management operations (triggering sync, reboot, or compliance check on collections of devices); configuration profile management (creating, updating, and assigning configuration profiles programmatically); and compliance reporting (extracting device compliance status for audit reporting).

PRACTITIONER TIP: Build a Script Library with Version Control



Every endpoint management team should maintain a version-controlled library of PowerShell scripts organized by function (SCCM management, Intune management, reporting, remediation) with documentation headers that explain what each script does, what parameters it accepts, and what assumptions it makes. Energy companies' IT teams often have high turnover in junior roles, and a well-documented script library is a key component of operational resilience. Store this library in a version control system (Git) even if the rest of your IT organization does not use version control the discipline of committing changes with meaningful descriptions is worth developing.

2.9 Operational Maturity: What Good Looks Like

Closing this chapter, it is worth describing what endpoint management operational maturity looks like in an energy sector context. The characteristics below distinguish high-performing endpoint teams from those that are perpetually reactive:

Proactive vs. Reactive Posture

Mature endpoint teams anticipate change new application versions, upcoming OS releases, security baselines and build them into a planned roadmap rather than responding reactively when they become urgent. They have visibility into their patch compliance posture at all times, not just when an audit is imminent. They conduct regular reviews of their POC environments to ensure they remain current with production configurations.

Clear Ownership and Escalation Paths

Every device in the fleet has a clearly defined owner either a specific user or an operations team and there are clear escalation paths for issues at each site type. The field IT team knows which corporate resources to contact for SCCM infrastructure issues, which operations contacts to notify before conducting any activity at a production site, and which security contacts to engage if a potential compromise is detected.

Documentation as a First-Class Practice

Mature teams treat documentation as part of the job, not an afterthought. Packaging procedures, deployment runbooks, site-specific quirks, known issues, and exception documentation are maintained in a knowledge management system that new team members can access and use effectively. This documentation discipline is particularly important in energy environments where field knowledge is hard to acquire and easy to lose when experienced staff move on.

Metrics and Reporting

High-performing endpoint teams track and regularly report on: patch compliance rate (by site type and overall), software deployment success rate, inventory freshness (percentage of devices that have checked in within the last X days), and endpoint security posture (percentage of devices with active AV, compliant configuration, and current patches). These metrics are reported to IT leadership and, where relevant, to the CISO and compliance teams, creating organizational visibility into the state of endpoint health.

Endpoint management at scale in energy environments requires mastery of SCCM/MCEM architecture and its integration with Microsoft Intune through co-management. The key principles:

- SCCM architecture must be designed for geographic distribution: secondary sites, pull distribution points at remote locations, and cloud management gateways for internet-based devices are not optional in energy environments they are architectural necessities.
- Co-management is the current standard deployment model, with workloads migrated gradually from SCCM to Intune as organizations build cloud management maturity. Never rush workload migration in energy environments where the consequences of misconfiguration extend beyond the IT function.
- Application packaging quality is foundational to deployment reliability. AdminStudio, InstallShield, and the Windows Installer standard provide the tools; clean machine discipline, rigorous testing, and documented standards provide the practice.
- Patch management must be integrated with operational schedules. Maintenance windows defined in coordination with operations teams are the mechanism that allows security-critical patching to proceed without operational disruption.
- Proof of Concept environments that replicate production conditions including bandwidth constraints at remote sites are essential for validating changes before they reach systems that matter.
- BeyondTrust EPM eliminates the false choice between security (remove local admin) and operations (applications need elevation). It is one of the highest-value security investments an energy sector endpoint team can make.
- PowerShell automation transforms endpoint management from a manually intensive operation into a scalable, repeatable practice. Build a version-controlled script library early and maintain it as a team asset.

Chapter 2 Checklist: Endpoint Management Readiness

- ☐ SCCM primary site and secondary sites are deployed at all major regional locations
 - ☐ Pull Distribution Points are deployed at all field and remote sites with limited bandwidth
 - ☐ Boundaries and Boundary Groups are configured to ensure clients resolve to the nearest content source
 - ☐ Cloud Management Gateway is configured for internet-based device management
 - ☐ Co-management is enabled with tenant attach and a clearly documented workload migration plan
 - ☐ Maintenance windows are defined per site type and documented in coordination with operations teams
-
- ☐ Application packaging standards are documented (MSI format, silent install, transform-based customization)
 - ☐ A clean machine image is maintained for application repackaging activities
-
- ☐ POC environment includes a simulated low-bandwidth remote site scenario
-
- ☐ Patch compliance reporting is configured and reported monthly to IT leadership and CISO
 - ☐ BeyondTrust EPM or equivalent elevation management is deployed to eliminate blanket local admin rights

- ❑ Emergency patch procedure is documented, approved, and accessible to the on-call team
- ❑ PowerShell script library is maintained in version control with documentation headers
- ❑ Third-party patch management process is defined with ownership and cadence for each application category
- ❑ Endpoint compliance metrics (patch rate, deployment success rate, inventory freshness) are tracked and reported

References and Further Reading

Microsoft Documentation

Microsoft. *Introduction to Configuration Manager*. Microsoft Learn, docs.microsoft.com/mem/configmgr. Continuously updated.

Microsoft. *What is co-management?* Microsoft Learn, docs.microsoft.com/mem/configmgr/comanage. Continuously updated.

Microsoft. *Cloud Management Gateway Overview*. Microsoft Learn, docs.microsoft.com/mem/configmgr/core/clients/manage/cmng. Continuously updated.

Microsoft. *Windows Autopilot Overview*. Microsoft Learn, docs.microsoft.com/mem/autopilot. Continuously updated.

Microsoft. *Plan for Windows Hello for Business*. Microsoft Learn, docs.microsoft.com/windows/security/identity-protection/hello-for-business. Continuously updated.

Industry Analysis and Best Practices

Flexera. *AdminStudio Product Documentation and Best Practices*. flexera.com/products/adminstudio. 2022.

Flexera. InstallShield vs. AdminStudio: Which Is Right for Your Organization? flexera.com/products/comparison. 2022.

TechTarget / SearchWindowsServer. Microsoft Configuration Manager vs. Intune: Key Comparisons. techtarget.com, 2022.

Kanlikilic, M.E. Best Practices for Co-Management Workload Distribution in SCCM and Intune. mertefekanlikilic.com, 2022.

Security and Compliance

BeyondTrust. Endpoint Privilege Management: Technical Overview. beyondtrust.com. 2022.

Center for Internet Security (CIS). CIS Benchmarks for Microsoft Windows. cisecurity.org. Continuously updated.

Microsoft. Security Baselines for Windows 10/11. Microsoft Learn, docs.microsoft.com/windows/security/threat-protection/windows-security-baselines. Continuously updated.

Mobile Device Management in the Field

Securing the Mobile Workforce from Wellhead to Boardroom

The field technician with a smartphone is also a security perimeter. Every unmanaged device accessing corporate email is a door you left open.

IT Security Lead, Large Upstream Energy Operator

3.1 The Mobile Device Challenge in Energy Environments

Mobile devices have become essential tools in energy operations. Field technicians use smartphones to report equipment issues, receive work orders, access safety procedures, and communicate with supervisors. Supervisors use tablets to review production dashboards and approve maintenance activities. Executives use personal phones to access email and review reports from anywhere in the world. Inspectors use ruggedized tablets to document conditions at remote pipeline stations.

The proliferation of these devices across a workforce that ranges from corporate knowledge workers to field operators in remote locations creates a mobile security challenge that is

distinct from, and in some ways more complex than, the endpoint management challenge addressed in Chapter 2. Smartphones and tablets are inherently more difficult to secure than managed workstations: they are physically carried into the field, they are frequently lost or damaged, they are used across corporate and personal contexts, and they connect to untrusted networks (public Wi-Fi, cellular) that a managed desktop would never encounter.

In energy environments, the stakes of mobile security failures are compounded by the operational context. A phone containing cached corporate data left at a refinery or a compromised tablet accessing corporate email from a field site represents the same kind of risk that the Colonial Pipeline attack illustrated at the infrastructure level: an IT security failure with operational consequences that extend far beyond the IT domain.

This chapter covers the full spectrum of mobile device management in energy companies: the strategic decision between MDM and MAM, Android Zero Touch enrollment for field device fleets, Apple Business Manager for iOS deployments, Mobile Application Management for BYOD scenarios, security policy design, and the operational practices that keep a large mobile fleet secure and functional across diverse and challenging environments.

3.2 MDM vs. MAM: The Foundational Decision

The first and most consequential decision in any enterprise mobile strategy is the choice between Mobile Device Management (MDM) and Mobile Application Management (MAM) or more precisely, determining which approach is appropriate for which device populations. These are not mutually exclusive: in most large energy companies, both are in use simultaneously for different device categories.

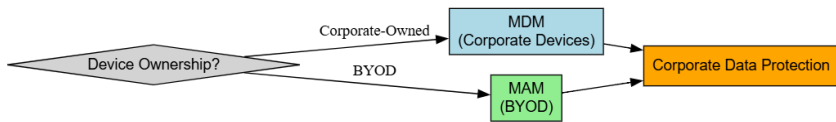


Figure 3.1 MDM vs. MAM decision framework for energy companies. The choice is primarily driven by device ownership. Corporate-owned field devices should always be enrolled in MDM. Employee personal devices accessing corporate resources should be managed via MAM without full enrollment, preserving personal data privacy.

Mobile Device Management (MDM)

MDM provides IT with full control over a device from the operating system level down. When a device is enrolled in MDM via Microsoft Intune, IT can push configuration profiles (Wi-Fi, VPN, email, certificates), deploy and remove applications silently, enforce compliance policies (encryption, screen lock, OS version), remotely wipe or lock the device, and view device inventory data.

In energy environments, MDM is the appropriate choice for all corporate-owned devices: field smartphones and tablets, ruggedized devices used in operational environments, shared devices at site offices, and any device that will have access to sensitive corporate systems. The rationale is straightforward: corporate-owned devices are company property, and the company has both the right and the obligation to fully manage them for security and compliance purposes.

MDM enrollment in Intune establishes the device as either a personally-owned or a corporate-owned device in the Intune portal – an important distinction that affects what management actions are available and what the user can see in the Company Portal app. Corporate-owned device enrollment should always use automated enrollment methods (Android Zero Touch or Apple ADE) to ensure the device is properly classified and configured from first boot.

Mobile Application Management (MAM)

MAM manages corporate data at the application level, without requiring full device enrollment. When a user signs into a Microsoft 365 application (Outlook, Teams, OneDrive, SharePoint) on their personal device with their corporate credentials, Intune's MAM policies apply to that application and the corporate data it accesses without touching the rest of the device.

MAM is the appropriate approach for BYOD scenarios: employees who prefer to use their personal phones for work email, contractors who need access to specific corporate applications, and executives who prefer a single device for personal and professional use. MAM protects corporate data within managed apps through a set of configurable policies preventing copy/paste from corporate to personal apps, requiring a PIN to open corporate apps, blocking screenshots in Microsoft 365 applications, and enabling selective corporate data wipe on departure while leaving all personal data and applications completely untouched.

The critical advantage of MAM for BYOD is privacy: the employee's personal data, applications, photos, messages, and browsing history remain entirely private and inaccessible to IT. This is both an ethical obligation and, in many jurisdictions, a legal requirement. Energy companies with international operations or workforces subject to GDPR and similar privacy frameworks should carefully document their MAM approach and ensure that employee communications clearly explain what IT can and cannot access on personal devices.



PRACTITIONER TIP: Document the BYOD Policy Before Deploying MAM

Before deploying MAM to employee personal devices, ensure that your BYOD policy is written, legally reviewed, and clearly communicated to employees. The policy should explicitly state

what data IT can access (none, on a personal device using MAM), what actions IT can take (selective corporate data wipe only), and what happens to corporate data on the device when an employee leaves the organization. Employees who understand and consent to this policy are significantly less likely to resist MAM enrollment or use workarounds to avoid it.

3.3 Android Zero Touch Enrollment: Fleet Deployment at Scale

Android Zero Touch (ZT) enrollment is Google's equivalent of Windows Autopilot for Android Enterprise devices. It allows IT to pre-configure Android devices so that when a device is powered on for the first time or after a factory reset it automatically enrolls in the organization's MDM platform without any IT intervention or physical handling of the device.

For energy companies with large field device fleets, Android Zero Touch is one of the highest-leverage MDM capabilities available. It enables a deployment model that was previously impossible: buying devices in bulk, shipping them directly to remote field sites, and having them arrive fully configured and ready to use without IT staff ever touching the device, traveling to the site, or staging devices in a central location.



Figure 3.2 Android Zero Touch enrollment flow for energy field device deployments. The defining capability is that IT never physically handles the device. Devices are registered by the reseller, configured remotely via the Zero Touch portal and Intune, shipped directly to field sites, and self-configure on first boot. Source: Google Android Enterprise documentation; Microsoft Intune integration.

Zero Touch Prerequisites and Planning

Implementing Android Zero Touch requires several prerequisites that should be planned and validated before large-scale deployment:

- **Compatible Hardware:** Zero Touch enrollment requires Android 8.0 or later and is supported only on devices from participating manufacturers. The major enterprise Android manufacturers Samsung, Motorola, Google, Zebra, Honeywell support Zero Touch on their enterprise device lines. When procuring devices for energy field deployment, verify Zero Touch support before purchase.
- **Reseller Enrollment:** The device reseller must have access to the Android Zero Touch portal and must register device IMEIs or serial numbers to your organization's Zero Touch customer account at the time of purchase. Establishing this relationship with your reseller before the procurement cycle is essential.
- **Intune Enrollment Profile:** The enrollment profile configured in Intune defines how the device will be set up device owner mode (fully managed) or work profile mode and which user account will be associated with the device. For field devices in energy environments, fully managed device owner mode is typically appropriate: IT has complete control, and the device is used exclusively for work.
- **Network Connectivity at First Boot:** The device must be able to reach Google's servers and the Intune enrollment endpoint on first boot to retrieve its Zero Touch configuration. For field sites with limited or intermittent connectivity, this means ensuring that the device can connect at least briefly to a Wi-Fi network during initial setup.

PRACTITIONER TIP: Pre-Stage Wi-Fi Credentials in Zero Touch Profile



One of the most common Zero Touch enrollment failures at remote field sites is the device being unable to connect to the network during initial setup. Mitigate this by including Wi-Fi configuration in the Zero Touch DPC extras JSON the device will automatically connect to the corporate Wi-Fi at the field site without the user needing to enter credentials. For field sites with cellular connectivity only, consider providing a corporate SIM pre-installed in the device, allowing the device to complete enrollment over cellular before the user has configured anything.

Android Enterprise Management Modes

Android Enterprise offers several management modes that are appropriate for different device scenarios in energy environments:

- **Fully Managed (Device Owner Mode):** The device is entirely managed by IT, with no personal use permitted. All apps are IT-managed, and the device is dedicated to work use. This is appropriate for field devices used by technicians and operators ruggedized smartphones and tablets that are company property and used exclusively for work purposes.
- **Corporate-Owned with Work Profile:** The device is corporate-owned but allows a personal work profile alongside IT management. Corporate apps and data are in the managed profile; the user can install personal apps in the personal profile. Appropriate for field supervisors and managers who carry a single corporate device but have legitimate personal use cases.
- **Dedicated Device (Kiosk Mode):** The device is locked to run a single application or a specific set of applications. Appropriate for single-purpose field devices: a tablet

locked to a field inspection app, a handheld scanner running a work order application, or a shared device at a site office running a specific monitoring dashboard.

COMMON MISTAKE: Deploying Android Devices Without Fully Managed Mode for Field Operations

!

A common mistake in energy field device deployments is enrolling company-owned devices as personally-owned or work-profile-only, leaving significant IT management capabilities unused. Without fully managed device owner mode, IT cannot silently install all apps, cannot enforce all compliance policies, cannot perform a complete device wipe, and cannot ensure that the device is used exclusively for work purposes. For corporate-owned field devices in energy environments, always use fully managed device owner mode. The level of IT control it provides is not excessive it is appropriate for a company-owned tool in a regulated environment.

3.4 Apple Business Manager: iOS/iPad Fleet Management

Apple Business Manager (ABM) is Apple's enterprise program for bulk device procurement, app licensing, and MDM integration. For organizations with iOS or iPad device fleets, ABM is the equivalent of Android Zero Touch it enables automated device enrollment, supervised mode management, and volume app purchasing that makes large-scale iOS deployments manageable.

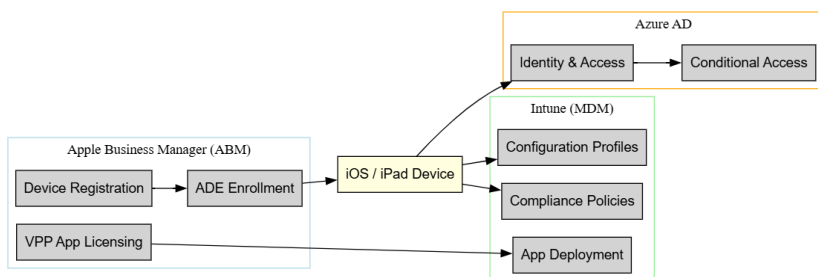


Figure 3.3 Apple Business Manager integration with Microsoft Intune for corporate iOS/iPad deployment. ABM provides the device registration and licensing infrastructure; Intune is the MDM authority. Supervised mode (enabled via ABM) unlocks significantly expanded management capabilities including silent app installation, activation lock bypass, and kiosk mode. Source: Apple Business Manager documentation; Microsoft Intune integration.

Automated Device Enrollment (ADE)

Apple's Automated Device Enrollment (ADE) previously known as Device Enrollment Program or DEP is the mechanism that enables zero-touch iOS enrollment. Devices purchased through Apple or authorized resellers can be linked to an organization's ABM account, assigned to an Intune MDM server, and configured with an ADE enrollment profile that determines how the device behaves on first boot.

The ADE enrollment profile allows IT to skip or pre-configure many of the out-of-box experience (OOBE) steps that would otherwise require user interaction: language selection, region, Wi-Fi setup, Apple ID login, privacy settings, and app setup screens. In a field device deployment, this means a device can be unboxed by a field user, powered on, connected to Wi-Fi, and be fully configured and ready to use within minutes without any IT staff present.

Supervised mode, enabled through ADE, is critical for energy field deployments. Supervised iOS devices can be managed with significantly more controls than unsupervised devices: silent app installation without user approval, activation lock bypass (allowing IT to reactivate a locked device after a user leaves), kiosk mode for single-app deployments, restriction of App Store access, AirDrop control, and more.

Volume Purchase Program (VPP) App Licensing

Apple's Volume Purchase Program, managed through ABM, allows organizations to purchase iOS app licenses in bulk and deploy them to devices without requiring individual Apple IDs. VPP licenses can be assigned to devices (rather than users), making them particularly useful for shared devices and field deployments where individual user Apple IDs may not be appropriate or practical.

In energy environments, VPP is especially valuable for specialized field applications inspection tools, work order systems, safety checklists, GIS mapping apps that need to be licensed and deployed to large numbers of devices. The ability to reclaim unused licenses and reassign them to new devices reduces licensing costs and simplifies lifecycle management.

PRACTITIONER TIP: Always Use Supervised Mode for Corporate-Owned iOS Devices



The difference in management capability between a supervised and an unsupervised iOS device is substantial. An unsupervised device cannot be silently managed for all app types, cannot have its activation lock bypassed if the associated Apple ID is no longer accessible, and cannot be fully locked down for kiosk scenarios. The overhead of setting up ABM and ADE to get supervised mode is modest compared to the management flexibility it provides over the lifetime of a device fleet. Establish supervised enrollment as

your standard from the first iOS device retrofitting it to an existing unenrolled fleet is significantly more disruptive.

3.5 Mobile Application Management Without Enrollment

MAM without enrollment (sometimes called MAM-WE) is the configuration where Intune's application protection policies apply to apps on a personal device without that device being enrolled in MDM. This is the standard approach for BYOD scenarios in energy companies, and understanding how it works and its limitations is essential for designing an effective mobile security strategy.

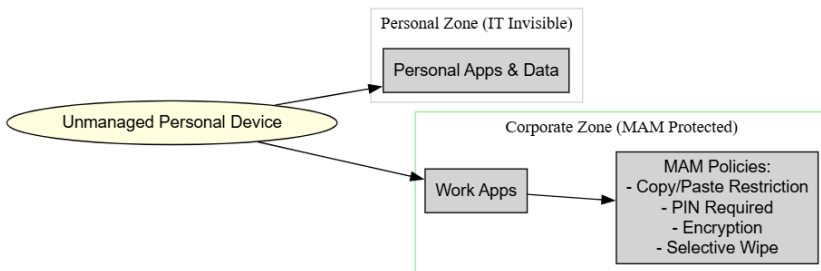


Figure 3.4 MAM without MDM: data protection on an employee's personal device. IT manages corporate data within Microsoft 365 apps (Outlook, Teams, OneDrive) through application protection policies, but has no visibility into or control over personal data, apps, or activity. On employee departure, corporate data is selectively wiped while personal data is untouched. Source: Microsoft Intune MAM documentation.

Key MAM Policy Settings for Energy Environments

The following MAM policy settings are particularly important in energy sector contexts and should be configured as part of any BYOD deployment:

- **Data Transfer Restrictions:** Prevent users from copying data from corporate apps (Outlook, Teams, SharePoint) to personal apps. In an energy environment where field reports, procurement data, and operational communications may contain sensitive information, this control prevents accidental or intentional data leakage.
- **Screenshot and Screen Recording Block:** Block screenshots within Microsoft 365 apps on enrolled devices. This prevents users from capturing sensitive information financial reports, operational data, personnel information and sharing it through personal channels.
- **Managed Browser Requirement:** Require corporate web links to open in a managed browser (Microsoft Edge with Intune protection) rather than the device's default personal browser. This ensures that web-based corporate applications are accessed in a managed context with appropriate data protection controls.
- **Offline Access Grace Period:** Configure an offline grace period the time a device can go without checking in with Intune before corporate data access is blocked. In energy field environments where connectivity may be intermittent, this period should be carefully calibrated: long enough to accommodate legitimate connectivity gaps, short enough to prevent prolonged access from a device that may have been compromised or reported lost.
- **Minimum OS Version Enforcement:** Require devices to be running a minimum iOS or Android version to access corporate apps. This prevents outdated, potentially vulnerable OS versions from accessing corporate data an important control given the diversity of device models and update patterns in a BYOD population.

COMMON MISTAKE: Configuring MAM Policies and Assuming Enforcement Without Testing

!

MAM policy enforcement is app-specific: policies apply to Microsoft 365 apps that integrate the Intune SDK, but may not apply to third-party apps or line-of-business apps that have not been wrapped or integrated with the Intune SDK. A common mistake is assuming that MAM policies provide comprehensive data protection across all apps on the device, then discovering that data can still be exfiltrated through an unmanaged app. Test your MAM policies thoroughly before deployment specifically verify that the data transfer restrictions work as expected between managed and unmanaged apps on both iOS and Android.

3.6 Mobile Device Enrollment Decision Framework

With multiple enrollment options available MDM via Zero Touch, MDM via ADE, MAM without enrollment, and various hybrid approaches selecting the right enrollment model for each device population requires a structured decision framework. The diagram below provides a decision tree designed specifically for the device scenarios common in energy companies.

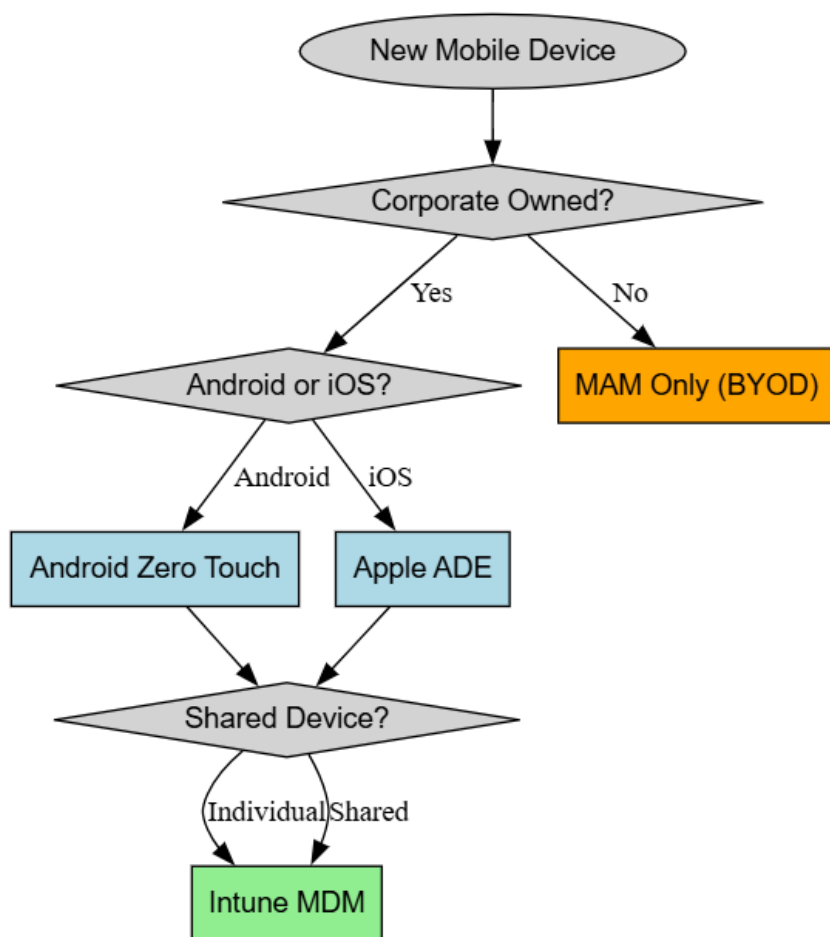


Figure 3.5 Mobile device enrollment decision tree for energy companies. The primary decision axis is device ownership (corporate vs. personal). For corporate devices, the secondary decisions concern platform (Android vs. iOS) and use mode (shared/kiosk vs. individual). Recommended default: MDM for all corporate devices; MAM for all BYOD scenarios. Avoid unenrolled corporate devices.

3.7 Security Policy Design for Energy Mobile Fleets

Configuring the technical enrollment is only half of the MDM challenge. The other half is designing the security and compliance policies that govern enrolled devices the rules that determine what the device must do (encryption, screen lock, OS version) and what it must not do (access from jailbroken devices, disable Find My Device) to be considered compliant and allowed to access corporate resources.

Compliance Policy Framework

Intune compliance policies define the minimum security requirements a device must meet to be considered compliant. Devices that do not meet compliance requirements can be restricted from accessing corporate resources through Conditional Access. Key compliance policy settings for energy company mobile fleets include:

- **Device Encryption:** Require full-device encryption on all enrolled devices. Both Android and iOS/iPad OS support hardware-level encryption, and enabling this requirement ensures that data is protected if a device is lost at a remote site.
- **Screen Lock with PIN/Biometric:** Require a PIN, password, or biometric lock with a maximum idle timeout. The idle timeout should be short enough to prevent an unattended device from being accessible but not so short as to create constant authentication friction for field workers who are actively using their devices.
- **OS Version Minimum:** Require a minimum supported OS version and flag devices that are below this minimum. Establish a process for notifying users of required OS updates and a grace period before Conditional Access blocks access.

- **Jailbreak and Root Detection:** Intune can detect jailbroken iOS devices and rooted Android devices and mark them as non-compliant. Jailbroken devices have bypassed the OS security controls and should never have access to corporate resources in an energy environment.
- **Mobile Threat Defense Integration:** For high-security scenarios, integrate a Mobile Threat Defense (MTD) solution such as Microsoft Defender for Endpoint or a third-party MTD that provides real-time threat detection on mobile devices. MTD solutions can detect malware, phishing attacks, network-level threats, and OS vulnerabilities, and report device risk level to Intune for inclusion in compliance decisions.

Conditional Access for Mobile

Conditional Access (CA) policies in Microsoft Entra ID (Azure AD) define the conditions under which a device is allowed to access corporate resources. For mobile devices, the most effective CA configuration requires that a device be enrolled in Intune AND be marked compliant before access to Exchange Online, SharePoint, Teams, and other corporate resources is granted.

In energy environments, Conditional Access for mobile should be implemented carefully, with a phased rollout that allows time for all users to enroll their devices before access is blocked for non-compliant devices. A CA rollout that cuts off field workers' access to critical communication tools without warning can create operational safety risks the field supervisor who cannot access the safety procedure they need because their phone was not yet enrolled.



PRACTITIONER TIP: Use Report-Only Mode Before Enforcing Conditional Access

Before enabling enforcement of any Conditional Access policy, run it in Report-Only mode for a minimum of two weeks. Report-Only mode logs what would have been blocked without actually blocking anything, allowing you to identify users and devices that would be affected. In energy environments where field workers may be on remote sites for extended periods without access to the Company Portal or IT support, this pre-enforcement visibility is critical for planning a rollout that does not create operational disruptions.

3.8 Office 365 Data Protection on Mobile Devices

Microsoft 365 applications Outlook, Teams, OneDrive, SharePoint, Word, Excel are the primary corporate tools accessed from mobile devices in most energy companies. Intune's integration with these apps provides a powerful data protection layer that applies regardless of whether the device is MDM-enrolled (corporate device) or not (BYOD).

Intune App Protection Policies for M365 apps in energy environments should be configured to prevent corporate data from leaking through mobile channels. Key scenarios to protect against include: a field technician forwarding a confidential process report from their corporate Outlook to their personal Gmail; a contractor downloading operational data from SharePoint to their personal OneDrive; a supervisor sharing screenshots of a production dashboard to a personal messaging app.

Per-App VPN for Sensitive Applications

For field applications that access sensitive corporate systems operational dashboards, maintenance management systems, ERP data a Per-App VPN configuration ensures that traffic from those specific applications is routed through the corporate VPN,

while other app traffic goes directly to the internet. This is particularly useful in energy environments where a full-device VPN would create performance issues over cellular connections, but specific corporate applications need the security of VPN-tunneled traffic.

Managed Email Profiles

For corporate-owned devices, push a managed Outlook email profile that pre-configures the user's corporate email account, Exchange server settings, and sync configuration. This eliminates the need for users to manually configure email on new devices and ensures that the email configuration meets corporate security standards particularly important for preventing users from adding corporate accounts to native mail apps that may not enforce Intune MAM policies.

CASE STUDY | Mobile Device Fleet Refresh at a Large Pipeline Company Composite Scenario

Background

A large pipeline operator with approximately 2,000 field and corporate users needed to refresh an aging mobile device fleet a mix of iOS and Android devices, many of which were enrolled in an older MDM platform with limited management capabilities. The refresh coincided with a migration to Microsoft Intune as the unified endpoint management platform.

Android Deployment Approach

For corporate Android devices (approximately 1,200 field smartphones), the team configured Android Zero Touch enrollment through the device reseller. Devices were purchased, registered in the Zero Touch portal, and shipped directly to regional field operations managers who distributed them to their teams. No central staging was required. Devices arrived pre-enrolled, with corporate Wi-Fi configured, required apps installed, and compliance policies active.

iOS Deployment Approach

For iOS devices (approximately 600 iPads and iPhones used by supervisors and corporate staff), the team configured Apple ADE through Apple Business Manager with supervised mode enabled. ADE enrollment profiles were linked to Intune. Devices were purchased through an Apple-authorized reseller with ABM registration, then shipped to users. VPP app licenses for field applications and corporate productivity tools were assigned to devices in bulk.

BYOD Strategy

Rather than requiring field contractors to enroll personal devices, the company implemented MAM-only policies for contractor access to Microsoft 365 apps. Contractors sign in to Outlook and Teams with their contractor accounts; Intune MAM policies protect corporate data within those apps without full device enrollment. The policy is clearly communicated in contractor onboarding documentation.

Outcome and Lessons

The Zero Touch and ADE deployments eliminated approximately 400 hours of staging labor compared to the previous deployment model. The primary challenge was the offline grace period setting for field sites with intermittent connectivity the initial setting of 24 hours was too short for some remote sites, and was adjusted to 72 hours after several field users were temporarily blocked. Testing offline scenarios at representative remote site conditions before deployment would have caught this issue earlier.

PRACTITIONER PERSPECTIVE | **Field IT Manager** | *Regional Midstream Pipeline Operator (Anonymous)*

"What was the biggest surprise when you rolled out MDM to field devices?"

The technology was easier than we expected. The people side was harder. Field workers, especially senior ones, were suspicious of

MDM at first. They thought IT was going to track their location or read their messages. We spent a lot of time doing one-on-ones with supervisors to explain exactly what MDM does and does not do showing them the Company Portal app and walking through what IT can see versus what we cannot. Once they understood that MDM is a management and wipe capability, not a surveillance tool, the resistance mostly disappeared. Communication first, technology second.

3.9 Device Lifecycle Management

Enterprise mobile devices have finite lifecycles typically three to four years for smartphones and tablets in field environments, potentially less for ruggedized devices in harsh conditions. Managing the full device lifecycle procurement, enrollment, use, refresh, and retirement is a critical operational function for energy sector IT teams with large mobile fleets.

Procurement Standards

Establish a standard device list the specific makes and models that are approved for corporate procurement based on Zero Touch and ADE support, ruggedization requirements for field environments, battery life, repairability, and support contracts. Having a standard device list simplifies procurement, support, and replacement logistics significantly compared to managing a heterogeneous fleet. For field environments in energy companies, ruggedized or semi-ruggedized devices from manufacturers such as Samsung (XCover/Galaxy Active series), Zebra, or Honeywell often provide better durability than consumer-grade devices, reducing replacement costs over the device lifecycle.

Device Assignment and Inventory

Intune provides device inventory data enrolled device list, user assignment, OS version, last check-in time, compliance status but this information should be supplemented with an asset management record that captures physical device location, assigned user, procurement date, warranty status, and incident history. For large energy company fleets, integrating Intune device data with a Service Management platform (ServiceNow, Remedy) creates a unified asset record that supports audit, warranty, and lifecycle planning.

Retirement and Wipe Procedures

When a device is decommissioned whether due to lifecycle refresh, damage, or employee departure the retirement procedure must ensure that all corporate data is removed before the device leaves IT control. For MDM-enrolled devices, Intune's Remote Wipe action performs a full factory reset, removing all corporate data, apps, and configurations. For MAM-enrolled personal devices, Selective Wipe removes only corporate app data, leaving personal data intact.

In energy environments, device retirement procedures should be documented in the change management system, with specific procedures for devices that may have been used at operationally sensitive locations or accessed classified operational data. These devices should be fully wiped and documented before reassignment or disposal, and the wipe action should be logged for audit purposes.

- MDM provides full device-level management and is appropriate for all corporate-owned mobile devices in energy environments. MAM provides app-level data protection for BYOD scenarios without device enrollment.
- Android Zero Touch and Apple ADE (via Apple Business Manager) enable zero-touch device deployment devices ship directly to field sites and self-configure, eliminating

staging labor and enabling rapid, scalable fleet deployment.

- Android Enterprise fully managed mode (device owner) is the correct MDM mode for corporate-owned field devices. Supervised mode is essential for corporate iOS devices. Neither should be compromised for operational convenience.
- MAM without MDM is the appropriate strategy for employee personal devices and contractor BYOD scenarios. Intune App Protection Policies enforce data protection within Microsoft 365 apps while leaving personal data entirely untouched.
- Conditional Access policies enforce device compliance as a condition of accessing corporate resources. Report-Only mode should be used for at least two weeks before enforcement to prevent operational disruptions.
- Device lifecycle management procurement standards, enrollment, inventory, and retirement procedures must be documented and operationalized for large fleets to maintain security and support audit requirements.
- Communication and change management are as important as technical configuration. Field workers who understand what MDM does and does not do are significantly more likely to cooperate with enrollment requirements.

Chapter 3 Checklist: Mobile Device Management Readiness

- | | |
|--------------------------|---|
| ☐ | MDM vs. MAM strategy is documented and aligned to device ownership categories (corporate, BYOD, contractor) |
|--------------------------|---|

☐	Android Zero Touch is configured in the portal with Intune as the DPC for all Android corporate device purchases
☐	Apple Business Manager account is established and linked to Intune with ADE token configured
☐	Supervised mode is enabled on all corporate iOS/iPad enrollments via ADE
☐	Volume Purchase Program (VPP) licenses are configured for required apps on iOS fleet
☐	Android Enterprise fully managed (device owner) mode is used for all corporate Android field devices
☐	MAM App Protection Policies are configured for iOS and Android, covering copy/paste, screenshot block, offline grace period
☐	BYOD policy document is written, legally reviewed, and communicated to employees
☐	Compliance policies require encryption, screen lock, minimum OS version, and jailbreak/root detection
☐	Conditional Access policy is deployed in Report-Only mode and validated before enforcement
☐	Offline grace period is tested and validated against actual connectivity profiles at remote field sites
☐	Per-App VPN is configured for applications accessing sensitive corporate systems
☐	Managed Outlook email profile is pushed to all corporate-owned mobile devices
☐	Device standard list (approved models) is documented for

corporate procurement

- ☐ Device retirement/wipe procedure is documented and includes audit logging in the change management system
- ☐ Mobile Threat Defense integration is evaluated and configured for high-security device populations

References and Further Reading

Microsoft Documentation

Microsoft. *What is Microsoft Intune?* Microsoft Learn, learn.microsoft.com/intune. Continuously updated.

Microsoft. *Mobile Device Management (MDM) vs. Mobile Application Management (MAM)*. Microsoft Learn, 2022.

Microsoft. *Android Zero-Touch Enrollment for Intune*. Microsoft Learn, learn.microsoft.com/intune/android-zero-touchenv. 2022.

Microsoft. *iOS/iPad OS Device Enrollment with Apple ADE and ABM*. Microsoft Learn, 2022.

Microsoft. *App Protection Policies Overview*. Microsoft Learn, learn.microsoft.com/intune/apps/app-protection-policy. 2022.

Microsoft. *Conditional Access: Require Compliant or Hybrid Azure AD Joined Device*. Microsoft Learn, 2022.

Platform and Vendor Documentation

Google. *Android Enterprise Zero-Touch Enrollment for IT Admins*. support.google.com/work/android. 2022.

Apple. *Apple Business Manager User Guide*. support.apple.com/guide/apple-business-manager. 2022.

Apple. *Automated Device Enrollment (ADE) Overview*. support.apple.com. 2022.

Industry Research

TechTarget / SearchMobileComputing. Understanding MDM vs. MAM in Microsoft Intune. techtarget.com, 2022.

Sophos. State of Ransomware in Energy, Oil/Gas and Utilities 2022. sophos.com, 2022.

Petervanderwoude.nl. Android Enterprise and Microsoft Intune. petervanderwoude.nl, 2022.

Active Directory, Group Policy, and Identity Management

The Foundation of Enterprise Security and Compliance

Active Directory is the central nervous system of enterprise Windows security. Everything from who can log in, to what software runs, to whether a workstation reboots at 2 a.m. or during a shift handover flows through it. In the energy sector, that makes AD one of the most consequential systems IT manages.

Enterprise Identity Architect, Large Energy Company

4.1 Why Active Directory Is the Security Backbone

In any large Windows-based enterprise, Active Directory Domain Services (AD DS) is the identity and access management foundation upon which everything else is built. It is the authoritative source for user and computer identities, the enforcement point for Group Policy settings, the trust anchor for Kerberos authentication, and in hybrid environments the on-

premises half of the identity bridge to Microsoft Entra ID (formerly Azure AD) and the cloud.

In energy companies, Active Directory carries additional weight. The same domain that authenticates a corporate accountant in the Houston office also authenticates the site supervisor's workstation at a compressor station in West Texas. Group Policy settings deployed from AD control what software can run, who can log in locally, and how endpoints behave across the entire enterprise including at operational sites where any unexpected system behavior carries operational risk.

Understanding Active Directory in the energy sector means understanding it not just as a directory service, but as a control plane for enterprise security. The design decisions made in AD how the OU structure is organized, how GPOs are linked, how hybrid identity is configured, how administrative accounts are managed have direct implications for the security posture of the organization and, by extension, for the safety and reliability of the operations those systems support.

This chapter covers four interconnected topics: Active Directory design and OU structure for energy environments; Group Policy design, inheritance, and management at scale; hybrid identity with Microsoft Entra ID and Azure AD Connect; and modern identity security with Windows Hello for Business, Windows LAPS, and the tiered administration model.

4.2 Active Directory Design for Energy Companies

Organizational Unit (OU) Structure

The Organizational Unit (OU) structure is the architectural skeleton of an Active Directory deployment. It defines how objects users, computers, service accounts, groups are organized, which Group Policy Objects apply to them, and how

administrative delegation is structured. A well-designed OU structure makes administration efficient, delegation clean, and GPO application predictable. A poorly designed one creates cascading problems that are expensive to fix.

In energy companies, the OU structure must reflect the unique characteristics of the organization: the geographic distribution of operations, the distinct management requirements of corporate versus field environments, and the need to apply different security baselines to different types of devices and users without creating an unmanageable proliferation of GPOs.

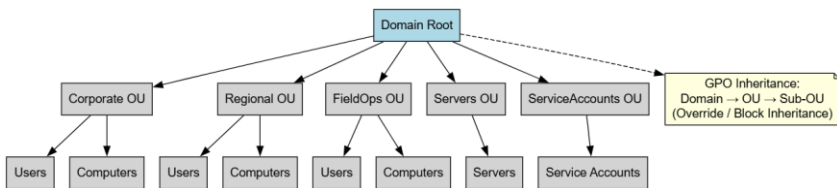


Figure 4.1 Representative Active Directory OU structure for a large energy company. The separation of Corporate, Regional, and FieldOps OUs allows different GPO baselines to be applied to each environment while inheriting common domain-level settings. Service accounts are isolated in a dedicated OU for tight access control. Key rule: always separate computer objects and user objects into distinct OUs.

Key OU Design Principles for Energy Environments

The following design principles should guide AD OU structure decisions in energy companies:

- Separate computers from users: Computer policy and user policy are applied differently in Group Policy computer settings apply during startup, user settings apply at logon. Placing computers and users in the same OU creates ambiguity in policy application and complicates troubleshooting. Always maintain dedicated

computer OUs and user OUs at each level of the hierarchy.

- **Reflect operational geography:** The OU structure should mirror the operational geography of the organization corporate HQ, regional offices, and field operations as distinct branches. This allows field-specific GPOs (different software restrictions, extended offline timeout, low-bandwidth optimizations) to be applied cleanly without affecting corporate endpoints.
- **Isolate service accounts:** Service accounts accounts used by applications and services to run processes, connect to databases, or access network resources should be in a dedicated OU separate from user accounts. This allows specific GPO settings (deny interactive logon, strict password policy, no GPO other than account policy) to be applied to service accounts without affecting user experience.
- **Plan for delegation:** The OU structure should enable administrative delegation granting specific IT teams management rights over specific OUs without giving them domain-wide administrator privileges. For example, the field IT team may have rights to manage computer objects in the FieldOps OU without having rights to modify user accounts in the Corporate OU.
- **Minimize depth:** OU hierarchies deeper than four levels become difficult to navigate and troubleshoot. In most energy companies, a three-level hierarchy Domain → Business Unit → Object Type provides sufficient granularity without excessive complexity.

PRACTITIONER TIP: Use a Naming Convention Before You Start



Establish and document a clear naming convention for OUs, GPOs, groups, and computer objects before deploying AD, or before a major restructuring. A convention like OU=Corporate-

Computers, GPO=SEC-Workstation-Baseline, GRP=APP-SAP-Users makes the purpose of each object self-documenting and dramatically reduces the time required for troubleshooting and auditing. Energy companies with AD deployments that have grown organically over many years often have naming conventions that reflect the priorities of whoever created each object which means no convention at all. A naming convention remediation project, while unglamorous, pays dividends in every subsequent administration and audit activity.

Domain Controller Strategy: RODCs at Remote Sites

One of the most consequential AD infrastructure decisions for geographically distributed energy companies is whether to deploy domain controllers at remote sites, and if so, what type. Remote sites without any domain controller are entirely dependent on WAN connectivity for authentication a workstation at a compressor station must reach HQ over the WAN to authenticate a user login. If the WAN link fails, users at that site cannot log in (unless their credentials are cached), and Group Policy cannot refresh.

Read-Only Domain Controllers (RODCs) provide a solution: a lightweight domain controller that can be deployed at remote sites with minimal hardware, maintaining a read-only replica of the AD database for local authentication. RODCs can authenticate users and apply Group Policy locally without WAN connectivity, and they do not require the physical security standards of a writable DC because they cannot make changes to the AD database.

For energy field sites where WAN connectivity may be intermittent and physical security of IT equipment may be limited RODCs are the recommended approach. The Password Replication Policy (PRP) on an RODC controls which account passwords are cached locally, allowing IT to grant local

authentication capability to specific accounts (site operators, field technicians) while preventing sensitive accounts (domain administrators) from having their credentials stored at a potentially insecure remote location.

PRACTITIONER TIP: Configure RODCs with Explicit Allow Lists for Password Replication



The default RODC password replication policy caches no passwords (conservative). For field sites where WAN connectivity is unreliable, this means users cannot log in if the WAN is down. Configure a specific security group `FieldSite-CachedAccounts` and add the accounts of users who work at each site. Add this group to the RODC's Allowed Password Replication Policy. This ensures those users can log in locally when the WAN is unavailable, while keeping domain admin and service account credentials off the RODC. Audit this group quarterly to remove departed employees.

Group Naming Conventions and Access Control Groups

Active Directory groups are the primary mechanism for controlling access to resources: file shares, applications, email distribution lists, and security policy scope. In energy companies with large application portfolios and complex access requirements, group sprawl the proliferation of poorly named, undocumented groups is a chronic problem that creates both administrative overhead and security risk.

A structured group naming convention should encode the group's purpose, type, and scope in its name. A common convention follows the pattern `TYPE-SCOPE-PURPOSE` for example, `GRP-APP-SAPUsers` (security group for SAP application access), `GRP-SITE-HoustonDC` (security group for Houston data center), or `DL-TEAM-ITOperations` (distribution list

for IT operations team). Whatever convention is chosen, the critical requirement is that it is documented, enforced, and applied consistently from the start.

Regular group membership audits are particularly important in energy environments with contractor and temporary worker populations. Contractors who have left the project but retain AD group memberships represent a persistent access control risk. Automating group membership review through Identity Governance tools or building a semi-annual manual review process is a security hygiene practice that pays dividends during audits and reduces the attack surface available to an adversary who compromises a contractor account.

4.3 Group Policy: Design, Management, and Enforcement at Scale

Group Policy is the mechanism through which Active Directory enforces consistent configuration and security settings across thousands of Windows devices. A Group Policy Object (GPO) is a collection of settings user environment preferences, security policies, software installation rules, script assignments, Windows Update configurations that is linked to an OU, site, or domain and applied to all objects within scope.

In energy companies managing 5,000 to 50,000 endpoints across dozens of locations, Group Policy is not just a convenience it is a compliance and security control. The ability to enforce a USB block on all field workstations from a single policy, push a screen lock timeout to every corporate laptop, or disable the Windows XP-era settings that create vulnerabilities in modern Windows environments all flow through Group Policy. Understanding how it works, how inheritance operates, and how to manage it without creating an unmanageable tangle of conflicting policies is an essential competency.

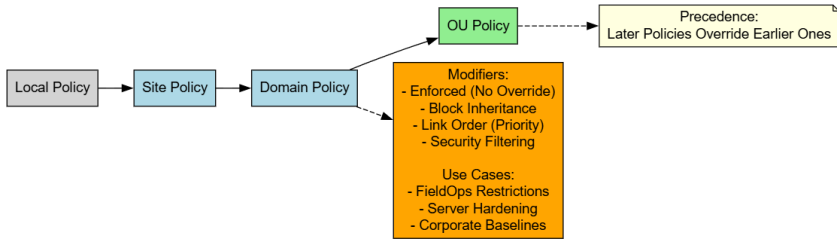


Figure 4.2 GPO processing order follows the LSDOU sequence: Local, Site, Domain, Organizational Unit. Within each level, policies are applied in link order, with higher-numbered links taking lower precedence. The Enforced modifier overrides Block Inheritance and prevents child OUs from overriding a parent GPO. Source: Microsoft Active Directory documentation.

The LSDOU Processing Model

Group Policy processes in a defined order Local, Site, Domain, Organizational Unit known by the acronym LSDOU. Within this sequence, later-applied policies take precedence over earlier ones when there are conflicting settings. This means OU-level GPOs have the highest precedence by default, overriding domain-level settings for the objects they apply to.

For energy IT professionals, the most important practical implication of LSDOU is this: settings you want to apply universally across the enterprise (password policy, account lockout, core security baselines) should be linked at the domain level, possibly with the Enforced flag to prevent OU-level policies from overriding them. Settings that need to differ by location or device type (software restrictions, offline logon cache size, application configuration) should be linked at the appropriate OU level.

GPO Design Principles for Large Enterprise Energy Environments

The following design principles should guide GPO creation and management in energy company AD environments:

- **Single-purpose GPOs:** Create GPOs that serve a single, clearly defined purpose rather than combining many unrelated settings in one object. A GPO named SEC-Workstation-USB-Block that contains only USB device restriction settings is easier to understand, troubleshoot, and modify than a monolithic GPO containing dozens of unrelated settings. Single-purpose GPOs also allow individual settings to be disabled or tested without affecting other configurations.
- **Separate computer and user GPOs:** Computer policy settings (applied at startup) and user policy settings (applied at logon) belong in separate GPOs, mirroring the OU separation of computer and user objects. A computer GPO linked to the Computers OU with user configuration disabled, and a user GPO linked to the Users OU with computer configuration disabled, is significantly more efficient and predictable than a mixed GPO.
- **Name GPOs descriptively:** The GPO name should convey its purpose, scope, and type at a glance. A convention like [TYPE]-[SCOPE]-[PURPOSE] (e.g., SEC-Domain-PasswordPolicy, APP-Corporate-ChromeConfig, MGT-FieldOps-OfflineCacheSize) makes the GPO library self-documenting.
- **Avoid Block Inheritance except in documented exceptions:** Block Inheritance prevents parent GPOs from flowing into a child OU. Used injudiciously, it creates security gaps where intended settings are silently not applied. If Block Inheritance is used, it should be documented with a clear justification and reviewed periodically to ensure the exception is still valid.
- **Use security filtering to scope GPOs precisely:** Rather than creating separate OUs for every variation in policy requirements, use security filtering to apply a GPO only

to specific security groups within an OU. This is particularly useful for phased rollouts for example, deploying Windows Hello for Business to a pilot group before enforcing it enterprise-wide.

COMMON MISTAKE: Modifying the Default Domain Policy for Custom Settings

!

A persistent and consequential mistake is adding custom settings to the Default Domain Policy rather than creating new, purpose-specific GPOs. The Default Domain Policy should contain only password policy, account lockout policy, and Kerberos policy settings nothing else. Adding custom application settings, software restrictions, or security baselines to the Default Domain Policy creates a single point of failure: if the Default Domain Policy becomes corrupted or needs to be rolled back, all of those custom settings are lost. It also makes the policy unreadable no one can determine what the Default Domain Policy does by reading its name. Always create new, named GPOs for custom settings.

Security Hardening Through Group Policy

Group Policy is the primary mechanism for deploying security hardening settings to Windows endpoints in enterprise environments. Key security-relevant GPO settings that should be configured in energy company environments include:

- Account policies: Password length (minimum 14 characters), complexity, history (minimum 24), and maximum age (60-90 days). Account lockout threshold (5 failed attempts), lockout duration (30 minutes), and reset counter. These settings apply at the domain level.
- User rights assignment: Restrict who can log on locally (Deny logon locally to domain admins on workstations), who can access the system from the network, and who

can shut down or restart the system. Service accounts should be restricted to only the rights they require.

- Windows Defender Firewall: Configure domain profile firewall rules that allow necessary corporate traffic while blocking lateral movement vectors. Ensure the firewall is enabled and configured consistently across the fleet.
- Removable media and USB restrictions: Block USB storage devices on workstations that do not require them. In energy environments, USB-based malware introduction is a documented attack vector the energy sector equivalent of the malware-laden USB in the parking lot scenario. Enforcing this at the domain level with a domain-wide or targeted GPO eliminates this attack surface.
- Screen lock and session timeout: Require screen lock after 10–15 minutes of inactivity. Configure session timeout for inactive Remote Desktop sessions. These settings balance security with usability for field operators who may step away from a workstation briefly.
- Software Restriction Policies or AppLocker: Control which applications can run on managed endpoints. In energy environments, preventing the execution of unauthorized software particularly at operationally sensitive workstations is a significant security control that can be enforced entirely through Group Policy.

PRACTITIONER TIP: Use the CIS Benchmarks as Your GPO Baseline Reference

✓ The Center for Internet Security (CIS) publishes detailed security benchmarks for Windows 10, Windows 11, and Windows Server that provide specific GPO setting recommendations with rationale. These benchmarks are widely used in regulated industries, including energy, as a reference for security hardening baselines. Start with the Level 1 benchmark settings, which represent a practical

baseline with minimal operational impact, and evaluate Level 2 settings case by case based on your organization's risk tolerance. Document which benchmark settings you have implemented and which you have waived with justification this documentation is valuable during audits.

GPO Change Management and Testing

In energy environments, Group Policy changes must be treated with the same rigor as any other change to production systems. A GPO that inadvertently breaks a critical application, prevents users from logging in, or disrupts operational workstations can have consequences that reach beyond the IT function. Every GPO change should follow a defined change management process: testing in a lab or isolated OU first, piloting on a small group of representative devices, staged rollout by site type, and documented rollback procedure.

The Group Policy Management Console (GPMC) includes a Resultant Set of Policy (RSoP) tool accessible via the `gpresult` command or the GPMC's Group Policy Results wizard that shows exactly which policies apply to a specific user and computer combination. Before deploying any significant GPO change, run RSoP on representative devices from each affected OU to verify that the intended settings will apply and that no unintended settings will be introduced.

4.4 Hybrid Identity: On-Premises AD and Microsoft Entra ID

Most large energy companies operate in a hybrid identity environment: user identities exist in on-premises Active Directory (the legacy authoritative source, often decades old) and in Microsoft Entra ID (the cloud identity platform required for

Microsoft 365, Intune, Conditional Access, and modern authentication). Managing this hybrid environment keeping both directories synchronized, ensuring authentication works seamlessly, and extending on-premises security policies to cloud resources is one of the core infrastructure responsibilities of energy sector IT teams.

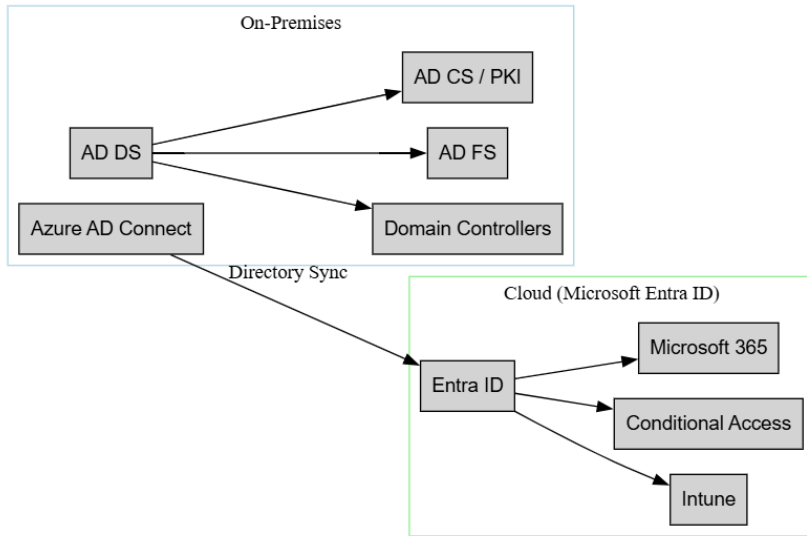


Figure 4.3 Hybrid identity architecture for a large energy company. Azure AD Connect (now Microsoft Entra Connect) is the synchronization engine that bridges on-premises AD DS with Microsoft Entra ID. Hybrid Azure AD join enables devices to have an identity in both environments, unlocking Windows Hello for Business, Conditional Access, and co-management. Password Hash Sync or Pass-Through Authentication provides cloud authentication without full federation.

Azure AD Connect (Microsoft Entra Connect)

Azure AD Connect is the synchronization engine that keeps on-premises Active Directory and Microsoft Entra ID in sync. It runs

on a dedicated server (or a highly available pair of servers) in the on-premises environment and synchronizes user accounts, groups, and device objects to the cloud on a scheduled basis (default every 30 minutes).

Configuration decisions in Entra Connect that significantly affect energy company environments include:

- Password synchronization method: Password Hash Sync (PHS) synchronizes a hashed representation of user passwords to Entra ID, allowing cloud authentication without on-premises dependency. Pass-Through Authentication (PTA) validates passwords against on-premises AD in real-time via an on-premises agent, but introduces dependency on on-premises connectivity for cloud authentication. For energy companies where on-premises connectivity may be disrupted, PHS is generally preferable for its resilience.
- Filtered synchronization: In large energy companies with complex AD structures, Entra Connect can be configured to synchronize only specific OUs or groups rather than the entire directory. This allows IT to keep service accounts, OT-adjacent accounts, and sensitive operational identities out of the cloud identity store.
- High availability: Entra Connect supports a staging mode server a passive replica that can be promoted to active if the primary fails. For energy companies where identity synchronization disruption could affect cloud application access for thousands of users, deploying a staging server is a high-value resilience investment.



COMMON MISTAKE: Synchronizing Service Accounts and OT-Adjacent Accounts to Entra ID

One of the most consequential hybrid identity mistakes in energy environments is synchronizing all on-premises AD objects to Entra ID without filtering. Service accounts

especially those used to run critical on-premises processes have no legitimate cloud identity use case and should not exist in Entra ID. More critically, any accounts used to access systems near the OT environment should be carefully evaluated before synchronization. An on-premises OT system account that is synchronized to Entra ID could potentially be targeted through cloud identity attack vectors that would not affect a purely on-premises account. Configure Entra Connect with an OU-based or attribute-based filter that excludes service accounts and OT-adjacent accounts from synchronization.

Hybrid Azure AD Join

Hybrid Azure AD Join is the configuration that gives Windows devices a dual identity: they are joined to the on-premises AD domain (as they have always been) AND registered in Microsoft Entra ID (giving them a cloud identity). This dual identity is the prerequisite for Windows Hello for Business, Intune co-management Conditional Access-based device compliance, and several other modern identity and endpoint management capabilities.

Enabling Hybrid Azure AD Join requires configuring Entra Connect to synchronize device objects and configuring a Service Connection Point (SCP) in AD DS that tells domain-joined devices where to register in the cloud. The SCP is a simple AD object that can be created through the Entra Connect configuration wizard or manually via PowerShell.

In energy environments, the Hybrid Join configuration applies to all domain-joined endpoints corporate workstations, regional office desktops, and field site computers. The main consideration for field sites is connectivity: devices must be able to reach Entra ID to complete their initial registration, which requires internet access (direct or via proxy) at some point after the domain join. For field sites with restricted internet access, planning the initial registration process ensuring devices

connect to the internet during staging before deployment prevents registration failures in the field.

4.5 Windows Hello for Business: Moving Beyond Passwords

Passwords are the weakest link in enterprise authentication. According to Microsoft, more than 80 percent of security breaches involve compromised credentials and in most cases, the compromised credential is a password. Windows Hello for Business (WHfB) replaces password-based authentication with hardware-backed, two-factor authentication: something the user knows (a PIN) combined with something they have (the device's Trusted Platform Module chip), or a biometric (fingerprint or facial recognition).

The critical distinction between a Windows Hello PIN and a traditional password is often misunderstood: the PIN is not transmitted over the network. It unlocks a cryptographic key stored in the device's TPM chip, which is then used to authenticate the user without the PIN ever leaving the device. This means that even if an attacker intercepts network traffic or compromises a server, they cannot capture and replay the PIN the way they can capture and replay a password hash.

Windows Hello for Business: Three Deployment Trust Models

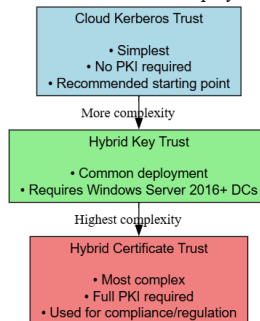


Figure 4.4 Windows Hello for Business deployment trust models. Cloud Kerberos Trust is the recommended starting point for most energy companies: it requires no enterprise PKI, supports all modern Windows versions, and is the simplest path to passwordless authentication. Hybrid Certificate Trust is appropriate for organizations with existing PKI that require smartcard-equivalent authentication for compliance purposes. Source: Microsoft Learn Plan a Windows Hello for Business Deployment.

WHfB Deployment Considerations for Energy Environments

Deploying Windows Hello for Business across a geographically distributed energy company requires careful planning that accounts for the diversity of device types, connectivity profiles, and user populations:

- **TPM availability:** WHfB strongly recommends TPM 2.0. Most corporate-class laptops and desktops manufactured after 2016 have TPM 2.0. Field site desktops and older workstations may predate TPM 2.0 availability. Run an inventory of TPM versions across the device fleet before designing the deployment devices without TPM 2.0 will fall back to software-based key storage, which provides reduced security.
- **Phased rollout by user population:** Begin WHfB deployment with corporate users in HQ where support is readily available. Expand to regional offices, then to field sites. Field operators unfamiliar with PIN-based authentication need clear onboarding documentation and accessible support during the rollout period.
- **Biometric enrollment guidance:** Facial recognition (Windows Hello) requires good lighting conditions and a compatible camera. For field environments where users may be wearing safety equipment (hard hats, safety glasses) that obstructs facial recognition, PIN-based authentication is more reliable than biometrics. Configure

fallback to PIN as the primary method for field deployments.

- Connectivity requirements for provisioning: WHfB provisioning requires the device to be connected to the corporate network (or VPN) and able to reach Entra ID to register the user's key. At field sites with intermittent connectivity, this provisioning step should be coordinated to occur when connectivity is available ideally during a planned maintenance window.

PRACTITIONER TIP: Use Security Groups to Stage WHfB Rollout

✓ Create a security group (e.g., GRP-WHfB-Enabled) and scope the WHfB GPO or Intune policy to this group using security filtering. Add users to the group in waves: IT staff first (month 1), corporate power users (month 2), all corporate (month 3), regional offices (months 4-5), field sites (months 6-8). This staged approach allows the support team to handle provisioning issues at a manageable rate and gives the field IT team time to prepare documentation and support procedures for each location before rollout reaches them.

4.6 Windows LAPS and the Tiered Administration Model

Two complementary security practices Windows LAPS and the tiered administration model address one of the most persistent vulnerabilities in enterprise Windows environments: the use of shared local administrator accounts that enable lateral movement across the network.

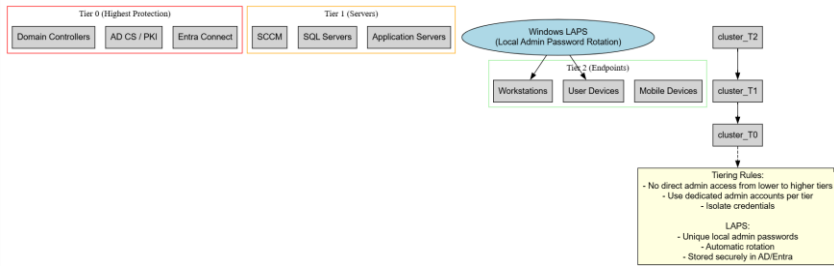


Figure 4.5 The tiered administration model with Windows LAPS. Each tier has separate administrative accounts that cannot access systems in other tiers. Windows LAPS generates a unique password for the local Administrator account on each device, stored encrypted in AD or Entra ID and rotated after each use. This prevents the lateral movement scenario where compromising one device's local admin account gives access to all devices sharing the same password. Source: Microsoft tiering model documentation; TechTarget Windows LAPS guide.

Windows LAPS: Eliminating the Shared Local Admin Problem

Local Administrator Password Solution (LAPS) now integrated directly into Windows 11 and Windows 10 (via update) as Windows LAPS addresses the shared local administrator password problem. In the pre-LAPS era, many organizations deployed all Windows workstations with the same local Administrator password often set during imaging and never changed. An attacker who discovered this password on one machine could immediately use it to authenticate to every other machine on the network with the same credential. This is the lateral movement scenario that has driven some of the most significant enterprise compromises.

Windows LAPS assigns a unique, randomly generated password to the built-in local Administrator account on each managed device. The password is stored encrypted in Active Directory (for on-premises accounts) or Microsoft Entra ID (for

cloud-joined devices), with access controlled by AD permissions or Azure RBAC. When an IT administrator needs local administrator access to a device, they retrieve the current password from AD or Entra ID, use it, and LAPS automatically rotates the password after a configurable period or immediately after use, in the most secure configuration.

In energy environments, LAPS is particularly valuable for field site workstations, which are often managed remotely and may be physically accessible to non-IT personnel. A unique local admin password per device means that compromise of one field site workstation does not grant an attacker access to other field site systems a meaningful security improvement given the geographic distribution and limited physical security of many field locations.

PRACTITIONER TIP: Enable Automatic Password Rotation After Admin Use

✓ Configure Windows LAPS with the PasswordExpirationProtection setting and, for high-security environments, trigger immediate password rotation after the local admin account is used. This ensures that a one-time use of the local admin credential does not leave a standing elevated access path open. The PowerShell cmdlet `Reset-LapsPassword` can be called programmatically at the end of an administrative session to force immediate rotation. In energy environments where field site access is episodic an IT technician visits a site, performs work, and leaves this pattern of retrieve-use-rotate is a clean and auditable access control model.

The Tiered Administration Model

The tiered administration model sometimes called the Microsoft Tier Model or the administrative tier model is a security

architecture that separates administrative accounts into distinct tiers based on the systems they manage, with strict controls preventing accounts from one tier from accessing systems in another tier.

Tier 0 is the most sensitive: it contains the systems that control the entire identity infrastructure—domain controllers, AD CS, Entra Connect, and any other system that can make authoritative changes to the directory. Compromising a Tier 0 system gives an attacker control over all identities in the organization. Tier 0 must be managed only from dedicated Privileged Access Workstations (PAWs) using dedicated Tier 0 admin accounts that are never used for any other purpose.

Tier 1 contains business-critical servers: SCCM, SQL servers, file servers, application servers. These systems are important but do not have the same identity authority as Tier 0 systems. Tier 1 is managed with dedicated Tier 1 server admin accounts that have no access to Tier 0 or Tier 2 systems.

Tier 2 contains workstations and end-user endpoints. IT help desk staff use Tier 2 admin accounts for workstation support. These accounts have no access to servers (Tier 1) or domain controllers (Tier 0).

The critical security property of this model is isolation: compromising a Tier 2 workstation admin account does not provide access to servers or domain controllers. An attacker who compromises a help desk technician's account cannot use that access to pivot to critical infrastructure. In energy environments where endpoint compromise is a real and documented threat, this isolation is a meaningful reduction in the blast radius of a successful attack.



COMMON MISTAKE: Using a Single Admin Account for All Administrative Tasks

One of the most common and most consequential Active

Directory security mistakes is using a single admin account for all administrative tasks: domain administration, server management, and workstation support. An IT administrator who logs into a workstation using a domain admin account to troubleshoot a user issue has just exposed domain admin credentials to any malware running on that workstation. Implementing the tiered administration model requires creating at least three separate admin accounts per IT staff member (Tier 0, Tier 1, Tier 2) a behavioral change that some teams resist. But in energy environments where a domain compromise could affect operational technology and safety systems, the investment in account segregation is not optional. It is a fundamental security control.

4.7 Active Directory Security Monitoring and Auditing

Active Directory is not just a management tool it is a target. Nation-state actors and criminal groups specifically target AD because controlling the directory means controlling the entire enterprise. Energy sector organizations, given their status as critical infrastructure operators, are high-value AD targets. Monitoring AD for indicators of compromise unauthorized changes, privilege escalation, suspicious authentication patterns is as important as the hardening work described in previous sections.

Critical Events to Monitor

The following Active Directory events warrant real-time alerting or regular review in energy environments:

- Event ID 4720 / 4726: User account creation and deletion. New accounts created outside the standard provisioning process, or accounts deleted without a

corresponding HR record, may indicate unauthorized access or insider activity.

- Event ID 4728 / 4729: Members added to or removed from security-enabled global groups. Unauthorized addition to privileged groups (Domain Admins, Enterprise Admins, Backup Operators) is a critical indicator of compromise.
- Event ID 4771 / 4768: Kerberos authentication failures and ticket requests. A surge in Kerberos failures from a single source, or ticket requests for accounts that should not be authenticating, can indicate password spray attacks or Kerberos exploitation attempts.
- Event ID 4625: Failed logon attempts. Monitoring for repeated failed logons against privileged accounts or from unexpected source addresses can detect brute force or credential stuffing activity.
- Event ID 4672: Special privileges assigned to logon. This event fires when a user with special privileges (SeDebugPrivilege, SeTakeOwnershipPrivilege, etc.) logs on monitoring this for non-Tier 0 accounts catches privilege escalation.
- Directory Service Access events (Event ID 4662): Access to sensitive AD objects AdminSDHolder, domain naming contexts, schema that should only be accessed by authorized administrators.

PRACTITIONER TIP: Forward AD Events to Your SIEM Immediately

✓ Domain controller event logs are the single most valuable data source for detecting Active Directory attacks. Configure all domain controllers to forward security event logs to your SIEM in real-time. The events described above, combined with baselines for normal authentication patterns at each site, will surface the vast majority of meaningful AD attack indicators. In energy environments, correlate AD authentication events

with operational system access logs where possible an account authenticating to AD from an unexpected location and then accessing an operational system is a higher-confidence alert than either event alone.

CASE STUDY | AD Restructuring During a Windows 10 Migration Composite Scenario

Background

A large natural gas company with approximately 6,000 AD objects users, computers, and service accounts accumulated over 15 years undertook a Windows 10 migration that revealed serious AD structural problems: no separation of computer and user objects, all service accounts in the default Users container with no dedicated policy, and a GPO structure with 40 GPOs, many with unclear purposes and overlapping settings.

Problem Identified

During pre-migration testing, the team discovered that several critical GPOs had conflicting settings applied to the same OU, and that several security hardening settings intended for corporate workstations were also applying to operational technology workstations at processing plants something that had gone undetected because no one was auditing GPO application scope. The GPO for USB device restrictions had been blocked at the FieldOps OU due to a Block Inheritance setting with no documentation meaning field workstations had no USB restriction for an unknown period.

Approach

The migration project included a parallel AD restructuring workstream. A new OU structure was designed, documented, and approved before any object migration. GPOs were audited using RSoP analysis on representative devices from each OU. Redundant and conflicting GPOs were consolidated. The USB restriction GPO was re-linked at the FieldOps OU level with Block Inheritance removed and the Enforced flag set. Service accounts

were migrated to a dedicated OU with appropriate access restrictions.

Outcome and Lessons

The restructuring added three months to the migration timeline but eliminated four known security gaps and dramatically simplified ongoing GPO management. The key lesson: AD restructuring is best done in conjunction with a major project (OS migration, domain consolidation) rather than as a standalone effort the business case is stronger and the change management is already underway. The second lesson: document every GPO's purpose, intended scope, and the rationale for any Block Inheritance or Enforced flag in the GPO description field. Future IT staff will thank you.

PRACTITIONER PERSPECTIVE | Active Directory Engineer | Large Upstream Energy Company (Anonymous)

"What is the single most impactful AD security improvement you have made in an energy environment?"

Windows LAPS. By a significant margin. Before LAPS, we had the same local admin password on every workstation it had been set during our imaging process years ago and never changed. We discovered this was the case during a red team exercise when the team compromised a field site workstation in about 20 minutes and then used that credential to move laterally to 30 other field machines in under an hour. After LAPS, each machine has a unique password, and lateral movement via local admin is essentially eliminated. It was not a hard deployment a GPO and a one-time AD schema extension. The hardest part was getting management to prioritize it before the red team exercise rather than after.

- Active Directory OU structure should reflect the operational geography of the energy company

Corporate, Regional, and FieldOps as distinct branches with computers and users always separated and service accounts isolated in a dedicated OU with restricted policy.

- Read-Only Domain Controllers (RODCs) at remote and field sites provide local authentication capability when WAN connectivity is unavailable, with Password Replication Policy controlling which accounts are cached at each site.
- Group Policy follows the LSDOU processing model. The Default Domain Policy should contain only password, lockout, and Kerberos settings. All other settings should be in purpose-specific, descriptively named GPOs linked at the appropriate OU level. The Enforced flag should be used for settings that must apply universally, such as USB restrictions and security baselines.
- Hybrid identity via Microsoft Entra Connect synchronizes on-premises AD to Entra ID, enabling Hybrid Azure AD Join, Windows Hello for Business, Intune co-management, and Conditional Access. Service accounts and OT-adjacent accounts should be excluded from synchronization via filtered sync.
- Windows Hello for Business replaces password authentication with hardware-backed two-factor authentication. Cloud Kerberos Trust is the recommended deployment model for most energy companies. Staged rollout using security group filtering minimizes deployment risk.
- Windows LAPS generates unique local administrator passwords per device, stored in AD or Entra ID. This eliminates the lateral movement vector created by shared local admin passwords one of the most impactful and underdeployed security controls in enterprise Windows environments.
- The tiered administration model separates administrative accounts into Tier 0 (identity infrastructure), Tier 1

(servers), and Tier 2 (workstations), preventing lateral movement from compromised workstation admin credentials to domain controllers or servers.

- AD security monitoring forwarding domain controller event logs to a SIEM in real-time and alerting on privilege escalation, unauthorized group membership changes, and authentication anomalies is as important as hardening configuration.

Chapter 4 Checklist: Active Directory and Identity Management Readiness

☐	OU structure separates computers from users, has dedicated service account OU, and reflects operational geography
☐	OU and GPO naming conventions are documented and consistently applied across the domain
☐	RODCs are deployed at remote and field sites with configured Password Replication Policy (explicit allow list)
☐	Default Domain Policy contains only password policy, account lockout, and Kerberos settings no custom additions
☐	All custom security and configuration settings are in purpose-specific, descriptively named GPOs
☐	GPO RSoP audit has been performed on representative devices from each major OU to verify intended application
☐	CIS Benchmark Level 1 settings have been evaluated and implemented as the workstation security baseline GPO
☐	USB device restriction GPO is deployed with the Enforced flag at the appropriate OU level
☐	Microsoft Entra Connect is deployed, current, and synchronized with filtered sync excluding service and OT accounts
☐	Hybrid Azure AD Join is enabled and validated for all domain-joined endpoints
☐	Windows Hello for Business is deployed using a staged security group rollout, starting with IT staff
☐	Windows LAPS is deployed on all managed workstations and

	servers, with AD or Entra ID as the password store
☐	LAPS password rotation is configured for all managed devices with automatic rotation after admin use
☐	Tiered administration model is implemented with separate Tier 0, Tier 1, and Tier 2 admin accounts per IT staff
☐	Domain controller security event logs are forwarded to SIEM in real-time with alerting on critical event IDs
☐	AD group membership audits for privileged groups are scheduled semi-annually
☐	Service account inventory is maintained with documented purpose, owner, and last-reviewed date

References and Further Reading

Microsoft Documentation

Microsoft. Active Directory Domain Services Overview. Microsoft Learn, learn.microsoft.com. Continuously updated.

Microsoft. Plan a Windows Hello for Business Deployment. Microsoft Learn, learn.microsoft.com/windows/security/identity-protection/hello-for-business/deploy. 2022.

Microsoft. Windows LAPS Overview. Microsoft Learn, learn.microsoft.com/windows-server/identity/laps. Continuously updated.

Microsoft. Get Started with Windows LAPS and Microsoft Entra ID. Microsoft Learn, 2022.

Microsoft. Microsoft Entra Connect Sync: Overview. Microsoft Learn, learn.microsoft.com/entra/identity/hybrid. Continuously updated.

Microsoft. *Hybrid Azure AD Join*. Microsoft Learn, learn.microsoft.com/entra/identity/devices/hybrid-join-plan. Continuously updated.

Security Best Practices

Center for Internet Security (CIS). *CIS Microsoft Windows 10 Benchmark*. cisecurity.org. Continuously updated.

Center for Internet Security (CIS). *CIS Microsoft Windows 11 Benchmark*. cisecurity.org. Continuously updated.

Quest Technology Management. *Best Practices for Securing and Managing Active Directory*. questsys.com, 2022.

Varonis. *12 Group Policy Best Practices: Settings and Tips for Admins*. varonis.com, 2022.

TechTarget / SearchWindowsServer. *How to Deploy Windows LAPS for Tighter Security*. techtarget.com, 2022.

Industry and Regulatory References

Microsoft. *Securing Privileged Access Reference Material (Tiered Administration Model)*. learn.microsoft.com/security/privileged-access-workstations. 2022.

National Institute of Standards and Technology (NIST). *NIST SP 800-53: Security and Privacy Controls for Information Systems*. csrc.nist.gov. Rev. 5, 2020.

CISA. *Known Exploited Vulnerabilities Catalog (Active Directory-related entries)*. cisa.gov/known-exploited-vulnerabilities-catalog. Continuously updated.

Cybersecurity in Critical Infrastructure

Protecting Systems Where Failure Is Not an Option

In every other industry, a cybersecurity failure is a business problem. In the energy sector, it is a safety problem, an environmental problem, and a national security problem sometimes all three simultaneously.

CISO, Large North American Energy Company

5.1 The Stakes Are Different Here

The energy sector has the highest concentration of critical infrastructure of any industry in North America. Pipelines that carry 45 percent of the East Coast's fuel supply. Power grids that serve millions of homes and hospitals. Compressor stations that maintain gas pressure across interstate transmission networks. Water treatment facilities co-located with energy operations. When cybersecurity fails in this environment, the consequences ripple outward in ways that a corporate IT breach in a financial services firm never could.

The threat data confirms what energy sector practitioners already know intuitively: their industry is one of the most targeted in the world, and the attackers are getting better. The statistics in this chapter are not presented to generate alarm

they are presented because energy sector IT professionals who understand the threat landscape are dramatically better equipped to make sound security decisions than those who do not.

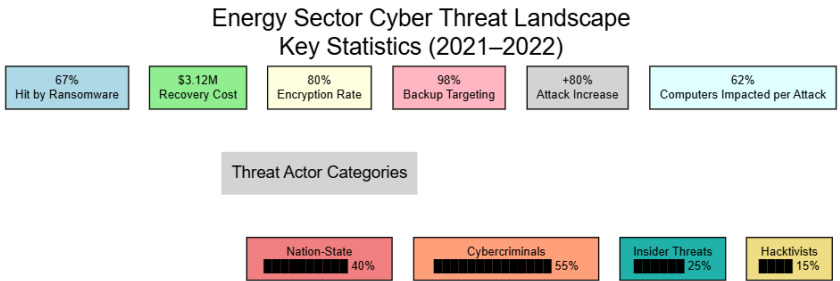


Figure 5.1 Energy sector cybersecurity statistics, 2021–2022. The energy sector consistently ranks among the most targeted and most severely impacted industries globally. Particularly notable: 98% of ransomware attacks attempted to compromise backups, with a 79% success rate the highest across all sectors. Sources: Sophos State of Ransomware in Critical Infrastructure 2022; TrustWave Energy Threat Intelligence Report 2022; KELA Threat Intelligence 2022.

The Threat Actor Landscape

Energy companies face a more diverse threat actor landscape than most enterprises. Three distinct categories of adversary drive the majority of serious incidents:

- Nation-state actors: According to Security Magazine, approximately 60 percent of cyberattacks targeting critical infrastructure sectors are attributed to state-affiliated actors. For the energy sector, Russia, China, Iran, and North Korea have all been attributed to significant campaigns targeting energy infrastructure not primarily for financial gain, but for intelligence collection,

pre-positioning for potential disruption, and geopolitical leverage. The SolarWinds supply chain breach of 2020, which affected numerous energy companies, was attributed to Russian intelligence services. The 2015 and 2016 Ukraine power grid attacks the first confirmed cyberattacks to cause power outages were attributed to Russian state actors.

- Financially motivated criminal groups: Ransomware-as-a-service (RaaS) groups represent the most frequent and most operationally disruptive threat to energy IT. The Colonial Pipeline attack (DarkSide, 2021), and hundreds of smaller incidents represent the ongoing impact of criminal ransomware on the sector. These groups have evolved from opportunistic attackers to sophisticated operators who conduct reconnaissance, identify backup infrastructure for pre-attack destruction, and calibrate ransom demands to the target's apparent ability to pay.
- Hacktivists and insider threats: Hactivist groups motivated by environmental, political, or social grievances have targeted energy companies with increasing sophistication, including attacks on industrial control systems. A recent industry report noted that hactivist groups have caused operational disruptions at over 1,000 sites a 146 percent increase from the previous year. Insider threats, while statistically less frequent, carry disproportionate risk because insiders already have network access, understand operational systems, and may be motivated by grievance, financial pressure, or coercion.

5.2 The Regulatory Framework: NERC CIP and TSA Pipeline Security

Energy sector IT operates under a regulatory cybersecurity framework that has no equivalent in most other industries.

Understanding this framework not at the level of a compliance lawyer, but at the level of an IT practitioner who makes decisions affected by it is essential for anyone working in energy sector IT.

The two most significant regulatory frameworks for energy IT professionals in North America are NERC CIP (primarily for electric utilities) and the TSA Pipeline Security Directives (for pipeline operators). Both impose specific, auditable cybersecurity requirements with legal and financial consequences for non-compliance.



Figure 5.2 NERC CIP standards reference map for IT professionals. Standards highlighted in red (CIP-005, CIP-007, CIP-008, CIP-010) have the highest direct IT impact: electronic security perimeters, systems security management, incident reporting, and configuration change management. CIP-015, currently proposed and under NERC review, would add Internal Network Security Monitoring (INSM) requirements for high and medium impact BES Cyber Systems. Source: NERC CIP Standards documentation; Certrec NERC CIP Summary; Fortinet NERC CIP guide.

NERC CIP: Key Standards for IT Professionals

NERC CIP applies to owners, operators, and users of the Bulk Electric System (BES) the interconnected electrical transmission network that operates at 100kV or above. If your energy company operates within or adjacent to the BES, your IT activities are subject to NERC CIP requirements. The following standards have the highest direct impact on IT operations:

- CIP-005 (Electronic Security Perimeters): Requires the definition and enforcement of Electronic Security

Perimeters (ESPs) around BES Cyber Systems. All electronic access to systems within an ESP must be controlled, monitored, and logged. For IT professionals, this means that any system that can communicate with BES-adjacent systems even indirectly must be carefully documented and its access controlled. The IT/OT boundary is not just a conceptual line; under CIP-005, it is a defined, auditable control.

- CIP-007 (Systems Security Management): This is the most technically demanding standard for IT practitioners. CIP-007 requires: logical port management (disable all ports not required for operations), security patch management with documented timelines for high-impact systems, malware prevention, security event monitoring and log retention, and system access controls. Patch management under CIP-007 is not optional and must be documented if a patch cannot be applied within the required timeframe, a compensating control and exception documentation are required.
- CIP-008 (Incident Reporting and Response Planning): Requires a documented incident response plan specifically for Cyber Security Incidents affecting BES Cyber Systems. Critically, CIP-008 requires notification to the NERC Electricity Information Sharing and Analysis Center (E-ISAC) within one hour of identifying a Cyber Security Incident that has or may have had an impact on BES operations. The plan must be tested at least once every 15 calendar months, with documented lessons learned.
- CIP-010 (Configuration Change Management and Vulnerability Management): Requires baseline configurations for all BES Cyber Systems, documentation of all changes to those baselines, and vulnerability assessments every 35 calendar days for high-impact systems. For IT professionals responsible for managing workstations at operational sites, this means

that any change to a system within scope a software update, a configuration change, even a hardware replacement must be documented and compared against the established baseline.

- CIP-015 (Internal Network Security Monitoring, proposed and under NERC review): The newest NERC CIP standard, CIP-015 requires continuous network security monitoring inside Electronic Security Perimeters for high and medium impact BES Cyber Systems. This represents a significant expansion of logging and monitoring requirements and will require IT teams supporting BES-adjacent environments to implement or expand internal network visibility capabilities.

PRACTITIONER TIP: Build CIP Compliance Evidence Into Your Operational Processes

✓ The most common NERC CIP audit finding is not failure to implement a security control it is failure to document that the control was implemented. Patch compliance reports, change management tickets, access review records, and incident response plan tests must be maintained as audit evidence. Integrate compliance documentation into your day-to-day operational processes rather than treating it as a separate compliance exercise. When a NERC audit occurs, the evidence should already exist as a natural byproduct of your operational activities not as a last-minute reconstruction.

TSA Pipeline Security Directives

Following the Colonial Pipeline ransomware attack in May 2021, the Transportation Security Administration issued a series of cybersecurity directives specifically for critical pipeline operators. These directives SD-02A, SD-02B, SD-02C, and subsequent updates impose requirements that parallel many NERC CIP elements but apply to the pipeline sector specifically:

- Designation of a Cybersecurity Coordinator: Pipeline operators must designate a Cybersecurity Coordinator available 24/7 to coordinate with TSA and CISA on cybersecurity issues.
- Incident Reporting: Confirmed or potential cybersecurity incidents must be reported to CISA within 12 hours of identification a significantly tighter window than most enterprises are accustomed to.
- Cybersecurity Assessment: Operators must conduct and document annual cybersecurity assessments against TSA's prescribed framework and submit results to TSA.
- Cybersecurity Implementation Plan: A documented plan addressing five security outcomes: network segmentation to prevent operational disruption if IT systems are compromised; access control for operational technology; continuous monitoring and detection; remediation of known vulnerabilities; and a cybersecurity response plan.

For IT professionals at pipeline operators, the TSA directives create direct operational requirements: network segmentation plans, access control implementations, and monitoring capabilities must be documented and demonstrably implemented. The 12-hour CISA reporting requirement means that incident response procedures must be fast and well-rehearsed a cyber incident on a pipeline network is not a situation where an organization has days to assess and draft a disclosure.

COMMON MISTAKE: Treating NERC CIP as a Compliance Exercise Rather Than a Security Framework



A persistent mistake in energy sector IT is approaching NERC CIP as a check-the-box compliance exercise: doing the minimum necessary to pass an audit without meaningfully improving security posture. This approach fails on both

dimensions audit findings for documentation gaps are expensive to remediate, and the underlying security vulnerabilities that the standards are designed to address remain. The organizations that manage NERC CIP most effectively treat it as a security framework that happens to have audit requirements: they implement the controls because the controls are good security practice, and the audit documentation follows naturally. An organization that truly implements CIP-007's patch management requirements is also genuinely more secure against ransomware the compliance and the security benefit are inseparable.

5.3 Defense-in-Depth: The Security Architecture Principle

Defense-in-depth is the foundational security architecture principle for critical infrastructure protection: the idea that security should be implemented in multiple independent layers so that the failure of any single control does not result in a compromise of the entire system. An attacker who penetrates the network perimeter still faces identity controls, endpoint controls, application controls, and data protection controls before reaching sensitive systems or data.

For energy IT professionals, defense-in-depth is not just a good idea it is the conceptual framework behind NERC CIP (which requires multiple overlapping controls at the perimeter, identity, and endpoint layers), NIST's Cybersecurity Framework, and the CIS Controls. Understanding where your organization's controls sit within this framework, and where the gaps are, is the starting point for any meaningful security improvement program.

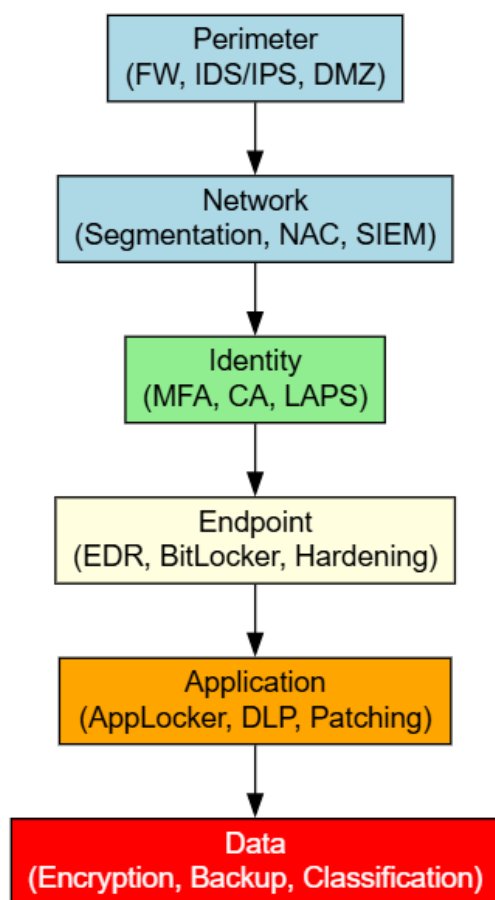


Figure 5.3 Defense-in-depth model for energy IT environments. Each layer provides independent security value; a breach of one layer does not mean all layers are compromised. Energy-specific additions include the IT/OT DMZ in Layer 2 and field-site adaptations at Layer 4 for devices with limited connectivity. Sources: NIST SP 800-53; CIS Controls v8; Microsoft Zero Trust architecture.

The IT/OT Boundary as a Security Layer

In energy environments, the IT/OT boundary the demilitarized zone between business IT systems and operational technology is itself a critical security layer in the defense-in-depth model. A properly implemented IT/OT boundary means that a

ransomware attack that compromises the IT environment cannot automatically propagate to SCADA systems, DCS, or PLCs. The Colonial Pipeline incident was, in one interpretation, a defense-in-depth success story: the OT systems were not directly compromised, and the IT/OT boundary held. The shutdown was a precautionary business decision, not a technical necessity which is a meaningful distinction.

IT professionals bear shared responsibility for the integrity of this boundary. Any network connection, communication path, or data transfer that crosses the IT/OT boundary is a potential attack vector that must be controlled, logged, and periodically reviewed. Common IT-to-OT connection points that require careful management include: historian servers that pull data from OT for business reporting, remote monitoring applications that allow IT staff to view OT dashboards, vendor access connections that use IT network infrastructure to reach OT systems, and data replication processes that synchronize OT event data to IT databases.

PRACTITIONER TIP: Map Every IT-to-OT Data Flow Before Attempting to Secure the Boundary



You cannot secure a boundary you have not mapped. Before implementing any IT/OT boundary controls, conduct a data flow mapping exercise that documents every communication path crossing the boundary: source, destination, protocol, port, purpose, and frequency. This inventory almost always reveals connections that were not known to IT, were not approved by OT, or were established years ago for a purpose that no longer exists. The mapping exercise is also valuable for NERC CIP-005 compliance documentation. Use it as the foundation for your Electronic Security Perimeter definition.

5.4 Workstation Hardening in Energy Environments

Workstation hardening the systematic reduction of attack surface on managed endpoints is one of the highest-leverage security activities available to energy sector IT teams. Most endpoint-based attacks succeed because of misconfigurations, excessive privileges, or unpatched vulnerabilities that could have been prevented by disciplined hardening. The workstation hardening framework described in this section is grounded in the CIS Controls v8, NIST SP 800-171, and NERC CIP-007 requirements.



Figure 5.4 Workstation hardening framework for energy IT environments. The six categories address the full attack surface of a managed endpoint. Account Security and Application Control represent the two highest-leverage categories: most successful ransomware attacks rely on either compromised credentials or execution of unauthorized code. References: CIS Controls v8, NIST SP 800-171, NERC CIP-007, Microsoft Security Baseline for Windows 10/11.

Microsoft Defender Attack Surface Reduction (ASR) Rules

Microsoft Defender for Endpoint includes a set of Attack Surface Reduction (ASR) rules GPO and Intune-configurable policies that block specific attack techniques at the endpoint level. These rules are not antivirus: they are behavioral controls that prevent the execution of known-malicious patterns regardless of whether the specific malware has been seen before. Key ASR rules for energy environments include:

- Block executable files from running unless they meet a prevalence, age, or trusted list criteria: Prevents execution of newly introduced or rare executables a common pattern in ransomware initial access.
- Block Office applications from creating executable content: Prevents malicious macros in Office documents from writing and executing files one of the most common phishing payload delivery mechanisms.
- Block credential stealing from the Windows local security authority subsystem (LSASS): Prevents credential dumping tools like Mimikatz from extracting credential hashes from memory a critical control given the energy sector's elevated risk of nation-state targeted attacks.
- Block process creations originating from PSEXEC and WMI commands: Prevents lateral movement using administrative tools that attackers commonly abuse to spread across networks after initial compromise.
- Use advanced protection against ransomware: Enables machine-learning-based ransomware detection that supplements traditional signature-based detection important given the high backup compromise rate (79%) in energy sector ransomware attacks.

PRACTITIONER TIP: Deploy ASR Rules in Audit Mode First

ASR rules can cause application compatibility issues if deployed in block mode without testing. Deploy in audit mode (which logs what would have been blocked without actually blocking it) for a minimum of four weeks, review the audit logs for false positives, and work with application owners to address legitimate applications that would be blocked before switching to enforcement mode. In energy environments where specialized field applications may have unusual execution patterns, this pre-deployment audit period is critical for avoiding operational disruptions.

Ransomware-Specific Controls

Given that the majority of energy sector organizations have been targeted by ransomware in recent years, and that attacks routinely target backup systems, ransomware-specific controls deserve dedicated treatment:

- **Immutable backups:** Configure backup infrastructure with immutable (write-once) storage that cannot be modified or deleted even by accounts with backup administrator privileges. The 79 percent backup compromise success rate in energy sector ransomware attacks is almost entirely attributable to backup systems that share credential domains with the production environment a single compromised domain admin account can wipe both.
- **3-2-1-1 backup rule:** Maintain at least three copies of data on two different media types, with one copy offsite and one copy air-gapped or immutable. In energy environments, this means ensuring that at least one backup copy is completely inaccessible from the corporate network not just on a different server, but on infrastructure that cannot be reached by a compromised domain account.
- **Controlled folder access:** Enable Windows Defender's Controlled Folder Access feature, which prevents unauthorized applications from modifying protected folders. This is a direct anti-ransomware control that blocks the file encryption behavior that is the primary mechanism of ransomware damage.
- **Network segmentation to limit blast radius:** Implement network segmentation between business units, sites, and functions so that a ransomware infection starting at one location cannot automatically reach the entire network. Flat networks where every device can communicate with every other device are the primary reason that energy sector ransomware attacks impact 62 percent of

computers on average, compared to 49 percent cross-sector.

COMMON MISTAKE: Backing Up to a Network Share on the Same Domain

!

Backing up to a network share accessible from the same domain is the single most effective way to ensure that a ransomware attacker who compromises a domain admin account can destroy your backups. This is not a theoretical risk the 79 percent backup compromise rate in energy sector ransomware attacks is a direct consequence of backup systems that share domain credentials with production. Backup storage must be either: (a) in a separate, isolated network segment with no domain trust, (b) a cloud service with MFA-protected access that is not accessible via any on-premises domain account, or (c) physically air-gapped media stored offsite. The cost of implementing one of these options is trivial compared to the \$3.12 million average recovery cost when backups fail.

5.5 Incident Response Planning for Energy Environments

Incident response planning in energy companies is more complex than in most enterprises because the response to a cyber incident must be coordinated simultaneously across IT (technical response), operations (production impact assessment and safety protocols), legal and compliance (regulatory reporting obligations), and executive leadership (communications and business continuity decisions). An IR plan that covers only the IT dimension is incomplete and will fail at the moment it is most needed.

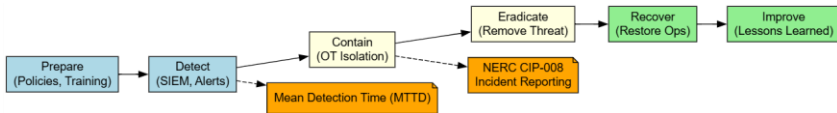


Figure 5.5 Incident response lifecycle adapted for energy company contexts. Key energy-specific additions: NERC CIP-008 1-hour E-ISAC reporting requirement in the Contain phase; mandatory OT assessment before isolating any field site system; CIP-009 recovery plan execution in the Recover phase; and CIP-008 lessons learned documentation in the Improve phase. The mean breach detection time of approximately 197 days (IBM Cost of a Data Breach Report 2022) underscores the importance of proactive detection capabilities.

Energy-Specific IR Plan Components

In addition to the standard incident response elements (roles and responsibilities, escalation paths, communication templates, technical runbooks), energy company IR plans must address:

- **Operations notification protocol:** A defined process for notifying operations teams immediately when a cyber incident is identified. This notification must happen before any containment action that could affect operational systems or communications. The operations team must be able to assess production impact and make safety-critical decisions about whether to continue or halt operations before IT containment actions are taken.
- **OT boundary protection protocol:** A specific procedure for assessing whether a cyber incident in the IT environment has reached or is likely to reach OT systems. This assessment should involve OT engineers and SCADA operations personnel, not just IT. The decision to isolate or shut down OT systems must involve operations leadership and follow established safety protocols it is never purely an IT decision.

- Regulatory reporting timeline: A documented tracking system for regulatory reporting obligations triggered by a cyber incident. NERC CIP-008 requires E-ISAC notification within one hour for BES-affecting incidents. TSA Pipeline Security Directives require CISA notification within 12 hours. These timelines are not aspirational they are legal obligations with audit trails.
- Ransom payment decision protocol: A pre-approved decision tree that defines who has the authority to authorize ransom payment, what legal and law enforcement consultation must occur before that decision, and how the payment would be executed. Having this documented in advance prevents chaotic decision-making under pressure a ransomware attack is not the time to discover that no one knows who can authorize a \$3 million wire transfer.

PRACTITIONER TIP: Run an Annual Tabletop Exercise That Includes Operations Leadership

✓ The most common IR plan weakness revealed in post-incident reviews is the discovery that operations leadership was not aware of their role in the IT incident response process. Annual tabletop exercises that include the CTO, VP of Operations, General Counsel, and communications leadership not just the IT and security teams surface these gaps in a controlled environment rather than during an actual incident. Run the scenario through to the regulatory reporting decision point: who makes the call to notify CISA? Does that person know they have 12 hours? The answers to these questions should be confirmed and documented before you need them.

5.6 Supply Chain Security in Energy Environments

The energy sector's reliance on a complex web of vendors, managed service providers, and specialized operational technology suppliers creates a supply chain attack surface that has attracted increasing attention from both regulators (NERC CIP-013) and threat actors. The SolarWinds attack of 2020 demonstrated that compromising a trusted software vendor can provide nation-state actors with access to hundreds of high-value targets simultaneously including energy companies.

For IT professionals in energy organizations, supply chain security means:

- Vendor risk assessment: Evaluating the cybersecurity posture of vendors before granting them access to corporate systems or data. This is particularly important for vendors who require remote access to operational systems a managed service provider with poor security practices and access to your network is a high-value attack vector.
- Software integrity verification: For BES Cyber Systems subject to NERC CIP-013, validating the integrity and authenticity of software updates before applying them. This involves checking digital signatures, comparing file hashes against vendor-published values, and in high-risk cases, testing updates in an isolated environment before production deployment.
- Vendor access management: Managing vendor remote access sessions with time-limited, monitored, and logged access rather than persistent VPN credentials. Vendors should authenticate with MFA, their sessions should be recorded where technically feasible, and access should be terminated immediately at the end of a service engagement.

- Third-party security contractual requirements: Working with procurement and legal to include minimum security requirements in vendor contracts particularly for vendors with access to BES Cyber Systems. These requirements should specify patch management obligations, incident reporting timelines, and the right to audit vendor security practices.

CASE STUDY | Ransomware Preparedness Assessment at a Large Pipeline Operator Composite Scenario

Background

A large pipeline operator with approximately 5,000 managed endpoints and operations across 15 states conducted an internal ransomware preparedness assessment following the publication of the Sophos critical infrastructure ransomware report. The assessment was prompted by a board-level request for a realistic assessment of ransomware risk following the Halliburton incident.

Assessment Findings

The assessment team found three critical gaps. First, backup infrastructure was accessible from domain admin accounts a ransomware attacker with domain admin credentials could wipe all backups before triggering encryption. Second, network segmentation between site types was inconsistent: corporate and field networks shared routing infrastructure, meaning a corporate workstation compromise could theoretically reach field site devices. Third, the incident response plan's operations notification protocol had not been tested with operations leadership, and the Regulatory Affairs team was unaware of the TSA 12-hour CISA reporting requirement.

Remediation Approach

The backup architecture was redesigned with immutable cloud-based backup (separate tenant, MFA-protected, no domain credential access). Network segmentation was enhanced with explicit ACLs between corporate and field VLANs. A tabletop

exercise was conducted with the VP of Operations, General Counsel, and VP of Regulatory Affairs the first time these leaders had participated in a cyber IR exercise. The operations notification protocol and regulatory reporting decision tree were updated and approved by all parties.

Outcome and Lessons

The remediation required six months and significant investment, but the board assessment confirmed that the pre-remediation gap represented existential risk: a successful attack against the legacy backup architecture would have likely resulted in complete data loss with no viable recovery path. The key lesson: ransomware preparedness is not a technical problem that IT can solve alone. The backup architecture gap was purely technical. The IR plan gaps were organizational. Both were equally dangerous.

PRACTITIONER PERSPECTIVE | VP of IT / Acting CISO | Large Midstream Energy Company (Anonymous)

"What is the single security control that would have prevented most of the major energy sector incidents you are aware of?"

Multi-factor authentication. The vast majority of successful attacks I am aware of in our sector and in the published incident reports started with a compromised credential that did not have MFA. Colonial Pipeline: no MFA on the VPN account. Halliburton: initial access via compromised credentials. The 2021 Florida water treatment facility hack: remote access without MFA. MFA is not glamorous and it creates user friction, but it is the single control with the highest return on security investment. Every organization I have spoken with that has fully deployed MFA across all remote access, email, and administrative consoles has dramatically reduced their successful initial access incidents. If I could only implement one security control in an energy company tomorrow, it would be MFA everywhere, no exceptions.

5.7 The Human Layer: Security Awareness in Energy Organizations

The most sophisticated technical security controls in the world can be bypassed by a single employee clicking a phishing link or plugging in a found USB drive. In energy environments, where field workers may not have the same security training culture as corporate IT staff, and where operational urgency can override careful decision-making, the human layer of security deserves dedicated attention.

Effective security awareness in energy companies goes beyond the annual compliance training video. It means building a security culture where field operators know not to plug in unauthorized devices, where supervisors understand their role in reporting suspicious activity, and where everyone from executives to contract workers understands that they are part of the security perimeter.

- **Role-specific training:** Field operators need different security training than corporate IT staff. Training for field workers should focus on recognizing phishing attempts in work-order emails, not plugging in USB devices found at work sites, reporting suspicious activity on operational workstations, and what to do if a device behaves unusually. It should be brief, practical, and delivered in a format accessible at the work site.
- **Phishing simulation programs:** Regular simulated phishing campaigns sent to all users, with immediate training for those who click are one of the most effective security awareness tools available. In energy companies, these simulations should include scenarios tailored to the industry: fake work order attachments, impersonated vendor invoices, fake safety bulletin emails.
- **Clear reporting channels:** Users who see something suspicious need to know how to report it quickly. A simple, well-publicized reporting mechanism (a dedicated

email address, a button in the email client, a phone number for the security operations center) dramatically increases the volume of user-reported incidents which is valuable intelligence for the security team and reinforces the security culture.

- The energy sector faces a uniquely severe threat landscape. According to recent Sophos research, the majority of energy organizations have been targeted by ransomware, with average recovery costs exceeding \$3.12 million average recovery cost and a 79 percent backup compromise rate the highest of any sector surveyed.
- Nation-state actors, financially motivated ransomware groups, and hacktivists all actively target energy infrastructure, with approximately 60 percent of critical infrastructure attacks attributed to state-affiliated actors.
- NERC CIP provides a mandatory cybersecurity framework for the Bulk Electric System, with 14 standards covering asset categorization, access control, patch management, incident response, and configuration management. CIP-015 (proposed) adds Internal Network Security Monitoring requirements.
- TSA Pipeline Security Directives impose similar requirements on pipeline operators, including a 12-hour CISA incident reporting requirement and annual cybersecurity assessments.
- Defense-in-depth implemented across perimeter, network, identity, endpoint, application, and data layers is the foundational security architecture principle for energy IT. The IT/OT boundary is a critical security layer that requires explicit mapping and control.
- Workstation hardening using CIS benchmark settings, Microsoft Defender ASR rules, EPM (least privilege), USB blocking, and immutable backup architecture

directly addresses the attack vectors most commonly exploited in energy sector ransomware incidents.

- Incident response plans for energy companies must include operations notification protocols, OT boundary protection procedures, regulatory reporting timelines (1-hour for NERC CIP-008, 12-hour for TSA), and a pre-approved ransom payment decision protocol.
- MFA deployed universally across all remote access, email, and administrative consoles remains the single highest-ROI security control for preventing initial access in the vast majority of known energy sector incidents.

Chapter 5 Checklist: Critical Infrastructure Cybersecurity Readiness

☐	Threat landscape briefing is reviewed annually by IT and security leadership; board-level risk communication is current
☐	NERC CIP applicability has been assessed; BES Cyber Systems are identified, categorized (high/medium/low), and documented
☐	CIP-005 Electronic Security Perimeters are defined; all electronic access points are controlled, monitored, and logged
☐	CIP-007 patch management process is documented with timelines; exceptions have compensating controls and exception documentation
☐	CIP-008 incident response plan is current, tested within the last 15 months, and includes E-ISAC 1-hour notification procedure

☐	CIP-010 baseline configurations are documented for all in-scope systems; change management process captures all deviations
☐	TSA Pipeline Security Directive obligations are assessed (if applicable); 12-hour CISA reporting protocol is documented
☐	IT/OT data flow map is current; all cross-boundary connections are documented, approved, and reviewed annually
☐	Defense-in-depth controls inventory is current: perimeter, network, identity, endpoint, application, and data layers assessed
☐	Workstation hardening baseline is deployed (CIS Level 1 minimum); compliance measured and reported monthly
☐	Microsoft Defender ASR rules are deployed in audit mode and evaluated for block-mode enforcement
☐	Immutable backup architecture is in place; backup credentials are not accessible from domain admin accounts
☐	3-2-1-1 backup rule is implemented: 3 copies, 2 media types, 1 offsite, 1 air-gapped or immutable
☐	Multi-factor authentication is enforced on all VPN, email, administrative consoles, and cloud services no exceptions
☐	Annual tabletop exercise includes operations leadership, General Counsel, and Regulatory Affairs
☐	Ransom payment decision protocol is documented and approved by executive leadership
☐	Vendor remote access is time-limited, MFA-protected, logged, and reviewed quarterly

- | | |
|---|---|
| □ | Security awareness training is role-specific; phishing simulation program is active; reporting channel is published |
|---|---|

References and Further Reading

Regulatory and Government Sources

NERC. *Critical Infrastructure Protection (CIP) Standards*. nerc.com/pa/Stand/Pages/CIPStandards.aspx. Continuously updated.

NERC. *CIP-015-1: Cyber Security Internal Network Security Monitoring*. NERC Standards, 2022 (proposed).

Transportation Security Administration. *Pipeline Cybersecurity Initiative*. tsa.gov/pipeline-cybersecurity. 2021–2022.

CISA. *Annual Review*. cisa.gov, 2022.

U.S. Department of Energy, CESER. *Cyber Baselines for Electric Distribution Systems*. DOE, 2022.

U.S. GAO. *Critical Infrastructure Protection: Agencies Need to Enhance Oversight of Ransomware Practices*. GAO. *Critical Infrastructure Cybersecurity*. 2022.

Industry Research

Sophos. *The State of Ransomware in Critical Infrastructure 2022*. sophos.com, 2022.

TrustWave. *Energy and Utilities Sector Threat Intelligence Briefing 2022*. trustwave.com, 2022.

IBM Security. *X-Force Threat Intelligence Index 2022*. IBM Corporation, 2022.

KELA Threat Intelligence. *Escalating Ransomware Threats to National Security*. kelacyber.com, 2022.

Resecurity. *Cyber Threats Against Energy Sector Surge as Global Tensions Mount*. resecurity.com, 2021.

TXOne Networks. *Comprehensive Guide to NERC CIP Compliance*. txone.com, 2022.

Technical Frameworks and Standards

Center for Internet Security. CIS Controls v8. [cisecurity.org](https://www.cisecurity.org). 2021.

NIST. Cybersecurity Framework v2.0. nist.gov/cyberframework. 2021.

NIST. SP 800-53 Rev. 5: Security and Privacy Controls for Information Systems. csrc.nist.gov. 2020.

Microsoft. Defender for Endpoint Attack Surface Reduction Rules Reference. learn.microsoft.com. Continuously updated.

Cloud Integration and Azure in Energy Environments

Modernizing Without Compromising Reliability

Cloud adoption in the energy sector is not a question of if it is a question of how fast and how far. The real skill is knowing which workloads to move, which to keep on-premises, and why.

Director of IT Infrastructure, Large Midstream Energy Company

6.1 Why Energy Companies Approach Cloud Differently

When cloud adoption discussions happen in most industries, the default assumption is that moving workloads to the cloud is good it reduces infrastructure costs, improves scalability, and enables modern capabilities. In the energy sector, this default assumption must be examined more carefully. Not because cloud is bad for energy companies it is not but because the energy sector has constraints that other industries do not, and a cloud adoption strategy that ignores those constraints will fail in predictable and expensive ways.

The energy sector's unique cloud adoption challenges include: regulatory constraints that restrict what data can leave certain network segments (NERC CIP systems within Electronic

Security Perimeters cannot simply be moved to public cloud without careful compliance analysis); operational reliability requirements that make internet dependency unacceptable for systems supporting production operations; connectivity constraints at remote and field sites that make cloud-dependent solutions unreliable; and an IT/OT boundary that means cloud adoption decisions affecting IT systems can have OT security implications if not carefully planned.

None of these challenges mean that energy companies should not adopt cloud services. The evidence from industry leaders Petrobras moving to cloud-native endpoint management with Intune and reporting zero security incidents despite expanded remote access; Uniper using Azure Stack HCI and Azure Arc to manage power plant systems while maintaining regulatory compliance demonstrates that cloud adoption in the energy sector is not only possible but strategically valuable. The key is a deliberate, phased approach that respects the sector's unique constraints.

This chapter provides an honest assessment of where Azure and Microsoft cloud services add value in energy IT environments, where caution is warranted, how to architect cloud integration responsibly, and what a realistic cloud adoption roadmap looks like for a large energy company.

6.2 The Cloud Maturity Journey for Energy IT

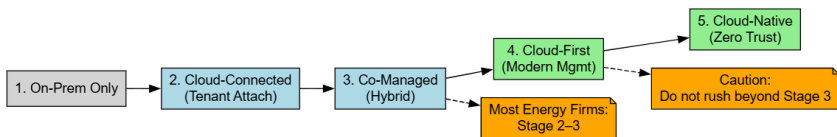


Figure 6.1 Cloud adoption maturity model for energy IT environments. Most large energy companies are currently at Stage 2 (cloud-connected)

or transitioning into Stage 3 (co-managed). The energy sector caution: Stage 5 (full cloud-native) may not be appropriate or achievable for all environments, particularly those with OT-adjacent workloads or field sites with limited connectivity. Progress should be deliberate and validated at each stage.

Understanding where your organization sits in this maturity progression and what the realistic next step is is more valuable than pursuing an aspirational target state that does not account for your organization's specific constraints. A pipeline company that successfully reaches and stabilizes Stage 3 has achieved something genuinely significant: modern endpoint management, cloud-based identity, improved security through Conditional Access and Defender for Endpoint, and the operational agility that co-management provides. That is a meaningful outcome, even if it falls short of the fully cloud-native ideal that technology vendors sometimes promote.

Stage 2: Cloud-Connected The First Cloud Step

For most large energy companies, the entry point into cloud integration is not a major migration it is enabling Microsoft's Tenant Attach and Azure AD (Entra) Connect. These two services, which can be enabled without replacing any existing infrastructure, provide immediate value at very low risk.

Tenant Attach uploads device inventory data from SCCM to the Intune portal, giving IT administrators a cloud-based view of their device fleet without transferring any management authority. It enables remote actions (restart, script execution, application deployment) on SCCM-managed devices through the Intune console which means IT staff can take actions on remote devices without VPN access to the management infrastructure. For energy companies with field sites and remote devices, this is immediately useful.

Entra Connect synchronizes user and group objects from on-premises Active Directory to Microsoft Entra ID, enabling M365

services and laying the groundwork for Hybrid Azure AD Join, Conditional Access, and Windows Hello for Business. These capabilities, covered in Chapter 4, flow from this single configuration step.

PRACTITIONER TIP: Enable Tenant Attach Before Anything Else



Tenant Attach has virtually no deployment risk—it uploads read-only inventory data from SCCM to the cloud and adds remote action capabilities. It requires no changes to your existing SCCM infrastructure, no client changes, and no impact on existing management workflows. The immediate benefit—a cloud-accessible device inventory view and remote management capabilities without VPN—makes it one of the highest-ROI cloud enablement steps available to energy sector IT teams. Enable it in a test environment, validate for two weeks, then enable in production. The entire process should take less than a day of configuration work.

6.3 Cloud Management Gateway: Managing Devices Beyond the Perimeter

The Cloud Management Gateway (CMG) is one of the most practically valuable Azure-based capabilities for energy companies. It extends SCCM's management reach to devices that are outside the corporate network—without requiring VPN—by hosting a cloud proxy in Azure that devices can reach directly over the internet.

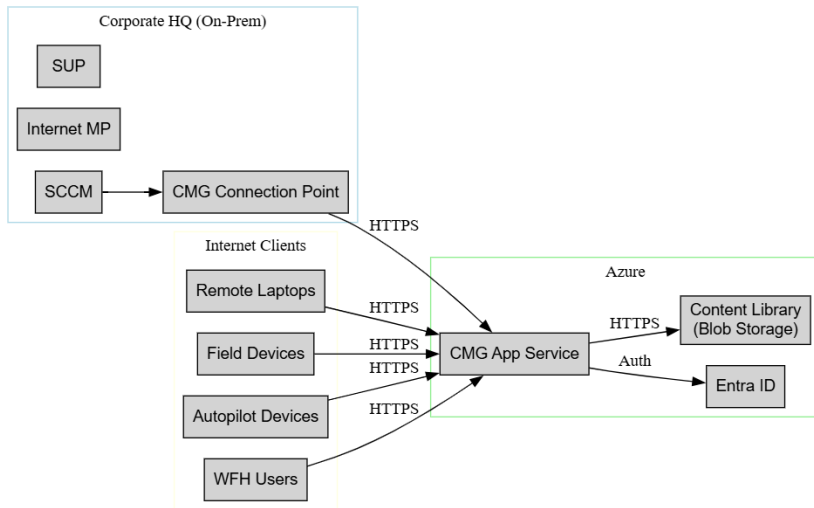


Figure 6.2 Cloud Management Gateway architecture for a large energy company. The CMG, deployed as an Azure App Service, acts as a cloud proxy between internet-based devices and the on-premises SCCM infrastructure. Clients reach the CMG over HTTPS using certificate or Entra ID authentication, and the CMG proxies their policy, patch, and content requests back to the on-premises site systems. This eliminates the VPN dependency for SCCM management of remote and field devices. Source: Microsoft Configuration Manager documentation.

CMG Architecture and Planning

A CMG deployment requires several components that must be configured before devices can use it:

- Azure subscription and app registration: The CMG is deployed as an Azure App Service in a subscription linked to your tenant. A service connection from SCCM to Azure must be configured using an app registration in Entra ID.
- PKI certificates or Entra authentication: CMG clients can authenticate using either PKI certificates (the traditional

approach, requiring an enterprise CA) or Entra ID tokens (the modern approach, requiring Hybrid Azure AD Join). For energy companies already on the Hybrid Join path from Chapter 4, Entra ID authentication is the simpler and more scalable option.

- Internet-enabled management point: The management point must be configured to accept HTTPS connections from internet clients, either directly or via the CMG. This is a role configuration change in SCCM no additional server hardware is required.
- Content distribution: For software deployments over CMG, content must be uploaded to the CMG's Azure storage. Large packages (OS images, large application installers) should be evaluated carefully internet-based content delivery may be slower than local DP delivery for some use cases.

PRACTITIONER TIP: Use CMG with BranchCache to Reduce Bandwidth at Remote Sites

✓ For field sites that have both a Pull Distribution Point (local content cache) and some devices that are internet-connected (not on the corporate network), configuring BranchCache alongside CMG allows devices to share content downloaded via CMG with other devices on the local network segment. This is particularly valuable at sites where a small number of devices are managed and individual internet-based downloads of large packages would consume limited cellular or satellite bandwidth multiple times. Test this configuration in your lab environment before deploying at bandwidth-sensitive sites.

CMG in the Energy Field Site Context

For field sites without Distribution Points sites too small or too remote to justify a local server the CMG becomes the primary

content delivery mechanism. IT teams managing these sites should evaluate CMG against the connectivity profiles of their smallest and most remote locations, specifically:

- **Bandwidth sufficiency:** A 256 kbps satellite link may be insufficient for delivering large patches or application packages over CMG even with bandwidth throttling. Evaluate the size of typical deployments against available bandwidth and adjust maintenance windows accordingly.
- **Latency impact:** High-latency satellite links (300–600ms round-trip) can cause policy retrieval timeouts if not accounted for in CMG timeout configuration. Test CMG client behavior on simulated high-latency connections before deployment.
- **Cellular fallback:** Where field sites use cellular connectivity as either primary or backup, configure CMG client settings to respect cellular network bandwidth limits preventing large deployments from triggering while a device is on a metered cellular connection.

6.4 Microsoft Entra ID: Cloud Identity for Energy Environments

Microsoft Entra ID (formerly Azure Active Directory) is the cloud identity platform that enables nearly every modern Microsoft cloud capability: Conditional Access, device compliance for M365 access, Windows Hello for Business, Intune co-management, and the integration between on-premises AD and cloud services. For energy companies already using M365 and SCCM, Entra ID is not optional it is already in use. The question is how well it is configured and how deeply its capabilities are being leveraged.

Conditional Access as a Security Multiplier

Conditional Access (CA) policies define the conditions under which access to corporate cloud resources is granted or denied. In energy environments, CA policies that require device compliance as a condition of accessing Exchange Online, SharePoint, and Teams provide a significant security uplift: a device that is not enrolled in Intune, not compliant with the organization's security baseline, or not Hybrid Azure AD joined simply cannot access corporate cloud resources even with valid credentials.

This policy, sometimes called Require Compliant Device or Require Hybrid Join, is one of the most impactful access controls available to energy sector IT teams because it directly addresses the compromised credential scenario that has driven most of the sector's major incidents. Even if an attacker obtains valid user credentials through phishing, credential stuffing, or password spray they cannot access cloud resources from an unmanaged device that does not meet the compliance baseline.

Deploying Conditional Access for device compliance requires: Hybrid Azure AD Join for all domain-joined devices; Intune enrollment for all managed devices; compliance policies in Intune that define the minimum security baseline; and CA policies that enforce compliance as an access condition. Each of these steps has dependencies on earlier chapters Chapter 4 (AD and hybrid identity), Chapter 2 (endpoint management and Intune co-management), and Chapter 3 (MDM enrollment).

COMMON MISTAKE: Deploying Conditional Access Without a Pilot and Rollback Plan

! Conditional Access policies that block non-compliant devices from accessing corporate resources will break access for any user whose device is not enrolled or compliant including field operators, executives, and IT staff who may not be part of the enrollment rollout. Deploying CA in enforcement mode without a pilot phase can simultaneously block hundreds or thousands

of users and generate a support crisis that undermines confidence in cloud adoption. Always deploy CA in Report-Only mode first (at least two weeks), review the impact report, identify affected users and devices, enroll and remediate them, then move to enforcement. For energy companies, add an explicit exclusion group for emergency access accounts that must retain access regardless of device state.

Privileged Identity Management (PIM)

Privileged Identity Management (PIM) is an Entra ID Premium P2 service that transforms how privileged access is managed in cloud environments. Instead of assigning permanent privileged role assignments which create standing access that an attacker can exploit at any time PIM implements just-in-time (JIT) privileged access: administrators are eligible for privileged roles but must explicitly activate them for a defined time period (typically 1–4 hours), with approval required from a second administrator for the most sensitive roles.

For energy sector IT teams, PIM is the cloud equivalent of the tiered administration model described in Chapter 4. Global Administrator, Intune Administrator, and Security Administrator roles in Entra ID should be managed through PIM not assigned permanently to any account. The activation audit trail that PIM generates is also valuable for NERC CIP compliance documentation: every use of a privileged role is logged with timestamp, justification (if configured), and approver.

6.5 Azure Security and Compliance Services

Beyond identity and endpoint management, Azure provides a comprehensive portfolio of security and compliance services that are directly relevant to energy sector IT operations. Understanding which of these services provide the highest value

in the energy context and which represent capabilities that may not be needed or appropriate for your environment allows for informed investment decisions.

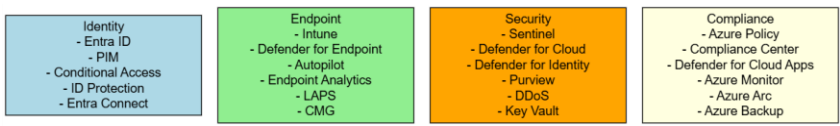


Figure 6.3 Azure security and compliance services reference for energy IT environments. The Identity and Endpoint columns represent the core services for most energy IT teams. Microsoft Sentinel (Security column) is particularly valuable for NERC CIP event monitoring requirements. Azure Arc (Compliance column) enables on-premises server management through the Azure portal relevant for energy companies with large server estates but regulatory restrictions on cloud migration. Source: Microsoft Azure documentation.

Microsoft Sentinel for Energy IT

Microsoft Sentinel is Microsoft's cloud-native Security Information and Event Management (SIEM) and Security Orchestration, Automation and Response (SOAR) platform. For energy companies subject to NERC CIP requirements, Sentinel provides capabilities that address CIP-007 (security event logging and monitoring) and CIP-015 (internal network security monitoring) in a scalable, cloud-managed platform.

Sentinel ingests log data from across the Microsoft ecosystem (Entra ID, Defender for Endpoint, M365, Azure) as well as third-party sources (on-premises SCCM, network devices, Active Directory event logs) and applies machine-learning-based analytics to detect threat patterns. For NERC CIP compliance, Sentinel's audit logging, alert generation, and incident management capabilities can serve as the centralized evidence repository that auditors expect.

The cost model for Sentinel based on data ingestion volume requires careful planning in energy environments. NERC CIP-scoped systems with high logging volumes can generate significant ingestion costs. Evaluate what data must be ingested for compliance and security purposes versus what is nice-to-have, and configure data retention policies that balance compliance requirements against cost.

Azure Arc for On-Premises Server Management

Azure Arc extends Azure management capabilities to on-premises servers, enabling energy companies to manage their on-premises Windows and Linux servers through the Azure portal with the same tools and policies used for cloud resources. For energy companies with regulatory restrictions that prevent certain workloads from being hosted in the public cloud NERC CIP-scoped OT-supporting systems, for example Azure Arc provides the operational benefits of cloud management without actually moving the workload.

Uniper, the German energy producer operating power plants across Europe, adopted Azure Stack HCI (now Azure Local) enabled by Azure Arc specifically to address this scenario: sensitive operational data and power plant management systems that cannot be hosted in the public cloud are managed centrally through the Azure portal while remaining on-premises. This architecture sometimes called the adaptive cloud approach is directly applicable to large energy companies navigating the tension between cloud modernization and regulatory data residency requirements.

6.6 Microsoft 365 in Energy Environments

Microsoft 365 (M365) has become the productivity backbone of most large energy companies. Exchange Online for email, Teams for communication and collaboration, SharePoint for

document management, and OneDrive for personal cloud storage are now standard tools across the industry. The cloud delivery model of M365 provides automatic updates, global availability, and built-in compliance features that reduce the operational burden of managing these services on-premises.

M365 E3 - Office Apps - Entra ID P1 - Intune & Autopilot - Defender for Business - Basic DLP Value: Covers core endpoint & identity needs	M365 E5 - Defender for Endpoint P2 - Defender for Identity - Defender for Cloud Apps - PIM - Entra ID Governance Value: Advanced security for IT & privileged users
---	---

Figure 6.4 Microsoft 365 E3 vs E5 licensing comparison for energy IT environments. E3 covers the core endpoint management and identity needs for most employees. E5 security additions particularly Defender for Identity (AD attack detection) and PIM (just-in-time admin access) are strongly recommended for IT staff, security team members, and any user with access to sensitive systems. Verify current licensing with Microsoft. Source: Microsoft 365 licensing documentation, 2022.

Teams Governance in Energy Companies

Microsoft Teams, deployed at scale in energy companies, creates governance challenges that are unique to regulated industries. Teams channels and chats may contain operational information maintenance schedules, incident reports, production data, regulatory filings that must be retained and discoverable for compliance purposes. The default Teams configuration, without governance policies, allows users to create new teams freely, share files without classification, and retain or delete content without oversight.

Energy company Teams governance should address: team creation policies (who can create new teams, what approval is

required); retention policies (how long are messages and files retained minimum periods for regulatory content); sensitivity labels (classification of teams and channels containing sensitive operational data); guest access policies (whether and how external contractors can be added to teams); and naming conventions (standardized team naming that enables discoverability and lifecycle management).

SharePoint and OneDrive: Data Protection in Practice

SharePoint Online and OneDrive for Business store a significant proportion of corporate knowledge and documentation in most energy companies. Protecting this data preventing unauthorized access, ensuring appropriate classification, and managing the lifecycle of sensitive documents requires a combination of Entra ID access controls, Microsoft Purview sensitivity labels, and data loss prevention (DLP) policies.

For energy companies subject to NERC CIP, documents containing BES Cyber System Information (BCSI) as defined by CIP-011 must be protected with encryption and access controls regardless of where they are stored. Storing BCSI in SharePoint Online or OneDrive without applying appropriate sensitivity labels and access restrictions could constitute a CIP-011 compliance failure. Work with your compliance team to assess which SharePoint content falls within CIP-011 scope and implement appropriate protection before migrating that content to the cloud.

6.7 Azure Backup: Cloud-Based Data Protection

Azure Backup provides cloud-based backup for on-premises workloads Windows servers, SQL databases, file shares, and virtual machines as well as Azure virtual machines and other cloud resources. For energy companies looking to implement

the immutable backup architecture described in Chapter 5, Azure Backup's soft-delete and immutability features provide cloud-based backup storage that is architecturally isolated from on-premises domain credentials.

Azure Backup's immutability features specifically the Immutable Vault policy prevent backup data from being deleted or modified for a defined retention period, even by Azure administrators with full permissions. This directly addresses the backup compromise scenario that affects 79 percent of energy sector ransomware attacks: an attacker who compromises on-premises domain admin credentials cannot reach Azure Backup vault data, which is protected by Azure RBAC and MFA-protected cloud access.

When designing an Azure Backup strategy for energy environments, key considerations include: network connectivity for backup data transfer (large backup jobs over limited bandwidth require scheduling during off-peak hours); data residency compliance (ensure backup vaults are provisioned in the appropriate Azure region for regulatory requirements); recovery time objectives (cloud-based recovery of large datasets may be slower than local recovery plan accordingly); and cost management (backup storage costs scale with data volume and retention period).

PRACTITIONER TIP: Configure Azure Backup with Cross-Region Restore for Critical Systems



Azure Backup supports Cross-Region Restore (CRR), which replicates backup data to a paired Azure region and allows recovery even if the primary region experiences an outage. For energy companies where extended downtime of key business systems would affect operational reporting, compliance activities, or executive decision-making, enabling CRR on critical backup vaults provides a level of resilience that on-premises backup solutions rarely achieve. The additional cost is modest relative to the recovery time

improvement it provides.

6.8 Building a Realistic Cloud Roadmap

The most common cloud adoption failure pattern in energy companies is not attempting too little it is attempting too much, too fast, without adequate planning for the sector's unique constraints. Organizations that try to mirror a cloud-native enterprise approach rapidly migrating all management workloads to Intune, moving all data to SharePoint Online, deprecating on-premises infrastructure invariably encounter the field site connectivity problem, the OT-adjacent system constraint, or the NERC CIP compliance question, and are forced to reverse course. The setback damages organizational confidence in cloud adoption and delays the legitimate benefits by years.

A realistic cloud roadmap for a large energy company is measured in years, not quarters, and progresses deliberately through the maturity stages described in Section 6.2.

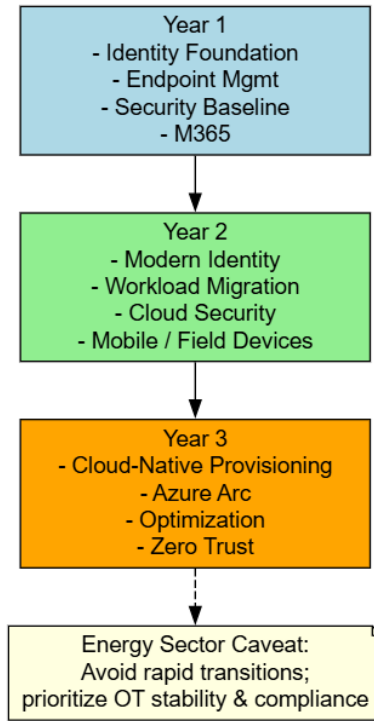


Figure 6.5 A realistic 3-year cloud adoption roadmap for a large energy company. Year 1 builds the foundational services that everything else depends on: identity synchronization, co-management enrollment, endpoint security baseline, and M365. Year 2 migrates workloads and expands modern management capabilities. Year 3 begins the transition toward cloud-native provisioning for new devices and leverages Azure Arc for on-premises server management. The energy sector caveat applies throughout: OT-adjacent and NERC CIP-scoped systems may remain on-premises permanently.

Governance and Cost Management

Cloud adoption without governance quickly becomes cloud sprawl: orphaned resources, unmanaged subscriptions, redundant services, and unexpected costs. Energy companies, accustomed to disciplined capital expenditure processes for

physical infrastructure, sometimes underestimate the operational expense management discipline required for cloud services.

Establish cloud governance practices early, before significant cloud resources accumulate: Azure Management Groups and Subscriptions to organize resources by environment (production, development, test); Azure Policy to enforce configuration standards and tagging requirements across all subscriptions; Azure Cost Management to monitor spending, set budget alerts, and identify optimization opportunities; and a tagging taxonomy that enables cost attribution to business units and projects.

For energy companies with regulatory reporting requirements, the ability to attribute cloud costs to specific projects, business units, or regulatory compliance activities may be important for cost justification and audit purposes. Design the tagging strategy with this in mind.

CASE STUDY | Cloud Integration Rollout at a Large Gas Transmission Company Composite Scenario

Background

A large natural gas transmission company with approximately 7,000 managed endpoints, 150 field sites, and significant NERC CIP compliance obligations undertook a cloud integration program following a strategic decision to modernize IT infrastructure. The CIO's charter was to achieve co-managed endpoints within 18 months while maintaining NERC CIP compliance and not disrupting operations.

Year 1 Approach

The team began with Entra Connect synchronization and Tenant Attach both enabled within the first two months with no operational impact. Hybrid Azure AD Join was rolled out to corporate endpoints using GPO, with field site devices following in a staged rollout scheduled to avoid peak production periods. The Cloud Management Gateway was deployed in Azure with Entra ID

authentication, providing immediate management capability for remote laptops that had previously required VPN for SCCM access. M365 services (Exchange Online, Teams, SharePoint) were already in place, so Year 1 focused on governance improvements: sensitivity labels for BCSI-containing documents, Teams governance policies, and DLP for email.

NERC CIP Compliance Approach

The compliance team worked with IT to assess which Azure services could be used for CIP-scoped systems. The determination: Entra ID authentication for non-BES IT systems was approved; BES Cyber Systems remained on isolated network segments with no Azure connectivity. Defender for Endpoint was deployed to all IT systems (not BES) and Sentinel was used to aggregate and analyze security logs with explicit exclusion of any data from within the Electronic Security Perimeter to avoid unintentional compliance complexity.

Outcome

By the end of Year 1, approximately 4,500 of the 7,000 endpoints were Hybrid Azure AD joined and co-managed. Remote management capability for internet-based devices improved dramatically field laptop support that previously required VPN or a site visit could now be handled via the CMG. Patch compliance improved from 72 percent to 89 percent, primarily because internet-based devices now received patches without requiring VPN connectivity. The NERC CIP compliance posture was maintained throughout, with no audit findings related to cloud integration.

Key Lesson

The most important decision in the entire program was the early agreement between IT and compliance on which systems were in scope for cloud integration and which were not. By clearly separating the IT cloud adoption program from any OT or BES-adjacent systems, the team avoided the compliance complexity that has derailed cloud programs at other energy companies. Scope clarity at the outset is more valuable than any technical capability.

PRACTITIONER PERSPECTIVE | Cloud Architect | Large Integrated Energy Company (Anonymous)

"What advice would you give an energy IT team just starting their cloud adoption journey?"

Start with identity. Every capability you want Conditional Access, Intune co-management, Windows Hello for Business, Autopilot depends on Entra ID being properly configured and your devices being Hybrid joined. If you skip the identity foundation and try to jump straight to deploying Intune or enabling Autopilot, you will encounter failures that are hard to diagnose because the dependency is invisible. Spend the first three months on Entra Connect, Hybrid join, and MFA. Do it right, validate it thoroughly, and everything else will be significantly easier. Also: do not let your compliance team veto cloud adoption entirely because of NERC CIP. Work with them to scope clearly what is and is not in scope. The vast majority of IT systems in a NERC-regulated energy company are not BES Cyber Systems, and those systems can and should adopt cloud services.

Chapter Summary

- Energy companies approach cloud adoption differently from other industries due to regulatory constraints (NERC CIP), operational reliability requirements, field site connectivity limitations, and OT/IT boundary security considerations. A deliberate, phased approach is essential.
- The cloud maturity model for energy IT progresses through five stages: On-Premises Only → Cloud-Connected → Co-Managed → Cloud-First → Cloud-Native. Most large energy companies are currently at Stage 2 or 3. Rushing past Stage 3 without addressing energy-specific constraints creates deployment failures and compliance risk.

- Tenant Attach is the lowest-risk, highest-ROI first step it provides cloud-based device visibility and remote management without changing any existing infrastructure.
- The Cloud Management Gateway extends SCCM management to internet-based devices without VPN, directly addressing the field site and remote user management challenges endemic to energy sector IT.
- Conditional Access policies requiring device compliance as an access condition directly address the compromised credential scenario responsible for most major energy sector incidents. Deploy in Report-Only mode for at least two weeks before enforcement.
- Privileged Identity Management (PIM) implements just-in-time privileged access for cloud admin roles the cloud equivalent of the tiered administration model, and valuable for NERC CIP audit trail documentation.
- Azure Backup with immutability features provides architecturally isolated backup storage that protects against the ransomware backup compromise pattern affecting 79 percent of energy sector attacks.
- A realistic 3-year roadmap focuses Year 1 on identity foundation and co-management enrollment, Year 2 on workload migration and cloud security, and Year 3 on cloud-native provisioning and Azure Arc for on-premises server management.
- Scope clarity between IT and compliance defining which systems are in and out of scope for cloud integration at the outset is more valuable than any technical capability.

Chapter 6 Checklist: Cloud Integration Readiness

☐	Cloud adoption maturity stage has been assessed and documented for each environment type (corporate, regional, field, OT-adjacent)
☐	Regulatory scope assessment completed: NERC CIP-scoped systems are clearly separated from cloud integration roadmap
☐	Microsoft Entra Connect is configured with filtered sync, PHS or PTA, and staging server for HA
☐	Tenant Attach is enabled; Intune portal shows current SCCM device inventory
☐	Hybrid Azure AD Join is rolled out to all domain-joined corporate endpoints; field sites in progress
☐	Cloud Management Gateway is deployed in Azure; internet-based clients (remote laptops, some field devices) are managed via CMG
☐	Conditional Access policies are deployed in Report-Only mode; impact report reviewed; enforcement timeline defined
☐	Privileged Identity Management (PIM) is configured for Global Admin, Intune Admin, Security Admin roles in Entra ID
☐	Microsoft 365 governance policies are in place: Teams creation policy, retention policies, sensitivity labels, guest access policy
☐	SharePoint and OneDrive DLP policies are configured; BCSI assessment completed for cloud-stored documents
☐	Azure Backup is implemented for critical on-premises workloads with immutable vault policy and soft-delete enabled

☐	Azure Monitor / Log Analytics workspace is configured; domain controller and endpoint logs are ingested
☐	Microsoft Sentinel is evaluated for NERC CIP event monitoring requirements; deployment decision documented
☐	Azure Cost Management is configured with budget alerts, tagging policy, and attribution to business units
☐	Cloud adoption roadmap is documented with year-by-year milestones, owner assignments, and success criteria
☐	Cloud governance framework is in place: Management Groups, Azure Policy, subscription structure

References and Further Reading

Microsoft Documentation and Case Studies

Microsoft. Cloud Management Gateway Overview. Microsoft Learn, learn.microsoft.com/configmgr/core/clients/manage/cmgy. Continuously updated.

Microsoft. What is Microsoft Entra ID? Microsoft Learn, learn.microsoft.com/entra/fundamentals. Continuously updated.

Microsoft. Azure Backup Documentation. learn.microsoft.com/azure/backup. Continuously updated.

Microsoft. Petrobras case study Cloud-native endpoint management with Intune. Microsoft Customer Stories, 2022.

Microsoft. Uniper case study Azure Stack HCI and Azure Arc for power plant management. Microsoft Azure Blog, 2022.

Industry Analysis

Gartner. Magic Quadrant for Distributed Hybrid Infrastructure. Gartner, 2022. (Microsoft Azure recognized as Leader.)

Microsoft Azure. 3 Key Cloud Adoption Trends in Migrating and Modernizing Workloads. azure.microsoft.com/blog. 2022.

Microsoft. Manage Your Portfolio Across Hybrid and Multicloud Operations. Cloud Adoption Framework. learn.microsoft.com. Continuously updated.

Regulatory Compliance and IT Governance

NERC CIP, CISA, SOX, and the Compliance Burden

Compliance is not the goal. Security is the goal. Compliance is how you prove it to someone who was not watching.

IT Compliance Manager, Large Electric Utility

7.1 The Compliance Reality in Energy IT

Energy sector IT operates under a compliance burden that would be unrecognizable to IT professionals in most other industries. A single large energy company may simultaneously be subject to NERC CIP (for bulk electric system assets), TSA Pipeline Security Directives (for interstate pipeline operations), CISA guidelines and CIRCIA reporting requirements (as a designated critical infrastructure operator), and Sarbanes-Oxley (SOX) IT General Controls (if publicly traded). Each of these frameworks has its own audit cycle, evidence requirements, and enforcement consequences. Each may affect the same IT systems and processes but from different regulatory directions and with different documentation standards.

The compliance function in an energy company is not the IT team's adversary it is a critical partner. IT professionals who

understand what compliance requires, why it requires it, and how to structure their operations to satisfy it continuously (rather than scrambling before an audit) will be more effective practitioners and more trusted partners to the compliance, legal, and executive teams they support. Those who treat compliance as an obstacle will find that every IT project, change, or incident eventually becomes a compliance conversation usually at the worst possible time.

This chapter provides an IT practitioner's guide to the major compliance frameworks affecting energy sector IT: what each requires, what IT must produce as evidence, how audits work in practice, and how to build a governance structure that makes compliance a byproduct of good operational practice rather than a separate, costly effort.

7.2 The Regulatory Landscape: A Map for IT Professionals

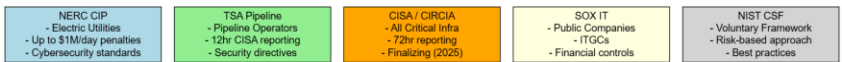


Figure 7.1 Regulatory compliance landscape for energy IT professionals in North America. Most large energy companies are subject to multiple overlapping frameworks simultaneously. CIRCIA (Cyber Incident Reporting for Critical Infrastructure Act of 2022) reporting rules are being developed; verify current requirements with legal counsel. Source: NERC, TSA, CISA, SEC/PCAOB, NIST documentation.

The first important observation from this landscape is that the frameworks overlap sometimes helpfully, sometimes creating conflicting requirements. An energy company that achieves strong compliance with NERC CIP is likely also well-positioned

for SOX ITGC requirements (both require documented change management, access controls, and audit trails) and CISA guidelines (which align closely with NIST CSF principles). Building the compliance program around a core of good IT practice documented processes, reliable evidence collection, and well-designed controls creates value across all frameworks simultaneously.

The second observation is that the IT professional's role in compliance is primarily operational and documentary, not legal or strategic. IT teams do not determine regulatory applicability (that is a legal and compliance function), negotiate with regulators (that is the compliance and executive function), or make risk acceptance decisions (that is management). What IT does is implement the controls, maintain the systems, document the activities, and produce the evidence. Understanding this scope and doing it excellently is what makes IT an effective compliance partner.

7.3 NERC CIP in Practice: What the Audit Looks Like

A NERC CIP audit is one of the most rigorous compliance assessments that an IT team will experience. Unlike a SOX audit, which is conducted by external accounting firms with standardized procedures, a NERC CIP audit is conducted by regional reliability entity (RE) staff with deep technical expertise in energy sector operations. These auditors understand SCADA systems, operational technology, and the IT/OT boundary they are not fooled by superficial compliance theater, and they know what good looks like.

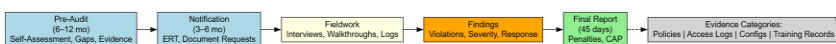


Figure 7.2 The NERC CIP audit process from an IT professional's perspective. The most important phase is Pre-Audit organizations that maintain continuous compliance evidence dramatically outperform those that scramble to reconstruct it after notification. Key IT evidence categories: CIP-007 patch compliance reports, CIP-005 ESP boundary diagrams and access logs, CIP-010 baseline configuration records and change management tickets. Source: NERC compliance monitoring and enforcement documentation; Certrec NERC CIP audit guide.

The Evidence Request Tool (ERT)

NERC's Evidence Request Tool (ERT) is the structured template that entities must populate with compliance evidence when responding to an audit notification. Each requirement in each applicable standard has a corresponding evidence request. For large entities with dozens of applicable standards across hundreds of in-scope systems, populating the ERT is a significant undertaking typically weeks of effort for a compliance team.

For IT professionals, understanding what the ERT will ask for is the key to building operational processes that naturally generate the required evidence. The ERT requests for CIP-007 (patch management), for example, will ask for: the list of BES Cyber Assets in scope; the patches applicable to each system; the dates on which patches were applied; and for any patches not applied within the required window, the exception documentation and compensating controls. If IT's patch management process generates this information as a natural output monthly compliance reports that capture applied patches with dates, a documented exception process that creates tickets with compensating control details the ERT can be populated quickly and accurately. If the information must be reconstructed after the fact, the process is painful and the result is unreliable.

PRACTITIONER TIP: Document Patch Exceptions at the Time They Occur

✓ When a CIP-007 patch cannot be applied within the required window because of a production constraint, vendor dependency, or other legitimate reason create the exception documentation immediately: the specific CVE or patch, the reason it cannot be applied, the compensating control (typically enhanced monitoring or network isolation), the approval from the appropriate authority, and the planned remediation date. Exception documentation created at the time of the exception is credible evidence. Exception documentation created six months later, under audit pressure, is not. Build your patch management workflow to create exception tickets automatically when a patch falls outside the compliance window.

Common NERC CIP Audit Findings and How to Avoid Them

NERC publishes a public database of compliance findings and penalties one of the most valuable resources available for energy sector IT compliance teams. Reviewing recent findings reveals patterns that recur across organizations:

- Incomplete asset inventory (CIP-002): BES Cyber Assets that were added to the environment without being formally assessed and categorized. This finding often results from changes to IT/OT-adjacent systems that were not reviewed through the CIP-002 assessment process. The fix is ensuring that the change management process for any system that might be in or adjacent to the BES includes a CIP-002 assessment step.
- Patch exception documentation gaps (CIP-007): Patches that were not applied within the required window but have no documented exception or compensating control.

As noted above, the fix is building exception documentation into the patch management workflow rather than treating it as a separate compliance activity.

- Access review failures (CIP-004, CIP-005): Quarterly reviews of who has access to BES Cyber Systems that are performed late, incomplete, or not documented. The fix is automating the access review process generating access lists from Active Directory or Entra ID quarterly and documenting the review and any access revocations.
- Configuration baseline discrepancies (CIP-010): Systems whose current configuration does not match the documented baseline, with no change management ticket explaining the difference. The fix is integrating automated configuration baseline comparison into the monthly compliance monitoring process and requiring all deviations to be captured in change management.
- Incident notification delays (CIP-008): Cyber Security Incidents that were not reported to E-ISAC within the required one-hour window. This finding often reflects an IR plan that was not tested with operational leadership, or an IR team that was not aware of the reporting obligation. The fix is covered in Chapter 5: test the IR plan, including the notification timeline.

COMMON MISTAKE: Waiting for the Audit Notification to Start Evidence Collection

The most expensive NERC CIP compliance mistake is treating the audit notification as the starting gun for compliance activity. Evidence that must cover a 12-month period cannot be credibly reconstructed in six weeks. If documentation was not created at the time of the event change tickets were not closed with test results, patch exceptions were not documented at the time of the exception, access reviews were not formally conducted and recorded the evidence either cannot be produced or will

not withstand auditor scrutiny. The NERC audit is a trailing indicator of compliance quality it measures how well you operated over the past year, not how well you can perform in the six weeks before the audit. The organizations that pass audits cleanly are the ones that operate compliantly every month of the year.

7.4 SOX IT General Controls: What Publicly Traded Energy Companies Must Demonstrate

The Sarbanes-Oxley Act of 2002 (SOX) imposes financial reporting controls on publicly traded companies and their external auditors. Section 404 of SOX requires management to assess the effectiveness of internal controls over financial reporting and for IT systems that support financial reporting, this assessment includes IT General Controls (ITGCs).

For IT professionals at publicly traded energy companies, SOX ITGCs are a significant and recurring compliance obligation. External auditors (typically one of the major accounting firms) test ITGCs annually as part of the financial statement audit. IT staff may be asked to produce evidence, participate in walkthroughs, and explain how specific controls work. Understanding what auditors are looking for and building operations to produce the required evidence naturally is a core IT competency at publicly traded energy companies.

Scoping: Which Systems Are in SOX Scope

One of the most important SOX concepts for IT professionals is scope. Not all IT systems are subject to SOX ITGC requirements only systems that directly support financial reporting. The typical in-scope systems for an energy company include: the enterprise ERP system (SAP, Oracle, or similar) that processes financial

transactions; the general ledger and financial consolidation systems; the revenue management systems that record and report energy sales; and the infrastructure (servers, databases, networks) that directly hosts these applications.

Corporate email, endpoint workstations, SCCM infrastructure, and most operational IT systems are typically out of scope for SOX ITGC unless they can materially affect the integrity of financial data. Scoping decisions are made jointly by IT, internal audit, and external auditors. IT professionals should engage actively in this scoping process: both to ensure that legitimately out-of-scope systems are not dragged into unnecessary compliance overhead, and to ensure that in-scope systems receive the compliance attention they require.

PRACTITIONER TIP: Automate Evidence Collection for SOX ITGC Before Audit Season



External auditors typically begin ITGC testing in the third or fourth quarter of the calendar year. By September of each year, IT should be able to produce: access listings for in-scope systems with new access approvals since the last audit; change management tickets for in-scope system changes with approvals and test evidence; backup completion logs for in-scope systems for the full audit period; and privileged access review documentation for the most recent quarterly review. Automating the generation and filing of this evidence scheduled reports from ServiceNow, Active Directory, and backup platforms, saved to a compliance evidence repository means audit season requires assembly rather than reconstruction.

7.5 CISA Guidelines and CIRCIA: The Emerging Reporting Framework

The Cybersecurity and Infrastructure Security Agency (CISA) provides voluntary cybersecurity guidance and mandatory reporting frameworks for critical infrastructure sectors. The Cyber Incident Reporting for Critical Infrastructure Act of 2022 (CIRCIA) established new mandatory cyber incident reporting requirements for critical infrastructure organizations, with implementing regulations currently under development.

CIRCIA, signed into law in 2022, establishes new mandatory cyber incident reporting requirements for critical infrastructure organizations. Covered entities including energy sector organizations will be required to report significant cyber incidents to CISA within 72 hours of identification and ransom payments within 24 hours once implementing regulations are finalized. These requirements will apply more broadly than NERC CIP and will affect all energy companies meeting the covered entity definition.

For IT professionals, CIRCIA reporting requirements have direct operational implications. The 72-hour reporting window means that cyber incident identification, triage, and escalation processes must be fast and well-documented. An organization that discovers a breach after the fact when forensic analysis reveals that the initial compromise occurred weeks earlier has already exceeded the reporting window for the initial compromise. Continuous monitoring, rapid detection, and well-rehearsed escalation processes are not just security practices; under CIRCIA, they are also the precondition for legal compliance.

7.6 The IT Governance Framework: Policies, Standards, and Controls

Underlying all compliance frameworks is the need for a structured IT governance framework: the documented set of policies, standards, procedures, and controls that define how IT operates. Without this framework, compliance is improvised different teams make different decisions, evidence is inconsistent, and auditors find it impossible to assess whether controls are operating effectively. With it, compliance becomes a matter of demonstrating that well-defined, consistently applied processes are working as intended.

Policy Development and Maintenance

IT policies in energy companies must address the operational reality of the sector while meeting regulatory requirements. Core policies that should exist in every large energy company's governance framework include: an Information Security Policy (the foundational statement of the organization's security commitments); an Acceptable Use Policy (governing how corporate systems and resources may be used); a Change Management Policy (defining how changes to IT systems are approved, tested, and documented); a Data Classification Policy (defining categories of data and required protection controls); an Incident Response Policy (defining the organization's commitment to incident detection, response, and reporting); and a Vendor Access Policy (governing how third parties access corporate systems).

Policies must be owned, reviewed annually, and approved by appropriate executive authority. A policy that was last reviewed three years ago, approved by a manager who has since left the organization, and references technology that no longer exists will not withstand auditor scrutiny and more importantly, it will not actually govern the behavior of IT teams who know it is out

of date. Build a policy review calendar and assign ownership for each policy to a named individual who is accountable for keeping it current.

Standards: The Specific Requirements That IT Must Meet

Standards translate policies into specific, measurable requirements that IT teams can implement and auditors can test. Unlike policies (which express intent) and procedures (which explain how to perform a task), standards answer the question: what exactly must be true? Good standards are specific, measurable, and directly testable.

Examples of well-written IT standards for energy environments include: 'All BES Cyber Assets must have applicable security patches applied within 35 calendar days of vendor release, or have a documented exception with compensating controls approved by the CISO' (CIP-007 patch standard); 'User accounts must be reviewed quarterly for each system classified as high-impact BES Cyber System; all unnecessary access must be removed within five business days of review completion' (access review standard); 'All changes to in-scope SOX systems must have an associated change ticket with pre-change testing results, approver sign-off, and post-change validation documentation' (SOX ITGC change management standard).

PRACTITIONER TIP: Use NERC CIP Requirement Language as Your Standards Template



The NERC CIP standards are specific, measurable, and auditor-tested they represent decades of regulatory refinement about what cybersecurity requirements should look like. Rather than inventing standards language from scratch, use the CIP requirements as the template for your standards. Where CIP requires a specific action (e.g., 'apply security patches within 35 calendar days'), make that exact

requirement your standard for BES-adjacent systems. For systems not in CIP scope, you can apply the same rigor at your own discretion. This approach creates standards that satisfy your most demanding regulatory framework and applies equally to all in-scope systems, simplifying compliance across the board.

The Change Management Process as a Compliance Cornerstone

Change management the formal process for approving, testing, implementing, and documenting changes to IT systems is arguably the most compliance-critical IT operational process in an energy company. It is tested by NERC CIP auditors (CIP-010 requires documented change management for BES Cyber Systems), by SOX auditors (ITGC change management requires testing and approval documentation), and implicitly by incident post-mortems (many IT incidents result from undocumented or inadequately tested changes).

An effective change management process for energy IT must address several scenarios that are not encountered in most enterprises: emergency changes at field sites where WAN connectivity may be limited; changes to systems adjacent to the OT environment that require operations coordination; changes during production-sensitive periods where downtime is not acceptable; and changes to CIP-scope systems that require documentation meeting NERC CIP-010 standards.

The ServiceNow or Remedy platform used for change management is not just a ticketing system it is a compliance evidence repository. Every field on a change ticket (approver, test results, implementation notes, post-deployment validation) is potential audit evidence. Design your change management workflow to capture this information comprehensively and

consistently, not as optional fields that users skip when in a hurry.

7.7 Building Compliance Into Operations: The Continuous Compliance Model

The continuous compliance model transforms regulatory compliance from an episodic, disruptive activity into a natural byproduct of well-run IT operations. The key practices that enable this transformation:

- **Automated compliance reporting:** Configure SCCM, Intune, and Active Directory to generate monthly compliance reports automatically patch compliance percentages by system category, access listings for in-scope systems, configuration baseline comparison reports. These reports serve both operational visibility and compliance evidence purposes.
- **Change management discipline:** Every change to a CIP-scope or SOX-scope system must have a complete ticket no exceptions, no verbal approvals, no changes outside the process. Make the change management process easy enough that compliance is the path of least resistance, not an obstacle.
- **Regular access reviews:** Conduct and document quarterly access reviews for in-scope systems. Assign ownership to a named individual for each system, provide them with the current access listing, and require documented confirmation that all access is appropriate. File the results in the compliance evidence repository.
- **Compliance evidence repository:** Maintain a structured repository a SharePoint library, a GRC platform, or a dedicated folder structure in a document management system organized by compliance framework, standard,

and time period. When audit evidence is needed, the question is never 'where is it?' it is 'is it complete?'

- Regular internal compliance reviews: Conduct semi-annual internal compliance reviews not just for external audit preparation but to identify and address gaps proactively. These reviews simulate the external audit process and surface issues while there is still time to remediate them before an official audit.

CASE STUDY | NERC CIP Compliance Program Maturation Composite Scenario

Background

A mid-sized electric utility with approximately 2,000 endpoints and three generation facilities had repeatedly received NERC CIP audit findings for the same issues across consecutive audit cycles: incomplete patch exception documentation, late access reviews, and configuration baseline discrepancies. Each audit cycle triggered an expensive remediation effort and a commitment to do better followed by a return to business as usual until the next audit notification.

Root Cause Analysis

The compliance team's post-audit analysis identified a systemic root cause: the compliance program was episodic rather than continuous. Compliance activities were treated as special projects that occurred before audits, not as ongoing operational practices. IT staff understood their technical responsibilities but did not have workflows that naturally generated compliance evidence. The patch exception process required manual intervention that was frequently skipped in the operational urgency of the moment.

Program Redesign

The utility redesigned its compliance program around the continuous model. Patch compliance reports were automated from SCCM generated monthly, filed automatically to the compliance evidence repository. The patch management workflow was

modified to automatically create exception tickets for any patch outside the 35-day window, with mandatory fields requiring compensating control documentation and CISO approval. Access reviews were scheduled as recurring tasks in ServiceNow with automated access list generation and filing of review results.

Results

At the subsequent NERC CIP audit, the utility had no repeat findings. The patch exception documentation was complete and credible because it had been created at the time of each exception, not reconstructed months later. The access review evidence was consistent across all reviewed periods because the process ran automatically. The auditors noted the improved documentation quality in their final report. The compliance team estimated that the program redesign reduced pre-audit preparation time by approximately 60 percent.

Key Lesson

The controls themselves had not changed between the two audit cycles the utility was implementing the same technical security practices. What changed was the documentation discipline. Good controls with poor documentation fail audits. Good controls with good documentation pass them.

PRACTITIONER PERSPECTIVE | Compliance Director | Large Integrated Energy Company (Anonymous)

"What is the most common mistake you see IT teams make in managing regulatory compliance?"

They treat compliance as a deliverable rather than a discipline. Before an audit, everyone works incredibly hard to produce evidence, answer questions, and demonstrate control. After the audit, compliance activities drop back to near zero until the next notification arrives. The problem is that the audit covers the previous 12 months so the work you do in the six weeks before the audit does not fix the gaps from the ten months before that. The

organizations that consistently pass audits cleanly do not work harder before audits. They work more consistently throughout the year. The monthly patch compliance report that takes five minutes to generate and file in January is worth far more than the three weeks of forensic reconstruction in October. Compliance is a daily discipline, not a quarterly project.

7.8 Governance Structure: Roles, Responsibilities, and Reporting

Effective IT governance in energy companies requires a clear governance structure that defines who is responsible for what, how decisions are made, and how compliance status is reported to leadership. This structure does not need to be elaborate in fact, overly complex governance structures often collapse under their own weight but it must be clearly documented and consistently followed.

The RACI Matrix for Compliance Activities

A RACI matrix (Responsible, Accountable, Consulted, Informed) is a practical tool for defining who owns each compliance activity. For NERC CIP compliance, a typical RACI structure assigns: the CISO as Accountable for the overall compliance program; IT Security as Responsible for implementing controls and collecting evidence; IT Operations as Responsible for executing the specific technical activities (patching, access reviews, configuration management); Legal and Compliance as Consulted on regulatory interpretation; and Executive Leadership as Informed through regular compliance dashboards.

Critically, Accountability and Responsibility must not be the same person. The CISO who is Accountable for the compliance program should not be the same person who is Responsible for

collecting the evidence that creates a conflict of interest and reduces the independence of the compliance oversight function.

Compliance Reporting to Leadership

IT compliance status should be reported to executive leadership and the board on a regular cadence typically quarterly, with ad hoc reporting for significant findings, near-misses, or regulatory developments. The compliance dashboard presented to leadership should be simple, accurate, and action-oriented: a green/amber/red status for each major compliance framework, a brief narrative of any open findings or remediation activities, and a forward-looking section on upcoming audit dates or regulatory changes.

In energy companies subject to NERC CIP, the board or audit committee should receive an annual briefing on CIP compliance status not as a technical deep-dive, but as a risk management discussion. Directors who understand that their organization is subject to up to \$1 million per day per violation for NERC non-compliance are better positioned to ensure that compliance receives adequate resources and executive attention.

- Energy sector IT operates under overlapping compliance frameworks: NERC CIP (electric utilities), TSA Pipeline Security Directives (critical pipeline operators), CISA/CIRCA (all critical infrastructure), and SOX ITGCs (publicly traded companies). Each has distinct requirements, audit processes, and enforcement mechanisms.
- NERC CIP audits are conducted by technically sophisticated regional entity auditors who test controls, review evidence, and interview staff. Common findings incomplete patch exceptions, late access reviews, configuration discrepancies are almost always documentation failures rather than control failures.

- The Evidence Request Tool (ERT) is the structured template that entities must populate with compliance evidence. IT teams that collect evidence continuously as a byproduct of operations can populate the ERT quickly and accurately. Those who reconstruct evidence after notification face weeks of disruptive effort and unreliable results.
- SOX ITGCs require evidence of four control domains: Logical Access Controls, Change Management, Computer Operations, and Backup and Recovery but only for systems that directly support financial reporting. Scoping with internal audit determines which systems are subject to SOX ITGC testing.
- CIRCIA (Cyber Incident Reporting for Critical Infrastructure Act) requires 72-hour incident reporting and 24-hour ransom payment reporting to CISA. These requirements apply broadly to critical infrastructure operators and have direct implications for incident detection and escalation processes.
- The IT governance framework policies, standards, procedures, and controls is the foundation of compliance readiness. Policies express intent; standards specify measurable requirements; procedures explain how to implement them; controls and evidence prove they work.
- The continuous compliance model converts compliance from an episodic pre-audit activity into a natural byproduct of well-run operations: automated monthly reports, disciplined change management, regular access reviews, and a structured evidence repository.

Chapter 7 Checklist: Regulatory Compliance and IT Governance Readiness

☐	Regulatory applicability assessment is complete and documented: NERC CIP, TSA Pipeline, CISA/CIRCI, SOX scope all assessed
☐	NERC CIP BES Cyber Asset inventory is current, categorized (high/medium/low), and reviewed annually per CIP-002
☐	Patch management process generates exception documentation automatically at the time a patch falls outside the compliance window
☐	Access review process runs quarterly for all in-scope systems; results are documented and filed in the compliance evidence repository
☐	Configuration baseline documentation is current for all CIP-scope systems; deviations are captured in change management
☐	CIP-008 incident response plan is current; E-ISAC 1-hour notification procedure is documented and known to response team
☐	CIRCI reporting obligations are assessed; 72-hour incident reporting and 24-hour ransom payment reporting procedures are documented
☐	SOX ITGC scope is formally determined in consultation with internal audit; in-scope systems are identified
☐	SOX ITGC evidence is collected continuously: access listings, change tickets with approvals, backup logs, recovery test documentation

☐	Change management platform (ServiceNow/Remedy) captures all required fields for compliance evidence; no informal changes allowed
☐	Compliance evidence repository is maintained and organized by framework, standard, and time period
☐	IT governance policy library is current: InfoSec policy, AUP, change management policy, data classification, IR policy, vendor access policy
☐	IT standards document specific, measurable requirements derived from applicable frameworks
☐	RACI matrix for compliance activities is defined; Accountability and Responsibility are separated
☐	Quarterly compliance dashboard is produced for executive leadership; annual board briefing on NERC CIP compliance status
☐	Internal compliance reviews are conducted semi-annually to surface gaps before external audits
☐	Audit readiness is assessed annually using a mock audit against applicable standards

References and Further Reading

Regulatory Documentation

NERC. NERC CIP Standards Full Text.

nerc.com/pa/Stand/Pages/CIPStandards.aspx. Continuously updated.

NERC. Compliance Monitoring and Enforcement Program (CMEP). [nerc.com/pa/comp/Pages/default.aspx](https://www.nerc.com/pa/comp/Pages/default.aspx). Continuously updated.

NERC. Public Penalty Postings (published compliance findings). [nerc.com/pa/comp/CE/Pages/Penalties.aspx](https://www.nerc.com/pa/comp/CE/Pages/Penalties.aspx). Continuously updated.

Transportation Security Administration. Pipeline Cybersecurity Initiative and Security Directives. [tsa.gov/pipeline-cybersecurity](https://www.tsa.gov/pipeline-cybersecurity). 2021.

CISA. Cyber Incident Reporting for Critical Infrastructure Act (CIRCIA) overview. [cisa.gov/circia](https://www.cisa.gov/circia). Continuously updated.

SEC / PCAOB. Auditing Standard AS 2201: An Audit of Internal Control Over Financial Reporting. [pcaobus.org](https://www.pcaobus.org). 2007.

Frameworks and Industry Guidance

NIST. Cybersecurity Framework v2.0. [nist.gov/cyberframework](https://www.nist.gov/cyberframework). 2022.

Certrec. NERC CIP Audits Explained. certrec.com/resources/info-guides/nerc-standards-nerc-cip-audits-explained. 2022.

TXOne Networks. Comprehensive Guide to NERC CIP Compliance. txone.com/blog. 2022.

Microsoft. NERC CIP Standards and Cloud Computing Azure Government. learn.microsoft.com/azure/azure-government/documentation-government-overview-nerc. Continuously updated.

Fortinet. NERC CIP Compliance Explained. fortinet.com/resources/cyberglossary/nerc-cip. 2022.

Application Lifecycle Management

From Packaging to Retirement in a Regulated Environment

Every application in your environment is a liability until it is packaged correctly, deployed deliberately, and retired on schedule. The ones nobody touches for years are your biggest risk they are running on infrastructure you no longer understand.

Senior Packaging Engineer, Large Midstream Energy Company

8.1 Application Management in the Energy Context

A large energy company might run anywhere from 300 to 1,500 distinct applications enterprise resource planning systems, geographic information systems, field inspection tools, engineering software, SCADA historians, safety management platforms, document management systems, and dozens of specialized tools developed by vendors who may no longer be in business. Each of these applications must be installed on the right devices, in the right version, with the right configuration, and removed cleanly when no longer needed. This is the domain of application lifecycle management.

In energy environments, application lifecycle management carries operational stakes that go beyond the typical enterprise IT context. A field inspection application that deploys incorrectly to a technician's tablet may result in missed maintenance activities at a compressor station. A legacy engineering tool running on an end-of-life platform may introduce unpatched vulnerabilities into workstations that are adjacent to operational technology. A software update that breaks a production scheduling tool may disrupt operations at a processing plant. Managing applications effectively in this context requires more than packaging skill it requires understanding the operational importance of each application and managing the full lifecycle accordingly.

This chapter covers the complete application lifecycle management process for energy companies: the seven-stage lifecycle from request to retirement, application portfolio management, packaging standards and tools, UAT and QA processes, the application catalog and self-service delivery model, application virtualization options, and the governance practices that keep a large application portfolio manageable and secure.

8.2 The Seven-Stage Application Lifecycle



Figure 8.1 The enterprise application lifecycle for energy companies. Each stage has defined ownership, activities, and service level agreements. The rework loop between Test and Package reflects the iterative nature of quality packaging issues found in testing return to the packaging team rather than proceeding to production. Energy-specific note: Production deployment at field sites requires explicit operations notification and maintenance window coordination.

Stage 1: Request and Intake

Every application entering the enterprise environment should enter through a formal intake process not through a user downloading and installing software independently, not through a vendor dropping an executable on a server, and not through an IT staff member deploying something that looked useful. The intake process serves multiple functions: it creates a record of why an application exists in the environment, establishes ownership, initiates security review, and ensures that licensing is understood and managed from the start.

The intake ticket created in ServiceNow, Remedy, or equivalent should capture: the application name and version, the business justification, the name of the business application owner (the person responsible for approving the application's continued presence in the environment), the number of users or devices requiring the application, the licensing model and cost, and the deployment urgency. This information becomes the foundation of the application's record throughout its lifecycle.

Security review at the intake stage is not an afterthought it is a gate. Before any application enters the packaging workflow, it should be assessed for security risk: is the vendor reputable? Does the application require elevated privileges? Does it communicate over the network? Does it handle sensitive data? Applications that fail this review should not proceed further without explicit risk acceptance by appropriate authority.

PRACTITIONER TIP: Require a Named Application Owner for Every Application



One of the most common and consequential application governance failures is the 'orphaned application' an application that has been running in the environment for years but has no clear owner. No one knows who approved it, why it is still needed, or whether it is being used. When the time comes to update it, or when it triggers a security vulnerability,

there is no one to call. Require a named, current business owner for every application at intake, review the owner list quarterly, and send annual reminders to owners asking them to confirm that their application is still needed. Applications whose owners cannot be confirmed after a defined grace period should be decommissioned.

Stage 2: Assess and Plan

Assessment converts the intake request into a packaging plan. The assessment team evaluates: what the application does and what it requires (runtime prerequisites, network access, registry permissions); whether a vendor-supplied silent install command is available; whether the application has known conflicts with other software in the environment; which Windows OS versions and hardware configurations must be supported; and what the deployment scope is (number of devices, site types, bandwidth constraints).

For applications destined for field sites with limited bandwidth, the assessment stage must explicitly identify the package size and evaluate whether the deployment approach (Push DP, Pull DP, CMG-based delivery) is appropriate for the connectivity profile of the target sites. A 2 GB installation package that works fine on a corporate LAN may be completely impractical for a satellite-connected field site, and the assessment stage is where this incompatibility is identified and addressed not after the package is built and the deployment fails.

Stages 3–5: Package, Test, and Pilot

These three stages are covered in detail in Chapter 2 (Endpoint Management at Scale) from a technical perspective. From a lifecycle management perspective, the critical discipline is the formal handoff between stages: a package does not move from Packaging to Test without a packaging quality review; it does not

move from Test to Pilot without a written UAT sign-off from the application owner; and it does not move from Pilot to Production without a documented pilot results report and an explicit go/no-go decision.

These formal handoffs prevent the most common application deployment quality problem: rushing a package from build to production because a user is waiting for it, skipping the UAT step that would have revealed a critical issue. In energy environments where deployment quality directly affects operational capability, the formal gate at each stage is not bureaucracy it is risk management.

Stage 6: Production Deployment

Production deployment in energy environments requires coordination that most enterprise IT contexts do not. Before deploying any application to field site workstations, the relevant operations supervisor should be notified with sufficient lead time for them to assess whether the deployment timing conflicts with any planned or unplanned operational activities. This notification is not a formality; it is the mechanism by which IT respects the production-first culture described in Chapter 1.

Production deployments should be staged geographically: corporate sites first, regional offices second, field sites last. This staging allows the help desk to see the full volume of deployment issues at corporate where support is readily available before those issues reach field sites where support is remote and difficult. Any deployment that generates an unusual volume of help desk tickets at the corporate stage should be paused and investigated before proceeding to field sites.

Stage 7: Retirement

Application retirement is the most neglected stage of the lifecycle in most organizations. Applications that are no longer needed, no longer supported by their vendor, or superseded by newer solutions remain in production environments indefinitely

consuming license costs, consuming management overhead, and, most importantly, accumulating unpatched security vulnerabilities.

A disciplined retirement process begins with the annual application portfolio review (covered in Section 8.3). When an application is flagged for retirement, the retirement process includes: notifying users and business owners with adequate lead time; providing a migration path to a replacement application if one exists; deploying an uninstall package to all devices where the application is installed; removing the application from the software catalog; and releasing any associated licenses. The retirement should be documented in the change management system and confirmed with a post-retirement audit that the application no longer appears in device inventory.

COMMON MISTAKE: Never Formally Retiring Applications

! The accumulation of unretired applications is one of the most common and costly application portfolio problems in large energy companies. Each unretired application represents a potential security vulnerability (if it is end-of-life and receiving no patches), a license cost (if the license is still being renewed for users who are no longer using it), and a management burden (when the next OS migration or endpoint refresh requires compatibility testing for an application that nobody uses). A simple annual application review process asking application owners to confirm that their applications are still needed and a disciplined retirement workflow for those that are not would save most large energy IT organizations significant cost and risk exposure every year.

8.3 Application Portfolio Management



Figure 8.2 Application portfolio management framework for energy companies. The portfolio quadrant maps applications by business criticality and lifecycle age to define investment strategy: Invest/Grow (high criticality, new), Maintain/Optimize (high criticality, mature), Migrate/Replace (high criticality, legacy highest priority action), Monitor (low criticality, new), Tolerate (low criticality, mature), Retire (low criticality, legacy). Annual portfolio review should categorize all applications in this framework and drive action plans for each quadrant.

Conducting the Annual Application Portfolio Review

The annual application portfolio review is the governance mechanism that prevents application sprawl, identifies security risks from end-of-life software, and drives the investment decisions that keep the application environment manageable. A well-structured review process addresses:

- **Inventory completeness:** Is the application inventory current? SCCM and Intune device inventory data should be the authoritative source applications discovered in the inventory that are not in the application catalog represent governance gaps that need to be investigated.
- **Owner confirmation:** For each application in the portfolio, is there a named, current owner who can confirm the application is still needed? Applications whose owners have left the organization or who cannot confirm continued need are candidates for decommissioning review.
- **Vendor support status:** For each application, is the vendor currently providing security patches? End-of-life applications those for which the vendor no longer

provides patches represent open-ended security risk that must be quantified and either mitigated (through compensating controls) or eliminated (through replacement).

- License utilization: For each licensed application, is the number of installed instances consistent with the number of purchased licenses? Both over-licensing (paying for licenses that are not being used) and under-licensing (using more licenses than purchased) are common and costly in large application portfolios.
- Compatibility with current environment: Does the application remain compatible with current Windows versions, endpoint hardware, and security configurations? Applications that require legacy settings (e.g., disabling UAC, requiring Internet Explorer, needing specific .NET framework versions) represent technical debt that creates management and security challenges.

PRACTITIONER TIP: Use SCCM/Intune Inventory Data as Your Portfolio Audit Starting Point

✓ Rather than maintaining a manually curated application list, generate your annual portfolio audit from the software inventory data in SCCM or Intune. This data shows every application installed on managed devices including applications that were never formally approved or packaged, installed by users from the internet or portable media. The gap between what the inventory shows and what is in the approved catalog reveals both your unauthorized software exposure and your orphaned application population. In energy environments where unauthorized software on operational workstations represents both a security risk and potentially a NERC CIP compliance issue, this inventory-first approach to portfolio management has direct operational value.

8.4 UAT and QA: The Quality Gate That Protects Production



Figure 8.3 The UAT and QA process for energy company application deployments. Three distinct environments ensure that applications are validated progressively before reaching production. The UAT environment must simulate field site bandwidth constraints a package that deploys successfully over LAN may fail at a 512 kbps field site without this simulation. UAT sign-off from the application owner is a mandatory gate before production deployment. Owner: Packaging Team (Dev lab); App Owner + QA Team (UAT); IT Operations (Production).

Writing Effective UAT Test Plans

A UAT test plan defines what must be tested before an application can be approved for production deployment. An effective test plan for an energy company application deployment includes: installation success confirmation on each supported hardware and OS configuration; application functionality testing against the specific workflows used by the target user population; uninstall verification (confirming the application removes cleanly without leaving residual files or registry entries); integration testing with other applications that the target population uses (particularly SAP, Microsoft 365, and any GIS or engineering tools); and a simulated field site deployment test that validates installation over a bandwidth-throttled connection.

The UAT sign-off is a formal document not an email, not a verbal confirmation signed by the named application owner confirming that the application functions as required in the UAT environment. This document becomes part of the change

management record and the compliance evidence repository. If a deployment later causes issues in production, the UAT sign-off establishes that the application owner accepted responsibility for the application's readiness.

QA Standards for Packaged Applications

Packaging quality assurance ensures that a package meets the organization's technical standards before it enters the UAT process. A QA checklist for enterprise application packages in an energy environment should verify: the package installs silently without user interaction; the package installs correctly on all supported hardware and OS configurations; the installation directory follows the organization's standard (typically Program Files rather than a user-specific directory); the package does not write to locations that require elevated privileges at runtime; the uninstall removes cleanly with no residual files or registry entries; shortcuts are created in approved locations; the detection method in SCCM/Intune accurately identifies whether the application is installed; and the package metadata (publisher, version, description) is accurate and consistent with the application catalog entry.

8.5 The Application Catalog and Self-Service Delivery



Figure 8.4 Application catalog structure and self-service delivery flow for energy companies. The catalog is the authoritative source of approved, packaged, deployable applications. Self-service delivery via the Company

Portal or Software Center reduces help desk ticket volume by removing manual install requests. Only catalog applications may be installed. AppLocker policy blocks unauthorized software execution. Non-catalog requests route through an approval and packaging workflow before becoming available for self-service.

Building and Maintaining the Application Catalog

The application catalog is the authoritative list of applications that are approved for use, packaged for deployment, and available through the self-service portal or automatic deployment. It is the application equivalent of the software bill of materials—a complete, current, maintained record of every application that should be in the environment.

An effective application catalog entry includes: application name and version; vendor name and support status; business category (productivity, engineering, field operations, security, etc.); deployment type (required, role-based, self-service, restricted); SCCM/Intune deployment collection or assignment group; named application owner; license count and type; last review date; and the known-good package location in the content library. Some organizations also include installation notes, known issues, and links to the application vendor's support resources.

Maintaining the catalog requires a formal update process for each lifecycle event: when a new application is added (after completing the intake and packaging process), when an existing application is updated to a new version, when an application is retired, and when ownership changes. The catalog should be reviewed annually for completeness and accuracy, with any discrepancies between the catalog and the actual device inventory investigated and resolved.

Self-Service Application Delivery

Self-service application delivery allowing users to install approved applications from the Company Portal or Software Center without submitting a help desk ticket is one of the highest-value improvements that an organized application portfolio enables. It reduces help desk ticket volume, improves user experience, and ensures that only approved, packaged software is installed.

The precondition for self-service delivery is an organized, maintained catalog: users can only self-serve applications that have been through the full lifecycle process. An organization that tries to enable self-service before its application catalog is organized will find that users request applications that are not packaged, create support burdens from incompatible software, and defeat the governance purpose of the catalog. Get the catalog right first; then enable self-service.

PRACTITIONER TIP: Start Self-Service with Your 20 Most-Requested Applications



When rolling out self-service delivery, start with the 20 applications that generate the most help desk install requests. Package these to the highest standard, test them thoroughly across all supported configurations, and make them available via the Company Portal. Monitor the help desk ticket volume for install requests after the rollout a well-implemented self-service catalog for the top 20 applications typically reduces install-related help desk tickets by 40–60 percent. Use this metric to build the business case for expanding the self-service catalog and investing in the packaging capacity to grow it.

8.6 Application Virtualization: App-V, MSIX, and When to Use Each

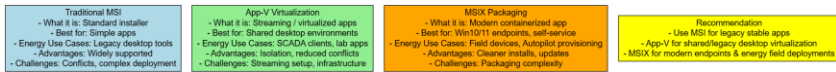


Figure 8.5 Application packaging format comparison for energy IT environments. Traditional MSI/EXE remains the standard for most enterprise applications. App-V virtualization addresses conflict-prone legacy applications by isolating them in virtual containers. MSIX is the preferred format for new Intune-deployed applications and is natively supported on Windows 10/11. The energy recommendation: use MSI/MSIX for most applications, App-V only for confirmed conflict scenarios. Source: Microsoft App-V and MSIX documentation; industry packaging practice.

App-V in Energy Environments

Microsoft Application Virtualization (App-V) packages applications in isolated virtual containers that run on top of the Windows OS without modifying it. The application appears to the user as a normally installed application, but its files, registry entries, and runtime environment are isolated from the base OS and from other applications. This isolation is the primary value of App-V: applications that would otherwise conflict with each other can coexist on the same device because each runs in its own virtual environment.

In energy environments, App-V is particularly useful for organizations that must support multiple versions of the same application (different users requiring different versions of engineering software), applications with known conflicts with enterprise tools (older field reporting software that conflicts with SAP), and legacy applications that require specific runtime

environments (older Java versions, specific .NET versions) that would conflict with the organization's standard baseline.

App-V requires an App-V Server infrastructure (or SCCM App-V integration) to manage sequencing and streaming of App-V packages. Organizations moving toward Intune-only management should note that App-V support in Intune is limited compared to SCCM. MSIX is the preferred virtualization-adjacent format for cloud-managed environments.

MSIX: The Modern Packaging Standard

MSIX is Microsoft's modern application packaging format, designed for clean installation and removal, automatic update handling, and native Intune deployment. Unlike traditional MSI installations, MSIX packages install to a protected, isolated location and are completely removed by the OS on uninstall leaving no residual files, registry entries, or application data behind.

For energy companies building a modern endpoint management practice, MSIX is the preferred packaging format for new applications and for repackaging existing applications as part of lifecycle refresh or OS migration projects. The Intune Win32 app deployment model supports MSIX natively, making MSIX packages directly deployable through the cloud management channel without SCCM infrastructure.

The investment in converting legacy MSI packages to MSIX is not always justified. Well-functioning MSI packages that install and uninstall cleanly do not need to be converted simply for format consistency. Focus MSIX conversion efforts on applications that are known to leave residual mess on uninstall, applications that are being refreshed as part of an OS migration project, and new applications entering the environment that do not have vendor-supplied MSI packages.

8.7 The Application Owner Relationship

One of the most important and most underappreciated aspects of application lifecycle management is the relationship between the IT packaging and deployment team and the business application owners. Application owners are the business stakeholders who depend on the applications that IT manages the engineering manager who needs the GIS tool, the field operations supervisor who depends on the work order system, the finance team that runs monthly close processes on SAP.

These relationships require ongoing cultivation, not just transactional interaction at deployment or upgrade time. Application owners who trust the IT team to understand their business requirements will engage proactively when they learn of upcoming vendor updates, will provide timely UAT sign-offs, and will support IT's change management requirements because they understand the value. Application owners who view IT as an obstacle will work around the packaging process, install software informally, and resist changes that affect their applications.

Communicating Upcoming Changes

Application owners should be notified of planned upgrades to their applications with sufficient lead time to plan their testing and communicate to their users. For major version upgrades that change the user interface or workflow, four to six weeks of notice is typically appropriate. For security patches that change only the security posture of the application without affecting functionality, one to two weeks is usually sufficient.

The notification should include: what is changing, why it is changing, the planned deployment date, what the owner needs to do (review and approve, participate in UAT, notify their users), and who to contact with questions. A brief, clear email template maintained as part of the packaging team's standard operating procedures makes this communication consistent and professional.

Managing Application Vendor Relationships

For enterprise applications particularly those from major vendors like SAP, IBM, or specialized energy software providers the IT team serves as the liaison between the vendor and the business application owner. This liaison role involves: ensuring that vendor update notifications are received, assessed, and routed to appropriate internal stakeholders; tracking vendor end-of-life announcements and communicating them to application owners with enough lead time to plan replacements; managing vendor support contracts and escalating issues through the vendor's support channels; and participating in vendor user groups or advisory boards where applicable to stay informed about product roadmaps.

CASE STUDY | Application Portfolio Rationalization at a Large Utility Composite Scenario

Background

A large electric utility with approximately 850 applications in its production environment undertook a portfolio rationalization initiative following a Windows 10 migration that revealed significant application debt: dozens of applications running on end-of-life runtimes, multiple applications performing overlapping functions, and an unknown number of applications with no identifiable business owner.

Discovery Phase

The team generated an authoritative inventory from SCCM software inventory data and cross-referenced it against the application catalog. The gap was striking: 312 applications in the SCCM inventory had no corresponding catalog entry, meaning they had been installed at some point without formal intake or packaging. Of the 850 total applications, 89 were identified as running on end-of-life vendor software with no patches available.

Rationalization Approach

Applications were classified into four categories: retire (no current owner, no confirmed business need 156 applications); consolidate (overlapping functionality that could be reduced to a single tool 43 applications across 12 functional groups); remediate (end-of-life or unpackaged applications requiring immediate action 89 applications); and retain (confirmed need, current vendor support, formal catalog entry 562 applications). Retirement was executed in three waves over six months, with each wave requiring owner notification, a 30-day grace period, and a confirmed uninstall deployment.

Outcome

The rationalization reduced the active application portfolio by approximately 200 applications, eliminated 89 end-of-life security risks, and identified \$240,000 in annual license savings from applications that were being licensed but not used. The packaging team's monthly workload for updates and compatibility testing was reduced by approximately 25 percent. The most valuable outcome was the establishment of governance disciplines that prevented re-accumulation of application debt over the following 18 months.

Key Lesson

The initial investment in inventory-to-catalog reconciliation which took approximately six weeks of dedicated effort was the most valuable activity in the entire rationalization initiative. Organizations that do not know what is in their environment cannot make informed decisions about what to keep, what to replace, and what to retire. The SCCM software inventory is the single best source of truth for this analysis, and the gap between inventory and catalog is the clearest indicator of application governance health.

PRACTITIONER PERSPECTIVE | Application Packaging Lead |
Large Electric Utility (Anonymous)

"What do most IT teams get wrong about application lifecycle management?"

They treat ALM as a technical problem and try to solve it with better tools. In my experience, the tools are never the limiting factor. AdminStudio is excellent. SCCM works well. Intune is improving every year. What breaks ALM programs is the governance the absence of a defined intake process, the lack of named application owners, the absence of a retirement process, the informality of UAT. I have seen organizations spend significant money on ALM tooling and still have 400 unmanaged applications in their environment two years later because the governance disciplines were never established. Build the process first. The tools will serve a process that exists. They cannot create a process that does not.

8.8 Knowledge Base Articles and Documentation

Application lifecycle management generates a significant amount of institutional knowledge: why a specific application requires a particular installation sequence, what workaround resolves a known conflict with another enterprise tool, which deployment collection should be used for a specific site type, and what the rollback procedure is if a deployment fails. This knowledge, if not captured, walks out the door when experienced packaging engineers leave the organization.

Knowledge Base (KB) articles are the primary mechanism for capturing and sharing application-specific knowledge. A good KB article for a packaged application should include: the application name, vendor, and version; the packaging approach and any non-standard configurations; known issues and their resolutions; deployment collection or Intune assignment group; the UAT sign-off record; any operational notes relevant to field site deployment; and the date of last review. KB articles should be maintained in a searchable repository ServiceNow, SharePoint, or a dedicated knowledge management platform

and updated whenever the application is updated or a new issue is discovered.

The investment in KB article creation is modest compared to the return: a new packaging team member who can find a KB article about a known application conflict saves hours of troubleshooting; a help desk technician who can find a KB article about a common installation error resolves the issue in minutes rather than escalating. In energy environments where field IT staff may be the only technical resource at a remote location, accessible KB articles are the difference between a resolved issue and an unresolved one.

Chapter Summary

- Application lifecycle management in energy environments requires a formal seven-stage process: Request/Intake, Assess/Plan, Package/Build, Test/Validate, Pilot Deploy, Production Deploy, and Retire. Each stage has defined ownership, activities, and formal handoffs.
- The annual application portfolio review is the governance mechanism that prevents sprawl, identifies end-of-life security risks, and drives retirement of applications that are no longer needed. Portfolio quadrant analysis by criticality and lifecycle age drives investment decisions.
- UAT and QA processes provide the formal quality gates that prevent poorly packaged or incompatible applications from reaching production. Written UAT sign-off from the application owner is mandatory before production deployment.
- The application catalog is the authoritative source of approved, packaged applications. Self-service delivery via the Company Portal or Software Center reduces help desk volume and ensures only approved software is

installed but requires an organized catalog as a precondition.

- Traditional MSI remains the standard for most enterprise applications. App-V addresses conflict-prone legacy applications. MSIX is the preferred format for new Intune deployments and Windows 11 standardization.
- Application owner relationships require active cultivation, not just transactional interaction at deployment time. Owners who trust the IT team engage proactively, provide timely sign-offs, and support change management requirements.
- Knowledge Base articles capture the institutional knowledge generated by the packaging and deployment process and make it accessible to the team, help desk, and field IT staff who need it.

Chapter 8 Checklist: Application Lifecycle Management Readiness

☐	Formal application intake process is documented; every new application requires a ServiceNow ticket with business owner, justification, and security review
☐	Every application in the environment has a named, current business owner who has confirmed continued need within the last 12 months
☐	Application catalog is current and reconciled against SCCM/Intune software inventory; gaps are investigated and resolved
☐	Packaging lab environment is maintained with a clean baseline VM and all required monitoring tools (ProcMon, Orca, AdminStudio)

☐	UAT environment simulates production hardware profiles and includes bandwidth throttling to replicate field site connectivity
☐	Written UAT sign-off from the application owner is required before any production deployment
☐	QA checklist is defined for packaged applications covering silent install, uninstall, detection method, and metadata accuracy
☐	Production deployment to field sites requires explicit operations notification with minimum 48-hour advance notice
☐	Self-service catalog is available via Company Portal/Software Center for all Category 3 (self-service) applications
☐	AppLocker or WDAC policy prevents installation of applications not in the approved catalog
☐	Annual application portfolio review is scheduled and produces a rationalization action plan for each quadrant
☐	End-of-life application inventory is maintained; remediation or replacement plans exist for all EOL applications
☐	License utilization is reviewed annually; over-licensed and under-licensed applications are corrected
☐	Retirement process is documented and includes user notification, migration path, uninstall deployment, and catalog removal
☐	KB articles exist for all major enterprise applications; last-reviewed dates are current
☐	Application owner communication template is documented for major upgrades and security patches

References and Further Reading

Application Packaging and Lifecycle

Flexera. AdminStudio Product Documentation.

flexera.com/products/adminstudio. Continuously updated.

Juriba. 7 Steps to Mastering the Application Packaging and Testing Process. blog.juriba.com, 2022.

Microsoft. MSIX Overview. learn.microsoft.com/windows/msix. Continuously updated.

Microsoft. App-V Overview. learn.microsoft.com/windows/application-management/app-v. Continuously updated.

Microsoft. Deploy Applications with Configuration Manager. learn.microsoft.com/configmgr/apps. Continuously updated.

Portfolio and Governance

Visure Solutions. Best Practices for Application Lifecycle Management. visuresolutions.com/alm-guide/best-practices. May 2021.

Ardoq. What Is Application Lifecycle Management? ardoq.com/knowledge-hub/application-lifecycle-management. 2022.

Salesforce. Application Lifecycle Management (ALM) Guide. salesforce.com/platform/enterprise-app-development. 2022.

Office 365 and Collaboration Tools in Energy

Enabling Productivity Without Creating Risk

Microsoft 365 changed how energy companies communicate overnight and most of them are still figuring out the governance implications. The technology deployed itself faster than the policies could keep up.

IT Director, Large Upstream Energy Company

9.1 M365 in the Energy Sector: Opportunity and Obligation

Microsoft 365 has become the productivity backbone of the energy industry. Email, calendar, collaboration, document management, and communication all flow through the M365 platform in most large energy companies a shift that happened gradually over a decade and then accelerated dramatically during and after the pandemic years. For IT professionals managing these environments, M365 is simultaneously one of the most valuable tools in the enterprise and one of the most complex governance challenges.

The complexity is not technical. The M365 platform is mature, well-documented, and supported by a vast ecosystem of administrators and resources. The complexity is contextual: energy companies operate in a regulatory environment where the data flowing through Teams channels, SharePoint libraries, and Exchange mailboxes may be subject to NERC CIP-011 (BES Cyber System Information protection), SOX records retention requirements, legal hold obligations, or simply the operational sensitivity of pipeline routing data, production forecasts, and incident reports that competitors and nation-state actors would find highly valuable.

This chapter covers the IT practitioner's guide to deploying and governing M365 in energy environments: tenant architecture, Exchange Online, Teams governance, SharePoint and OneDrive data protection, upgrade management, and the specific adaptations required for field worker collaboration. It is written from the perspective of an IT professional responsible for ensuring that M365 enables the business while meeting the compliance and security obligations of an energy sector organization.

9.2 M365 Tenant Architecture and Governance Foundation

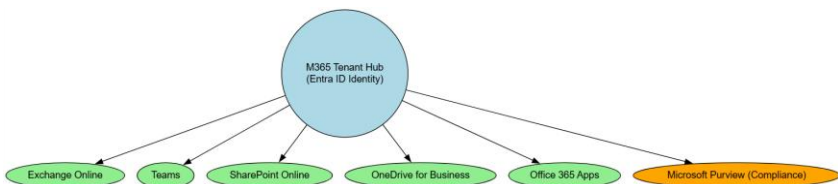


Figure 9.1 Microsoft 365 service architecture for an energy company. All services share the same Entra ID tenant identity, meaning governance policies and security controls applied at the tenant level affect all services

simultaneously. Microsoft Purview (formerly Microsoft Compliance Center) provides the cross-service compliance layer: sensitivity labels, DLP policies, retention policies, and eDiscovery apply across Exchange, Teams, SharePoint, and OneDrive from a single configuration point.

Single-Tenant vs. Multi-Tenant Architecture

Most large energy companies operate a single M365 tenant one organization with one Entra ID directory and one set of policies governing all users and services. This is the appropriate architecture for most energy companies: it simplifies administration, enables seamless collaboration across business units, and allows consistent governance policy application.

Multi-tenant architectures where different business units or subsidiaries have separate M365 tenants are occasionally encountered in energy companies that have grown through acquisition and have not yet consolidated their collaboration infrastructure. Multi-tenant environments are significantly more complex to govern and secure: users in different tenants cannot seamlessly collaborate, compliance policies cannot be applied consistently across tenants, and the identity and access management overhead multiplies. Energy companies with multi-tenant M365 environments should evaluate tenant consolidation as a strategic priority, accepting that the migration cost is likely to be recovered in operational efficiency and reduced governance complexity within a few years.

Administrative Roles and Least Privilege in M365

M365 administration should follow the same tiered access principles described in Chapter 4 for Active Directory. Global Administrator the most powerful role in M365, with the ability to modify any setting and access any data should be assigned to no more than two to four dedicated accounts that are never used for day-to-day work. All regular administration should use scoped roles: Exchange Administrator for mail, Teams

Administrator for Teams, SharePoint Administrator for SharePoint, and so on.

Privileged Identity Management (PIM), covered in Chapter 6, should govern all Global Administrator access: administrators should activate the Global Admin role only when needed, for a defined time period, with approval from a second administrator for the most sensitive operations. The audit trail generated by PIM provides the documentation needed for SOX ITGC access control evidence: every use of Global Administrator is logged with timestamp, justification, and approver.

PRACTITIONER TIP: Create Emergency Access Accounts and Protect Them Carefully



Every M365 tenant should have two emergency access accounts (sometimes called break-glass accounts) that are excluded from Conditional Access policies and MFA requirements, so they can always be used to access the tenant even if normal authentication methods fail. These accounts should be cloud-only (not synchronized from on-premises AD), should use passwords of maximum length and complexity stored in a physical safe, and their use should trigger immediate alerts. They exist for genuine emergencies situations where all normal admin accounts are locked out and should be tested at least once a year to confirm they work. Do not use them for routine administration under any circumstances.

9.3 Exchange Online: Email in the Energy Enterprise

Exchange Online is the most business-critical M365 service for most energy companies email is the primary communication and document distribution channel for operational activities,

compliance filings, vendor communications, and executive decision-making. Disruptions to Exchange Online affect the entire enterprise, and misconfigurations can expose sensitive communications or create compliance gaps.

Mail Flow and Security Configuration

Exchange Online's mail flow configuration determines how email enters and leaves the organization. Key security configurations for energy companies include:

- Spam and phishing protection: Microsoft Defender for Office 365 (included in M365 E3 and above) provides multi-layer protection against phishing, malware, and spam. Anti-phishing policies should be configured with impersonation protection enabled for executive names and the organization's domain a critical control given that spear-phishing targeting energy company executives is a documented initial access vector for nation-state actors.
- Safe Attachments and Safe Links: Defender for Office 365's Safe Attachments policy detonates email attachments in a sandbox before delivery, blocking malware that bypasses signature-based detection. Safe Links rewrites URLs in emails and scans them at click time, protecting against links that were safe at delivery but were later weaponized. Both should be enabled for all users.
- Domain authentication (SPF, DKIM, DMARC): Properly configured SPF (Sender Policy Framework), DKIM (DomainKeys Identified Mail), and DMARC (Domain-based Message Authentication, Reporting, and Conformance) records prevent email spoofing of the organization's domain. DMARC in enforcement mode (p=reject or p=quarantine) prevents attackers from sending emails that appear to come from the

organization's domain a significant brand and security protection.

- External email warning banners: Configure mail flow rules that add a visible banner to emails from external senders a simple, effective user awareness control that reduces the likelihood of users being deceived by spoofed emails that appear internal.

Retention Policies and Legal Hold

Email retention in energy companies is not purely an IT decision it is a legal and compliance obligation. Exchange Online retention policies should be designed in consultation with Legal and Compliance to ensure that emails are retained for the required periods for each category of business communication: regulatory filings (specific retention periods per regulation), financial communications (SOX-relevant records), operational communications (company policy), and general business email (minimum retention periods).

Legal Hold (also called Litigation Hold) allows IT to preserve all mailbox content for specific users indefinitely, regardless of deletion activity, when legal proceedings are anticipated or in progress. In energy companies, Legal Hold situations arise from regulatory investigations, litigation, contract disputes, and incident investigations. IT must be able to execute Legal Hold quickly and reliably when instructed by Legal a capability that should be tested and documented before it is needed, not discovered under pressure during an actual legal proceeding.



COMMON MISTAKE: Setting a Single Retention Policy for All Email

A single organization-wide retention policy that deletes all email after X years will eventually destroy records that should have been preserved for regulatory or legal purposes. Energy

companies are subject to retention requirements from multiple frameworks SOX (7 years for financial records), NERC CIP (audit evidence for the period covered by the audit cycle), and various state and federal regulatory requirements. Configure tiered retention policies: a default policy for general email, longer retention for users in roles likely to handle regulatory content, and indefinite retention for executives and designated compliance roles. Work with Legal to define the retention schedule before configuring it in Exchange.

9.4 Teams Governance: Structure and Control

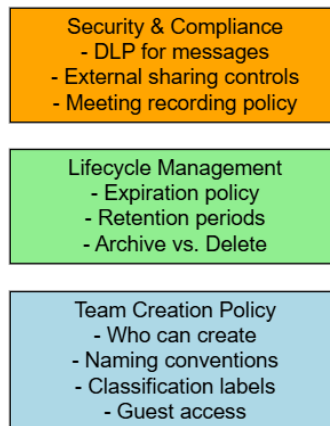


Figure 9.2 Microsoft Teams governance framework for energy companies. Effective Teams governance requires policies across three dimensions: creation control (who can create teams and with what naming/classification), lifecycle management (expiration, retention, and archiving), and security/compliance (DLP, external sharing, recording policy). Uncontrolled Teams sprawl creates compliance risks (unretained regulatory messages), security risks (sensitive data in unclassified teams), and management overhead. Source: Microsoft Teams admin documentation; Microsoft Purview compliance guidance.

Team Creation and Naming Governance

By default, any M365 user can create a Microsoft 365 Group (which creates a Team). In energy environments, this default creates rapid sprawl dozens or hundreds of teams created for informal purposes, with inconsistent naming, no classification, and no owner accountability. Within months of a Teams deployment, it is common to find teams with names like 'Test', 'John's Team', and 'Temp Project 2021' that no one can identify, whose owners may have left the company, and whose content may include sensitive operational information.

Restricting team creation to a security group IT staff plus approved business unit team champions is the most effective control for preventing uncontrolled sprawl. The process for requesting a new team should be simple (a ServiceNow request with team purpose, classification, and owner designation) but formal. This small friction eliminates the majority of spurious team creation while not impeding legitimate collaboration.

A naming policy enforced through Entra ID M365 Group settings requiring teams to follow the pattern [Department]-[Function]-[Name] makes the team inventory browsable and understandable. Sensitivity labels required at team creation classify the team's data handling requirements before any content is added.

Lifecycle Management: Expiration and Retention

Teams expiration policies address the other half of the sprawl problem: teams that were created for legitimate purposes but are no longer active. An expiration policy automatically notifies team owners when their team has been inactive for a defined period (typically 12 months) and asks them to renew it or allow it to be archived or deleted. Teams without active owners that are not renewed are archived preserved for reference but no longer active and eventually deleted after a defined retention period.

Retention policies for Teams messages must align with the organization's legal and regulatory retention requirements. Unlike email, where users are accustomed to retention policies, Teams users often do not realize that their channel messages and chats are subject to retention and potential legal hold. Communicating this clearly during Teams onboarding that Teams messages are corporate communications subject to the same retention and eDiscovery obligations as email sets appropriate expectations and reduces the likelihood of users treating Teams as an unmonitored back channel.

9.5 SharePoint and OneDrive: Document Management and Data Protection

Known Folder Move: Protecting User Files Automatically

Known Folder Move (KFM) is an Intune and OneDrive configuration that automatically redirects users' Desktop, Documents, and Pictures folders to OneDrive for Business. Once configured, every file a user saves to their Desktop or Documents folder is automatically synchronized to the cloud providing backup protection without any user action required.

For energy companies, KFM provides two significant operational benefits: it protects user files from device loss or failure (a field technician whose laptop is damaged at a remote site does not lose their work), and it enables device replacement without data migration (the replacement device simply reconnects to OneDrive and the user's files are immediately available). KFM is one of the highest-value, lowest-effort M365 configurations available, and it should be part of every energy company's Intune configuration profile for managed Windows devices.

PRACTITIONER TIP: Use Sensitivity Labels with Auto-Labeling for BCSI and Confidential Content

✓ Requiring users to manually apply sensitivity labels is unreliable: users are busy, classification is not their primary concern, and the consequence of mislabeling is a compliance gap. Configure Microsoft Purview auto-labeling policies that detect patterns associated with sensitive content (BCSI keywords, financial data patterns, PII) and automatically apply the appropriate sensitivity label. Auto-labeling in SharePoint and OneDrive works on existing content as well as new uploads, progressively classifying the content library. Start with advisory mode (which recommends a label without applying it) to calibrate the policy, then enable automatic application after the false positive rate is acceptable. This approach brings the classification coverage of a large document library to levels that manual labeling can never achieve.

SharePoint Permissions: The Governance Gap

SharePoint permissions management is one of the most persistent governance challenges in M365 environments. SharePoint's flexible permissions model allows site owners to grant access to virtually any combination of users, groups, and external people, creating a permissions landscape that, without governance, becomes an unauditable tangle of individual-level grants, broken inheritance, and external sharing that no one can fully account for.

Best practices for SharePoint permissions governance in energy environments include: using security groups for access control rather than individual user grants (groups can be managed centrally, audited easily, and updated when people change roles); auditing external sharing links quarterly to identify and remove links that are no longer needed; requiring site owner confirmation that permissions remain appropriate during the

annual site lifecycle review; and using SharePoint's built-in site ownership reports to identify sites with no active owners.

For SharePoint libraries containing BCSI or other CIP-011 regulated content, access must be restricted to explicitly authorized personnel only, with all access changes logged and available for audit. Automated access review generating a current access list quarterly and requiring the designated custodian to confirm all access is appropriate should be a mandatory control for these libraries.

9.6 M365 Upgrades: Managing the Continuous Change

Managing the M365 Message Center

Microsoft communicates upcoming M365 changes through the Message Center in the M365 admin center. For energy company IT teams, monitoring the Message Center is a compliance function as much as an operational one changes to service behavior, feature additions, and deprecated features may affect compliance configurations, data governance policies, or end-user workflows that support regulatory obligations.

Establish a formal process for Message Center review: assign one IT team member as the primary Message Center monitor, review new messages at least weekly, categorize messages by impact level (informational, action required, urgent), and route action-required items to the appropriate owner. Messages about changes that affect compliance configurations retention policy changes, DLP engine updates, label behavior changes should be reviewed by the compliance team before the change takes effect.

Compatibility Testing for Line-of-Business Applications

M365 Apps updates occasionally break compatibility with line-of-business applications that use Office add-ins, COM automation, or specific Office API behaviors. In energy environments, where specialized engineering tools, field reporting applications, and operational data tools may integrate with Excel or Outlook through add-ins or automation, compatibility testing before broad deployment is essential.

Use the Current Channel (assigned to IT staff) as the first compatibility signal: IT staff who use the affected add-ins on Current Channel will encounter any compatibility issues approximately two to four months before they reach Semi-Annual Enterprise Channel users. When a compatibility issue is identified, notify the application owner, engage the vendor, and if needed, deploy a compatibility fix or hold back the update for affected users using the office update policy in Group Policy or Intune.

9.7 Teams for Field Operations

Configuring Teams Policies for Field Workers

Microsoft Teams provides a rich set of messaging, meeting, and calling policies that can be assigned per user or per group. For field worker populations in energy companies, the following policy configurations are typically appropriate:

- Video disabled by default in meetings: Configure the meeting policy to start meetings without video for users in field roles. This reduces bandwidth consumption and prevents accidental video in safety-sensitive environments where a phone in a shirt pocket could capture sensitive operational areas.

- Walkie-Talkie enabled: Enable the Walkie-Talkie app in the Teams app setup policy for field worker roles. Configure the channels assigned to each field team so they can communicate by push-to-talk with the appropriate group.
- File sharing restrictions: Configure the messaging policy to restrict external file sharing field workers should not be sending corporate documents to personal or contractor accounts through Teams chat.
- Meeting recording: Disable meeting recording for field worker accounts. Field workers participating in operational briefings or incident response calls should not be creating recordings that could contain sensitive operational content on personal devices.

PRACTITIONER TIP: Pre-Stage Teams Content for Field Sites Before Loss of Connectivity

✓ Teams caches recent messages and files locally on the device, but the cache is limited and follows a last-recently-used pattern. For field workers who will be in areas without connectivity for extended periods, configure the Teams sync policy to pre-cache the channels and files they are most likely to need. Test the offline experience on the actual devices and connectivity profiles used at your most remote sites before deploying Teams to field operations discovering that critical shift handover information is unavailable offline, in the field, is a much more expensive problem than discovering it during a staged rollout test.

Viva and Advanced Collaboration Capabilities

Microsoft Viva is Microsoft's employee experience platform built on top of M365. For energy companies, several Viva components have specific operational value: Viva Connections provides a customizable intranet experience within Teams,

enabling a single entry point for news, policies, procedures, and tools across the enterprise; Viva Insights provides analytics on collaboration patterns that can identify team communication bottlenecks, after-hours work trends, and collaboration network gaps; and Viva Learning enables targeted training delivery within the Teams interface, making compliance training (annual NERC CIP-004 awareness training, for example) accessible where workers are already spending their collaboration time.

Viva adoption in energy companies should be evaluated based on specific operational needs rather than deployed as a broad platform. The components with the most direct value for energy sector IT and operations are Viva Connections (intranet and operational communications) and Viva Learning (compliance and safety training delivery). These two components provide measurable operational value without significant governance complexity.

CASE STUDY | Microsoft Teams Rollout at a Large Integrated Energy Company Composite Scenario

Background

A large integrated energy company with approximately 12,000 employees spanning upstream, midstream, and downstream operations across North America deployed Microsoft Teams as part of an M365 migration from on-premises Exchange and Lync. The IT team had six months to deploy Teams to the full workforce, including approximately 3,500 field workers across 200+ operational sites.

Governance Decision

Early in the deployment, the IT team made a critical governance decision: restrict team creation to designated team champions in each business unit, rather than enabling open creation for all users. This decision was unpopular initially some managers wanted to create their own teams immediately but it was enforced consistently. Twelve months after deployment, the company had

approximately 400 active teams with clear ownership and classification, rather than the 2,000+ unmanaged teams that organizations with open creation policies typically accumulate in the same timeframe.

Field Deployment Approach

Field worker deployment followed a hardware-first model: all field workers received corporate smartphones before Teams was enabled for them. The Teams deployment to field workers included pre-configured push-to-talk channels for each site operations group, a pre-staged Teams app setup policy with Walkie-Talkie and Shifts enabled, video disabled by meeting policy, and a 'welcome to Teams' knowledge base article published in the site supervisor's Teams channel before rollout. A 30-minute virtual training session was conducted with site supervisors one week before deployment.

BCSI and Compliance

The compliance team identified that certain operational Teams channels would contain content potentially meeting the BCSI definition under NERC CIP-011. For these channels, sensitivity labels were applied at the team level, DLP policies blocked external sharing, and access was restricted to explicitly authorized personnel. The compliance documentation for these controls was integrated into the NERC CIP compliance evidence repository.

Outcomes

Eighteen months post-deployment, the company measured a 40% reduction in internal email volume, a 25% reduction in meeting duration (attributed to Teams' asynchronous communication capabilities reducing the need for scheduled calls), and a 60% adoption rate for the Shifts feature among field supervisors. The governance discipline particularly the team creation restriction and classification requirement was credited by the compliance team as a key factor in maintaining NERC CIP compliance posture through the deployment.

PRACTITIONER PERSPECTIVE | Collaboration Platform Engineer |
Large Midstream Pipeline Company (Anonymous)

"What is the biggest risk most energy companies do not recognize when deploying Teams?"

The retention and eDiscovery exposure. When companies move from email to Teams for operational communication, they often assume that Teams messages are less formal and therefore not subject to the same retention and legal hold obligations as email. That assumption is incorrect. Teams messages are corporate records subject to the same obligations as email. The risk is that companies deploy Teams without configuring retention policies, users have real operational conversations in Teams channels, and then a regulatory investigation or lawsuit requires production of records from a period where Teams messages were not being retained. By the time anyone realizes the gap, the records are gone. Configure Teams retention policies before you deploy, not after the first legal hold request arrives.

9.8 M365 Adoption and Change Management

Deploying M365 tools is not the same as enabling productive use of them. Energy companies that simply turn on Teams and SharePoint and expect users to naturally migrate their collaboration workflows from email and shared drives will be disappointed. Effective M365 adoption requires intentional change management: understanding current workflows, designing the new workflows, communicating the changes, providing role-specific training, and measuring adoption over time.

In energy environments, the adoption challenge is amplified by the workforce diversity: corporate knowledge workers will adopt new collaboration tools relatively quickly; field operators accustomed to phone and radio communication may need more support and clearer operational rationale for adopting digital

collaboration tools; executives may resist changing established email workflows unless they see clear personal productivity benefits. Adoption programs should be designed for each of these populations separately, with use cases and training that reflect their specific work patterns.

Microsoft provides adoption resources through the M365 Adoption Hub, including customizable training content, adoption guides, and campaign templates. These resources significantly reduce the effort required to build an adoption program and should be the starting point, adapted to the organization's specific energy sector context and vocabulary.

Chapter Summary

- M365 in energy environments requires governance that accounts for NERC CIP-011 (BCSI protection), SOX records retention, and the operational sensitivity of energy sector data not just default M365 configuration.
- Exchange Online security requires properly configured anti-phishing policies, Safe Attachments and Safe Links, domain authentication (SPF/DKIM/DMARC), and tiered retention policies aligned with regulatory requirements. Legal Hold capability must be tested before it is needed.
- Teams governance requires policies across three dimensions: creation control (restrict team creation, enforce naming and classification), lifecycle management (expiration policy, retention policies), and security/compliance (DLP, external sharing controls, recording policy).
- SharePoint governance must include a defined information architecture (Hub Sites, Team Sites, Communication Sites), sensitivity labels with auto-labeling for BCSI and confidential content, and quarterly

access reviews for libraries containing regulated information.

- Known Folder Move should be deployed via Intune for all managed Windows devices it provides automatic cloud backup for user files with no user action required and enables seamless device replacement.
- M365 Apps update channel strategy should assign the Semi-Annual Enterprise Channel to approximately 70% of the fleet (field and regional users) for stability, with IT staff on Current Channel for early compatibility detection.
- Teams for field workers requires bandwidth-aware configuration: video disabled by policy at bandwidth-constrained sites, Walkie-Talkie enabled for push-to-talk communication, and pre-staged content caching for offline access at remote locations.
- Teams retention policies must be configured before deployment Teams messages are corporate records subject to the same retention and legal hold obligations as email. This configuration gap is the most common and consequential Teams governance failure.

Chapter 9 Checklist: M365 and Collaboration Governance Readiness

- | | |
|--------------------------|--|
| ☐ | M365 tenant administrative roles follow least privilege: Global Administrator assigned to maximum 4 accounts managed via PIM |
| ☐ | Emergency access accounts are configured, documented, stored securely, and tested annually |
| ☐ | Exchange anti-phishing policies are configured with executive impersonation protection enabled |

☐	Safe Attachments and Safe Links are enabled for all users
☐	SPF, DKIM, and DMARC records are configured; DMARC is in enforcement mode (p=reject or p=quarantine)
☐	Exchange retention policies are tiered by content type and aligned with legal/regulatory requirements
☐	Legal Hold capability is tested and procedures are documented with Legal team involvement
☐	Teams creation is restricted to designated team champions; naming policy is enforced
☐	Teams sensitivity label classification is required at team creation
☐	Teams expiration policy is configured; team owners are notified of inactive teams
☐	Teams retention policies are configured and aligned with email retention schedule
☐	Teams DLP policies are active for messages containing sensitive keywords or data patterns
☐	External sharing controls are configured: anonymous links disabled, external sharing approval required
☐	SharePoint information architecture (Hub Sites, Team Sites, Communication Sites) is documented and implemented
☐	Sensitivity labels with auto-labeling are configured in Microsoft Purview for BCSI and Confidential content
☐	BCSI-labeled SharePoint libraries have access restricted, audit logging enabled, and external sharing disabled

- Known Folder Move is deployed via Intune configuration profile for all managed Windows devices
- M365 Apps update channel strategy is documented; Semi-Annual Enterprise Channel for field/regional users
- Teams policies for field workers: video disabled, Walkie-Talkie enabled, file sharing restricted
- M365 Message Center review process is defined with assigned owner and weekly cadence

References and Further Reading

Microsoft Documentation

Microsoft. Microsoft Teams Admin Documentation.

learn.microsoft.com/microsoftteams/microsoft-teams. Continuously updated.

Microsoft. SharePoint Online Documentation.

learn.microsoft.com/sharepoint/sharepoint-online. Continuously updated.

Microsoft. Microsoft Purview Compliance Documentation.

learn.microsoft.com/microsoft-365/compliance. Continuously updated.

Microsoft. Microsoft 365 Apps Update Channels.

learn.microsoft.com/deployoffice/overview-update-channels. Continuously updated.

Microsoft. Known Folder Move Overview.

learn.microsoft.com/sharepoint/redirect-known-folders. Continuously updated.

Microsoft. Manage Microsoft Teams Governance.

learn.microsoft.com/microsoftteams/teams-adoption-governance-quick-start. Continuously updated.

Compliance and Security

*NERC. CIP-011-2: Cyber Security Information Protection. nerc.com.
Continuously updated.*

*Microsoft. Sensitivity Labels in Microsoft 365.
learn.microsoft.com/microsoft-365/compliance/sensitivity-labels.
Continuously updated.*

*Microsoft. Data Loss Prevention (DLP) Policies.
learn.microsoft.com/microsoft-365/compliance/dlp-overview. Continuously
updated.*

*Microsoft. Exchange Online Retention Policies.
learn.microsoft.com/microsoft-365/compliance/create-retention-policies.
Continuously updated.*

IT Operations in Field and Remote Environments

Supporting the People Who Keep the Energy Flowing

Field IT is where all the theory meets reality. You can design the most elegant management architecture in the world, and then you find out the compressor station has 256 kbps satellite and the nearest IT technician is four hours away.

Field IT Operations Lead, Large Midstream Pipeline Company

10.1 The Field Operations Reality

No chapter of this book covers territory more operationally demanding than this one. Field and remote IT operations in energy companies represent the convergence of every challenge discussed in previous chapters: limited connectivity, geographic dispersion, operational sensitivity, regulatory constraints, specialized hardware requirements—compressed into environments where IT support staff may be hours or days away and where a technology failure can directly affect production and safety.

The field IT challenge is fundamentally different from corporate IT in one critical respect: the cost and logistics of physical presence. At corporate headquarters, a broken laptop is a

fifteen-minute walk to the IT help desk. At a gas compressor station in a remote basin, the same broken laptop may mean a technician driving four hours, spending the night, and driving four hours back consuming two days of labor for a hardware replacement that should have taken thirty minutes. Designing field IT operations to minimize this physical presence requirement through robust remote tooling, pre-provisioned spare hardware, and processes that enable users to self-resolve common issues is not just a convenience; it is an operational and financial necessity.

This chapter covers the complete field IT operations model: site tier classification, remote support tooling, field network architecture (including the critical IT/OT boundary), hardware selection for harsh environments, the depot and advance ship model, patch management at bandwidth-constrained sites, and the governance considerations unique to field operations.

10.2 Site Tier Classification: The Foundation of Field IT

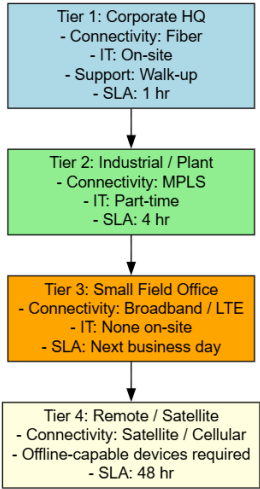


Figure 10.1 Energy field site IT profile and connectivity tiers. Site tier classification drives every subsequent IT decision: support SLAs, patch window design, hardware selection, deployment approach, and remote management tooling. Tier 4 (remote/satellite) sites require fundamentally different IT architectures than Tier 1 corporate sites. The percentages shown are illustrative; actual distribution varies significantly by company type and geography. Source: IT field operations practice; energy sector IT experience.

Building Your Site Tier Taxonomy

The site tier taxonomy is one of the most valuable governance tools available to an energy IT organization. It provides a shared language between IT, operations, and leadership for discussing support expectations, justifying infrastructure investments, and communicating the operational impact of IT resource constraints. A field operations supervisor who understands that their site is a Tier 3 site with a defined support SLA of next business day has appropriate expectations for IT response. A CISO who sees that 15 percent of the device fleet is at Tier 4 sites with satellite-only connectivity understands why certain cloud-dependent security tools may not be viable for those devices.

Define the tier taxonomy collaboratively with operations and facilities teams, not unilaterally by IT. The operations team understands which sites are operationally critical in ways that IT may not—a small compressor station might be low in device count (Tier 3 by typical metrics) but highly critical operationally (because it controls flow on a major pipeline). The tier taxonomy should capture both the IT infrastructure profile and the operational criticality of each site, and the support SLA should reflect both dimensions.

Once defined, the taxonomy should be applied to every site in the portfolio and maintained as part of the site inventory. SCCM

and Intune collections aligned to the tier taxonomy devices in Tier 3 sites in a dedicated collection, Tier 4 devices in another enable tier-appropriate policy application: different patch maintenance windows, different bandwidth throttling settings, different app deployment schedules.

PRACTITIONER TIP: Create an SCCM/Intune Collection for Each Site Tier



The single most operationally valuable implementation of the site tier taxonomy is creating dedicated SCCM/Intune collections for each tier and applying tier-appropriate settings. Tier 3 collections get patch maintenance windows during off-peak hours, bandwidth throttling on software distribution, and reduced installation deadline windows. Tier 4 collections get the most conservative patch schedules, the most aggressive bandwidth throttling, and pre-staged content where possible. This one-time configuration investment pays dividends with every patch cycle, every software deployment, and every policy change automatically applying the right approach to the right site without manual intervention.

10.3 Remote Support Model: Doing More Without Being There

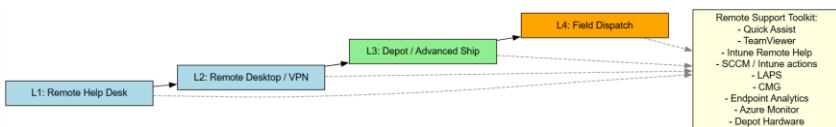


Figure 10.2 Field IT remote support model. The escalation model minimizes costly Level 4 field dispatch by maximizing the resolution rate at Levels 1–3. The critical enabler for Level 3 (depot/advance ship) is pre-enrolled spare hardware: a device that arrives at a field site already

enrolled in Autopilot, with the user's applications targeted, and their files available via OneDrive does not require IT presence for setup. Source: Energy sector field IT operations practice.

Building the Remote Support Toolkit

The effectiveness of field IT support is directly proportional to the quality of the remote support toolkit. An IT team that can remotely control any managed device, push any software package, retrieve local admin credentials, and execute diagnostic scripts has most of the capability of an on-site technician for the large majority of field support scenarios. An IT team that can only send emails to users and hope they follow instructions correctly will dispatch physical technicians for issues that should never require travel.

Microsoft Quick Assist, built into Windows 10 and 11, is the lowest-friction remote control option for managed devices it requires no additional software installation, works over HTTPS without VPN, and generates an audit log of the session. For devices that are not on the corporate network and do not have Quick Assist available, TeamViewer or AnyDesk (deployed as a managed application through SCCM/Intune) provides equivalent capability. Intune Remote Help is a licensed add-on that provides compliance-checked remote assistance sessions directly from the Intune console useful for environments where compliance state must be verified before remote access is granted.

SCCM and Intune remote actions software installation, script execution, device wipe, policy sync provide management capability that does not require user involvement or even a logged-in session. These actions work over the CMG for internet-based devices, making them available for Tier 3 and Tier 4 sites without VPN. This capability is the foundation of effective field IT: the ability to take management actions on

remote devices without requiring the user to do anything or the IT technician to be there.

COMMON MISTAKE: Providing Remote Support Without a Proper Remote Control Tool

! The most common field IT support failure pattern is organizations that do not have a standardized, pre-deployed remote control solution for all managed devices. When a field user calls with an issue that cannot be resolved verbally, the support technician has no option but to walk the user through the resolution step by step a process that is slow, error-prone, and frustrating for both parties, and which fails entirely when the user cannot follow technical instructions. Deploying a remote control solution (Quick Assist, TeamViewer, or Intune Remote Help) to every managed device and training help desk staff to use it routinely transforms field support from a guessing game into a manageable remote operation. This investment which is low cost and straightforward to deploy should be a first-year priority for any field IT program.

Building the Depot and Advance Ship Model

The depot model is the most effective mechanism for resolving field hardware failures without site visits. The concept is straightforward: maintain a stock of pre-configured spare devices at regional depot locations, and when a field device fails, ship a spare to the user overnight rather than dispatching a technician to repair or replace the device on-site.

The pre-configuration requirement is the critical enabler: a spare device that ships to a field site and still requires hours of IT configuration after arrival provides limited value over a technician visit. A spare device that arrives pre-enrolled in Autopilot, with the user's account pre-associated, their role-based applications targeted in Intune, and their files available

through OneDrive the moment they sign in this device enables the user to be productive within an hour of the package arriving, with no IT presence required.

Depot sizing should be based on failure rate data: track device failures by site tier and hardware model over rolling 12-month periods, and maintain depot stock at a level that ensures a spare is almost always available. For most energy company field operations, regional depots with two to five spare devices per site tier serve the majority of the fleet without requiring central warehouse inventory. The cost of maintaining spares in depot is almost always lower than the travel cost of the technician visits they prevent.

10.4 Field Site Network Architecture: IT/OT Boundary Management

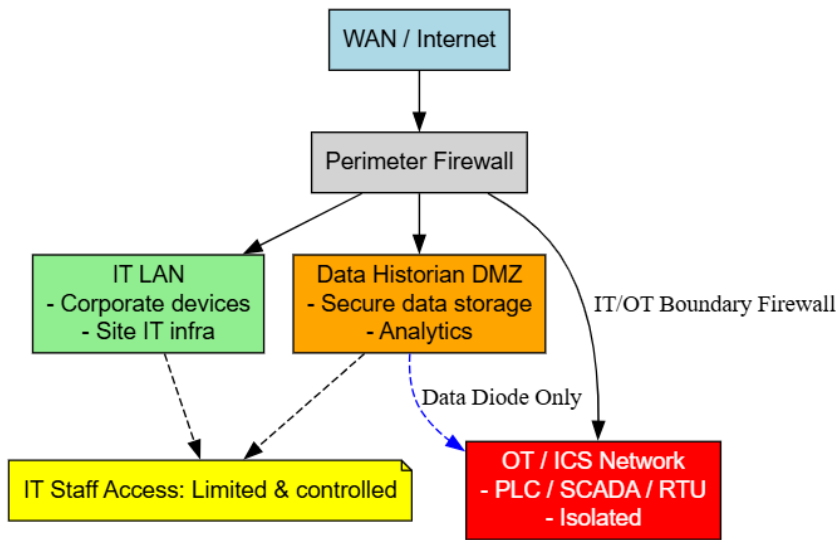


Figure 10.3 Field site network architecture illustrating IT/OT segmentation at a pipeline compressor station. The IT LAN and OT/ICS network are physically and logically separated by a boundary firewall. The data historian in the DMZ acts as the read-only bridge between OT data and IT reporting systems. IT staff manage the IT LAN and site IT infrastructure only OT systems are managed exclusively by Control Systems engineers. This boundary is a NERC CIP requirement for applicable BES sites and a fundamental security control for all energy field environments. Source: Energy sector network architecture practice; NERC CIP-005 electronic security perimeter requirements.

IT's Role at the IT/OT Boundary

One of the most important and most frequently misunderstood aspects of field IT operations in energy environments is the IT/OT boundary. The boundary exists to prevent a cybersecurity compromise of the IT environment from propagating into the OT environment where it could affect physical operations. It is also, for BES-connected sites, a NERC CIP compliance requirement: the Electronic Security Perimeter (ESP) around BES Cyber Systems must be defined and enforced.

IT staff at field sites have a clearly scoped responsibility: the IT LAN and the IT infrastructure (switches, wireless access points, UPS devices, printers, workstations) on the IT side of the boundary. The OT network the PLCs, SCADA HMIs, remote terminal units, safety systems, and the OT switches and firewalls that connect them is managed by OT engineers and control systems staff, not by IT.

This boundary is not a suggestion or a recommendation it is a hard rule that IT professionals in energy environments must internalize and respect. An IT technician who connects a corporate laptop to an OT switch to "just check something quickly" may be violating a NERC CIP electronic security perimeter, introducing an uncontrolled device into an OT environment with potentially catastrophic consequences, and taking an action that could result in both regulatory penalties and

job-ending consequences. When in doubt about whether something is on the IT or OT side of the boundary, ask the Control Systems team do not assume.

PRACTITIONER TIP: Document the IT/OT Boundary for Every Field Site



The IT/OT boundary is not the same at every field site. Some sites have clear physical separation; others have more complex topologies where the boundary runs through a shared switch or a firewall with complex rule sets. For each site in your tier 2 and above portfolio, document: which switches, VLANs, and physical segments are in the IT domain; which are in the OT domain; and which firewall rules permit communication between them. This documentation is required for NERC CIP compliance at applicable sites, and it is essential operational knowledge for any IT technician who will work at the site. Without it, the risk of an IT staff member inadvertently touching OT infrastructure is real.

Site IT Infrastructure Management

Below the IT/OT boundary, the site IT infrastructure network switches, wireless access points, UPS devices, and any local servers is IT's responsibility to manage and maintain. For most Tier 3 and Tier 4 sites, this infrastructure must be remotely manageable because there is no on-site IT staff. Key requirements for field site IT infrastructure:

- Out-of-band management: Network switches should have out-of-band management access (dedicated management VLAN, OOBM port, or cellular backup connection) so IT can access them even if the production network is down. A network issue that takes down the main LAN and also removes IT's ability to access the

switch remotely requires a site visit that could have been prevented.

- UPS monitoring: Uninterruptible power supplies at field sites should be monitored remotely power events, battery health, and runtime estimates should generate alerts to the IT monitoring platform. A UPS that has degraded to 30 percent battery health will fail on the next power event without warning if it is not monitored.
- Wireless coverage: Wireless access points at field sites should be managed through a cloud wireless controller or the site network, providing remote visibility into client counts, signal quality, and connectivity issues. Field workers who cannot connect to corporate Wi-Fi at a remote site have essentially no IT support capability.

10.5 Field Hardware: Selecting the Right Device for the Environment



Figure 10.4 Field hardware selection guide for energy environments. Device selection must be validated against the actual work environment before procurement. Rugged devices cost 2–3 times more than standard equivalents but provide significantly longer field lifecycles and lower total cost of ownership when factoring in damage/replacement rates. Intrinsically safe devices are required not optional for classified hazardous areas. Involve HSE (Health, Safety, and Environment) in the selection and approval process for any device used in classified hazardous areas.

The Total Cost of Ownership Argument for Rugged Devices

The most common procurement mistake in field IT is selecting standard consumer-grade or business laptops for field technicians to reduce upfront cost. The calculation appears straightforward: a rugged laptop costs \$2,800 while a standard business laptop costs \$900. But this comparison ignores the operational reality. A standard laptop deployed to a field technician who works outdoors, in vehicles, and in industrial environments will typically fail within 12–18 months due to dust ingress, vibration damage, drop damage, or moisture. A rugged laptop in the same environment will typically operate for five to seven years.

The total cost calculation over five years: three to four standard laptop replacements at \$900 each plus the service call and logistics cost of each replacement (\$300–500 per incident) equals \$3,600–\$5,100 total. One rugged laptop at \$2,800 plus one depot refresh at year four equals \$3,200–\$3,500 total. The rugged device is cheaper over its operational lifecycle before even accounting for the productivity loss and operational disruption associated with each hardware failure at a remote site.

Hazardous Area Devices: A Non-Negotiable Requirement

Classified hazardous areas defined by the presence of flammable gases, vapors, or dusts that could be ignited by electrical equipment exist at refineries, wellheads, tank farms, loading terminals, and other energy sector facilities. In North America, these areas are classified under the National Electrical Code (NEC) as Class I, Division 1 or 2 (for gases and vapors) or Class II (for dusts). In international contexts, the IEC zone system (Zone 0, 1, 2 for gases; Zone 20, 21, 22 for dusts) applies.

Any electronic device used in a classified hazardous area must be certified as intrinsically safe or explosion-proof for the applicable classification. This is not an IT decision it is an HSE and engineering requirement with legal liability consequences if violated. IT professionals who receive requests for devices at classified hazardous area locations must involve the HSE team to verify the area classification and procure equipment certified for that classification. The alternative deploying a standard business laptop in a Class I Div 1 area is not merely a policy violation; it is a potential source of ignition in an environment where ignition can cause explosions.

10.6 Patch Management at Bandwidth-Constrained Sites

Patch management at Tier 3 and Tier 4 field sites represents one of the most technically complex operational challenges in energy IT. The same compliance requirements that apply to well-connected corporate devices NERC CIP's 35-day patch window for applicable BES Cyber Systems, monthly security updates for all managed endpoints apply equally to devices at sites where available bandwidth may be measured in kilobits per second. Meeting these requirements requires patch management strategies specifically designed for bandwidth-constrained environments.

Bandwidth Throttling and Scheduling

SCCM and Intune provide robust tools for controlling bandwidth consumption during software distribution and Windows updates. For Tier 3 and Tier 4 sites, configure:

- SCCM bandwidth throttling on Distribution Points and CMG: Set maximum transfer rates that align with available site bandwidth, with larger allocations during scheduled maintenance windows (typically overnight or

weekend hours) and minimal bandwidth consumption during operational hours.

- Windows Update for Business delivery optimization: Configure peer-to-peer content delivery so that devices at the same site share downloaded content rather than each device downloading independently. At a Tier 3 site with 20 devices, peer delivery can reduce total patch bandwidth consumption by 90 percent.
- Maintenance window scheduling: Set SCCM/Intune maintenance windows for Tier 3 and Tier 4 devices during hours when operational activity is lowest and bandwidth contention is minimal. For most energy field sites, this is between 10 PM and 5 AM local time. Coordinate with operations to confirm that the maintenance window does not coincide with planned overnight work.

Pre-Staging Content for Remote Sites

For Tier 4 satellite sites where even nighttime bandwidth may be insufficient for large patch downloads within the maintenance window, content pre-staging provides an alternative. Content pre-staging involves shipping a USB drive with pre-downloaded patch content to the site, where it is loaded onto the local cache and then distributed locally to devices without requiring internet bandwidth.

This approach requires discipline: the USB drive must be tracked and accounted for (a removable drive with security update content that is lost or stolen is a minor security issue; one that contains sensitive data would be a significant one), the content must be current at the time of shipment, and the local loading process must be documented and followed correctly. For most Tier 3 sites with adequate nighttime bandwidth, content pre-staging is unnecessary. For the small number of Tier 4 sites

where satellite bandwidth makes normal patch distribution impractical, it may be the only viable approach.

10.7 The Zero-Touch Field Device Replacement Workflow

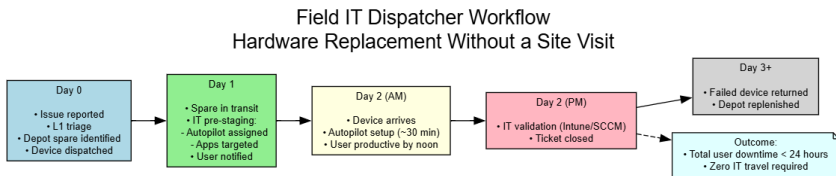


Figure 10.5 Zero-touch field device replacement workflow enabled by Autopilot and OneDrive. This workflow eliminates IT travel for the most common field hardware scenario (device failure requiring replacement) by pre-staging spare hardware, leveraging Autopilot for zero-touch provisioning, and relying on OneDrive for user file availability. Prerequisites: Autopilot pre-enrollment of all spare devices, Intune app targeting by user group, OneDrive Known Folder Move enabled, and stocked regional depots. Each prerequisite must be in place before the first hardware failure occurs.

Building the Autopilot Deployment Model for Field

The zero-touch replacement workflow described above depends on Windows Autopilot Microsoft's zero-touch provisioning service that allows a new or replacement device to be deployed to a user without IT staff involvement. When a user powers on an Autopilot-enrolled device and connects to the internet, the device automatically downloads its configuration, applies policies, installs assigned applications, and presents the user with a standard sign-in experience. From the user's perspective,

they sign in with their M365 credentials and the device configures itself.

For field operations, Autopilot provides two deployment models that are particularly valuable:

- **User-Driven Mode:** The user receives the device, powers it on, connects to Wi-Fi (or cellular), and the Autopilot enrollment process runs automatically. This requires an internet connection but no IT presence. All spare devices in the depot should be enrolled in Autopilot in this mode.
- **Pre-Provisioned Mode (White Glove):** The device is partially provisioned in the depot by IT before shipping device-level policies and applications are installed while IT has the device in hand. When the user receives it, only the user-specific portion of the configuration runs (which takes minutes rather than 30–60 minutes for full provisioning). This model is valuable for Tier 4 sites where internet bandwidth is too limited for reliable over-the-air Autopilot provisioning.

CASE STUDY | Remote Field IT Operations Transformation Composite Scenario

Background

A large midstream pipeline company with operations across 14 states, approximately 4,200 managed endpoints, and 180 field sites ranging from unmanned compressor stations to regional offices undertook a field IT transformation after an internal audit found that field IT support was consuming 35 percent of the IT support team's time primarily in travel and logistics while achieving customer satisfaction scores of 3.1 out of 5 from field employees.

Root Cause Analysis

The core problem was structural: the company had no depot model, no standardized remote control tooling, no Autopilot enrollment, and no site tier taxonomy. Every hardware failure at a remote site

required a technician visit. Every software issue that could not be resolved by phone consumed hours of back-and-forth. SCCM was deployed but had no bandwidth throttling configured for field sites, causing patch downloads to saturate site connectivity during operational hours and generate complaints from operations supervisors.

Transformation Initiative

Over 18 months, the IT team implemented: a four-tier site taxonomy applied to all 180 sites; SCCM/Intune collections aligned to each tier with appropriate patch windows and bandwidth settings; regional depots with pre-imaged Autopilot-enrolled spares at six locations; Microsoft Quick Assist deployed to all managed devices; OneDrive Known Folder Move enabled for all field users; and a formal escalation model with defined criteria for each level.

Field Network Cleanup

The team also conducted a site IT/OT boundary audit across all 45 Tier 2 sites, discovering that 12 sites had no formal documentation of the boundary and three had IT switches that were physically adjacent to OT switches with unclear demarcation. These findings were remediated before the next NERC CIP compliance review, avoiding potential findings that would have been far more disruptive to address under audit pressure.

Outcomes

Within 12 months of completing the transformation, field IT travel was reduced by 62 percent. Customer satisfaction from field employees improved from 3.1 to 4.3 out of 5. Patch compliance at Tier 3 and Tier 4 sites improved from 71 percent to 94 percent after bandwidth throttling was configured. The average time to resolve a field hardware failure dropped from 3.8 days (primarily driven by technician travel scheduling) to 1.4 days. The cost savings from reduced travel exceeded the technology investment within 14 months.

PRACTITIONER PERSPECTIVE | Field Operations IT Manager |
Large Upstream Energy Company (Anonymous)

"What is the one thing that most dramatically improved your field IT operations?"

Autopilot and the depot model, without question. Before we implemented those, every hardware failure at a remote site was a three-day event: one day to schedule the technician, one day to travel and fix it, one day to travel back. Our technicians were spending more time in trucks than at computers. After we set up regional depots with Autopilot-enrolled spares, a hardware failure became a same-day ship and a user-handled setup. The technician who used to spend three days on a single field trip can now resolve the same issue remotely from the office in two hours, including the time to confirm the replacement device is working correctly. The field user experience actually got better because the resolution was faster. I wish we had done it years earlier.

10.8 Field IT Governance and Documentation

Field IT operations without adequate documentation are inherently fragile: dependent on the institutional knowledge of the individual technicians who built and maintain the infrastructure, and vulnerable to disruption whenever those technicians change roles or leave. For energy companies where field sites may have complex, custom configurations that evolved over years, documentation is not bureaucratic overhead; it is operational continuity insurance.

Every field site in the Tier 2 and above portfolio should have a site IT record that captures: the site tier and address; the IT infrastructure inventory (switches, APs, UPS, local servers make, model, serial number, IP address, management credentials location); the network topology and IT/OT boundary definition; any non-standard configurations or known issues; the

local operations contact and their phone number; and the date of last IT visit and last documentation review.

Site documentation should be reviewed and updated whenever a technician visits the site, whenever a significant infrastructure change is made, and at least annually as part of the site lifecycle review. Documentation stored only in a single technician's memory or personal files is not documentation it is a single point of failure. Store site documentation in a centrally accessible system (SharePoint, ServiceNow, or a dedicated CMDB) where it is available to any IT team member who needs it.

- Site tier classification (Tier 1 through Tier 4 based on connectivity and IT presence) is the foundational governance tool that drives all field IT decisions: support SLAs, patch window design, hardware selection, and deployment approach.
- Effective field IT support requires a four-level escalation model (Remote Help Desk → Remote Desktop → Depot/Advance Ship → Field Dispatch) with the goal of maximizing resolution at Levels 1–3 to minimize costly Level 4 field travel.
- The remote support toolkit Quick Assist, TeamViewer/AnyDesk, SCCM/Intune remote actions, LAPS, CMG gives the IT team most of the capability of an on-site technician for the large majority of field support scenarios.
- The depot and advance ship model, enabled by Autopilot pre-enrollment and OneDrive Known Folder Move, reduces field hardware replacement from a multi-day travel event to a sub-24-hour user-handled process.
- The IT/OT boundary at field sites is a hard boundary that IT staff must never cross without explicit authorization. IT manages the IT LAN; OT/Control Systems engineers

manage the OT network. Document this boundary for every Tier 2 and above site.

- Hardware selection for field environments must account for the operational environment: rugged devices provide lower total cost of ownership than standard devices in harsh environments; intrinsically safe devices are required not optional for classified hazardous areas.
- Patch management at bandwidth-constrained sites requires tier-specific maintenance windows, SCCM/Intune bandwidth throttling, and delivery optimization peer sharing. Configure these settings before deploying devices to field sites not after bandwidth complaints arrive from operations.
- Site IT documentation IT infrastructure inventory, network topology, IT/OT boundary definition must be centrally stored, reviewed annually, and treated as operational continuity insurance rather than administrative overhead.

Chapter 10 Checklist: Field IT Operations Readiness

☐	Site tier taxonomy is defined, documented, and applied to all sites in the fleet
☐	SCCM/Intune device collections are aligned to site tiers with tier-appropriate patch windows and bandwidth settings
☐	Remote control solution (Quick Assist, TeamViewer, or Intune Remote Help) is deployed to all managed field devices
☐	SCCM/Intune CMG is configured for all Tier 3 and Tier 4 devices to enable management without VPN

☐	LAPS is configured for all field devices so local admin credentials can be retrieved remotely for recovery
☐	Depot locations are established with pre-imaged, Autopilot-enrolled spare devices for each tier
☐	Spare device par levels are defined based on historical failure rate data
☐	Windows Autopilot is configured for user-driven mode (Tier 3) and pre-provisioned/White Glove mode (Tier 4)
☐	OneDrive Known Folder Move is deployed to all managed field Windows devices
☐	IT/OT boundary is documented for all Tier 2 and above sites; boundary definition is accessible to all IT staff
☐	IT staff training covers IT/OT boundary rules: explicit authorization required for any OT-adjacent access
☐	Field hardware selection includes rugged device standards for field technician roles
☐	Hazardous area device procurement process involves HSE; intrinsically safe/ATEX devices for classified areas
☐	Bandwidth throttling is configured in SCCM/Intune for Tier 3 and Tier 4 site collections
☐	Delivery optimization peer sharing is enabled for field site device collections
☐	Site IT records are maintained for all Tier 2 and above sites: inventory, topology, boundary, ops contact
☐	Site documentation is stored in a centrally accessible system, not in individual technician records

References and Further Reading

Field IT Operations and Remote Management

Microsoft. Windows Autopilot Overview.

learn.microsoft.com/autopilot/windows-autopilot-overview. Continuously updated.

Microsoft. Autopilot Pre-Provisioned Deployment (White Glove).

learn.microsoft.com/autopilot/pre-provision. Continuously updated.

Microsoft. Microsoft Intune Remote Help.

learn.microsoft.com/intune/remote-actions/remote-help. Continuously updated.

Microsoft. Configure Bandwidth for Software Distribution in Configuration Manager. learn.microsoft.com/configmgr. Continuously updated.

Microsoft. Delivery Optimization for Windows Updates.

learn.microsoft.com/windows/deployment/do. Continuously updated.

Industrial and OT Security

NERC. CIP-005-7: Cyber Security Electronic Security Perimeters.

nerc.com. Continuously updated.

CISA. Recommended Practices for Industrial Control Systems (ICS) Security. cisa.gov/ics. Continuously updated.

ISA/IEC 62443. Industrial Automation and Control Systems (IACS) Security Standards. isa.org. Various years.

Hazardous Area Equipment

National Fire Protection Association. NFPA 70 National Electrical Code (NEC). nfpa.org. Triennial revision cycle.

IECEX. International IECEX System for Certification of Equipment and Services for Use in Explosive Atmospheres. iecex.com. Continuously updated.

IT Project Management and Stakeholder Communication

Delivering Change in a Production-First Culture

In energy companies, the best IT project manager is not the one who understands the technology best. It is the one who understands operations well enough to know when not to deploy.

Senior IT Project Manager, Large Integrated Energy Company

11.1 Project Management in the Energy Context

IT project management in energy companies is shaped by a fundamental tension: IT projects exist to improve capability, but the energy sector's production-first culture treats any disruption to operations as a cost that must be justified. The IT project manager who deploys a system upgrade without coordinating with the operations team and disrupts a planned maintenance shutdown will not be forgiven for being technically correct the business impact of that disruption is real, immediate, and traceable. The IT project manager who over-coordinates, delays projects indefinitely while waiting for a perfect window, and fails to deliver committed capabilities will be equally criticized.

Navigating this tension successfully is the central project management skill in the energy sector. It requires building credibility with operations stakeholders before asking for their flexibility, communicating about changes in the language of operational impact rather than technical detail, and designing deployment approaches that minimize disruption while still delivering the required capability on schedule.

This chapter provides a practical guide to IT project management in energy environments: the five-phase project lifecycle with energy-specific adaptations, stakeholder communication frameworks, risk management for energy-specific risks, business case construction that resonates with energy leadership, portfolio management and reporting, and the vendor and contract management considerations unique to the sector.

11.2 The Five-Phase IT Project Lifecycle

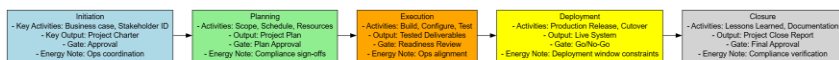


Figure 11.1 IT project lifecycle for energy companies. Each phase ends with a formal gate review before work proceeds to the next phase. The energy-specific notes (bottom row) highlight the operational coordination requirements that distinguish energy IT projects from those in most other industries. Projects that skip the operations coordination gate before deployment are the most common source of preventable IT-operations conflict in energy companies. Source: IT project management practice; energy sector IT experience.

Phase 1: Initiation Building the Foundation

The initiation phase establishes whether a project should exist and what it is trying to accomplish. In energy companies, initiation requires two activities beyond the standard business case: a regulatory pre-screen and a stakeholder mapping exercise that explicitly identifies which operations teams will be affected.

The regulatory pre-screen asks a simple question: does this project touch any systems or processes that are in scope for NERC CIP, TSA Pipeline Security Directives, SOX ITGCs, or other regulatory frameworks? If yes, the relevant compliance team must be engaged from the beginning not at the end when compliance review threatens to delay a completed project. Early compliance engagement costs a meeting; late compliance engagement can cost months of rework.

The stakeholder map for an energy IT project should include not only the typical IT stakeholders (project sponsor, IT management, end users, help desk) but also the operations contacts who will need to be coordinated for any deployment activity. Identifying these contacts at initiation getting names, phone numbers, and preferred communication channels means they are available when needed during execution and deployment, not being discovered for the first time under pressure.

PRACTITIONER TIP: Schedule the Operations Conversation Before Writing the Project Plan



The most valuable thirty minutes in the initiation phase of any energy IT project that will touch field sites or operational systems is a conversation with the relevant operations manager or site supervisor. Ask them: what times of year are busiest for your team? What maintenance windows are coming up? Are there any periods in the next twelve months when you cannot afford IT work at your sites? What is the best

way to communicate with your team about upcoming IT changes? The information you gather in this conversation shapes the project timeline, deployment approach, and communication plan in ways that dramatically reduce the risk of ops-IT conflict during execution. And the conversation itself builds the relationship credibility that makes future coordination easier.

Phase 2: Planning Designing for the Energy Environment

The planning phase converts the approved project charter into a detailed plan: scope, schedule, resource requirements, risk register, communications plan, and change management plan. In energy environments, each of these components requires energy-specific adaptation.

The project schedule must account for energy operational cycles. Large capital projects, turnarounds, and seasonal production peaks create periods when IT projects at affected sites must pause. Build these blackout periods into the schedule before committing to delivery dates. A Windows 11 migration project that promises field site deployment in Q3 without checking whether Q3 coincides with the annual turnaround season at those sites will fail the Q3 commitment before the first device is touched.

The resource plan must acknowledge that energy IT teams are typically lean most IT staff have both project and operational responsibilities, and project work competes directly with the daily support demands that field operations generate. Plan for realistic availability: an IT specialist who is nominally assigned 50 percent to a project will typically deliver closer to 30 to 40 percent because operational support demand is unpredictable and operationally urgent. Build this reality into the schedule rather than discovering it when timelines slip.

Phase 3: Execution Maintaining Momentum and Visibility

During execution, the project manager's primary functions shift from planning to tracking and communication. The weekly status report is not administrative overhead it is the mechanism by which issues are surfaced, decisions are escalated, and the project team maintains shared situational awareness. A project team that stops producing weekly status reports during a difficult phase is almost certainly one that has lost track of its issues.

Issue and decision logs are the two most valuable tracking tools in project execution. The issue log captures every identified problem with its owner, status, and resolution date. The decision log captures every significant decision made during the project what was decided, who decided it, and why. These logs serve both real-time coordination purposes and post-project retrospective purposes. They are also compliance evidence: projects that affect NERC CIP-scope systems need documented decision trails for audit purposes.

Change management in execution refers not to IT change control (which is covered in Chapter 7) but to organizational change management the discipline of managing the human side of change. Technology implementations fail when the technology works but the people do not use it, or use it incorrectly. Energy sector IT projects that affect field worker workflows require investment in training and communication proportional to the degree of change they introduce.

COMMON MISTAKE: Treating Status Reporting as Optional When Projects Get Difficult

!

The most common project communication failure is the project manager who stops sending status reports precisely when the project is in trouble either because they do not want to report bad news, or because producing the report takes time they feel they cannot spare while managing a crisis. This is exactly

backwards. Stakeholders who do not receive status reports assume the project is in worse shape than it is; they begin seeking information through informal channels, receive incomplete or incorrect information, and make decisions or create pressure based on inaccurate understanding. A brief, honest status report that says 'we have hit a technical blocker on the field site deployment, we are working the issue, here is our recovery plan' is dramatically better for stakeholder confidence than silence. Report when things are hard, especially when things are hard.

11.3 Stakeholder Communication: The Energy IT PM's Core Skill

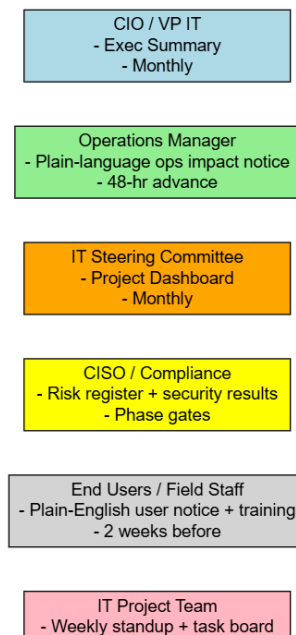


Figure 11.2 Stakeholder communication framework for energy IT projects. Each stakeholder group has different information needs, different preferred formats, and different communication cadences. The Operations Manager row is the most energy-sector-specific entry no equivalent communication obligation exists in most non-energy IT environments. Proactive communication with operations stakeholders before each deployment window is one of the most effective risk-reduction activities available to an energy IT project manager. Source: Energy sector IT project management practice.

Communicating with Operations Stakeholders

The operations manager communication is the most energy-sector-specific project management skill, and the one that most IT professionals underestimate when they move from other industries into energy IT. Operations managers in energy companies are not IT stakeholders in the traditional sense they do not care about technical specifications, architecture decisions, or project methodology. They care about one thing: will this IT change affect my operations, and if so, when and how?

An operations notification for a planned IT deployment should answer exactly those questions, in plain language, without technical jargon. The format is simple: what is changing, what impact (if any) should operations expect during the change window, what the rollback procedure is if something goes wrong, and who to call if there is a problem. It should be sent at least 48 hours before the deployment window and again on the morning of the deployment. If the deployment must be canceled or rescheduled, operations should be notified immediately leaving an operations manager waiting for an IT change that was quietly canceled is a trust-eroding experience.

Communicating with Executive Sponsors

Executive sponsors the CIO, VP of IT, or business executive sponsoring the project need information at the level of strategic

decisions, not technical details. The monthly executive summary should cover: overall project health (a single RAG status), schedule status (on track / delayed and by how much), budget status (on track / over or under and by how much), top risks and mitigation status, and any decisions needed from the sponsor. It should fit on a single page.

The most important sentence in any executive status report is the last one: the explicit ask. If you need a decision, say 'Decision needed: please approve the extension of the deployment window to include the March maintenance shutdown response needed by Friday.' If you need escalation support, say 'Escalation needed: the vendor has missed the last two delivery commitments your direct engagement with their executive team would help resolve this.' Executives who receive status reports without a clear ask have no way to help even when they want to.

11.4 Risk Management for Energy IT Projects

Managing the NERC CIP Project Risk

For any IT project that touches systems in or adjacent to the NERC CIP Electronic Security Perimeter even tangentially the project plan must include an explicit step for CIP compliance review. This review asks: does the project introduce any new systems, change any existing systems, or modify any connections that affect the CIP-002 asset inventory, the CIP-005 electronic security perimeter, the CIP-007 patch management baseline, or the CIP-010 configuration baseline?

The consequence of missing this review is not merely a technical issue it is a compliance finding. A project that adds a new management workstation to a CIP-scope network segment without updating the asset inventory and notifying the compliance team has violated CIP-002 and CIP-010 as of the moment the device was connected. These violations are discovered during the next audit and result in findings against

the organization even though the technical mistake was made in good faith during a well-intentioned project. The fix is a thirty-minute conversation with the compliance team at project initiation the cost of not having it is months of compliance remediation.

PRACTITIONER TIP: Use a Compliance Pre-Screen Checklist for Every Project



Create a one-page compliance pre-screen checklist that every IT project must complete at the initiation phase. The checklist asks: does this project affect any system currently in the NERC CIP asset inventory? Does it add new systems to a network segment that contains CIP-scope assets? Does it change network connectivity in any way that could affect an Electronic Security Perimeter? Does it affect any system in scope for SOX ITGCs? A no to all questions means the compliance team does not need to be engaged until the standard change management review. A yes to any question triggers an early compliance consultation. This checklist takes five minutes to complete and prevents the class of compliance failures that arise from projects that never thought to engage compliance at all.

11.5 Building the IT Business Case for Energy Leadership

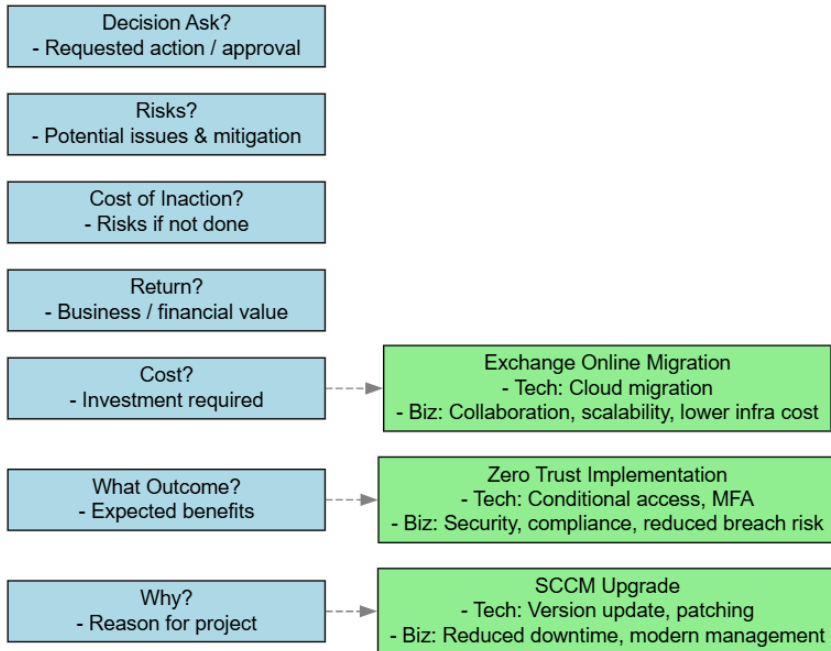


Figure 11.4 IT business case structure and language translation guide for energy companies. The seven questions on the left map to the standard business case structure. The translation examples on the right illustrate the most important communication skill for IT professionals in energy companies: converting technical requirements into operational and financial language that resonates with operations-minded leadership. The cost of inaction framing 'what happens if we do not do this?' is particularly effective in energy environments where risk quantification is part of the operational culture. Source: Energy sector IT leadership communication practice.

Quantifying Risk in Business Cases

Energy sector leadership responds well to quantified risk. Operations teams routinely perform risk assessments for

equipment and process decisions assigning probabilities and consequences to failure modes and the same analytical mindset applies to IT risk decisions when the risk is expressed in the right language. An IT business case that says 'our endpoint management system is end-of-life and creates security risk' is weak. The same case expressed as 'our endpoint management system is end-of-life; the average breach cost for a mid-sized energy company is \$3.12 million; our current unmanaged device population creates an exposure that comparable companies have experienced at a 67 percent rate this upgrade reduces that risk exposure to less than 20 percent based on industry data' is actionable and compelling.

The same quantification logic applies to productivity and operational arguments. 'The field IT replacement process currently takes an average of 3.8 days, consuming approximately \$2,400 per incident in IT labor and logistics' is more compelling than 'field IT replacements take too long.' Add the incident count per year, multiply by the cost per incident, and present the proposed solution's impact on that cost this is the business case formula that energy executives respond to.

The Mandatory 'What If We Do Nothing' Section

Every IT business case for energy company leadership should include an explicit section on the cost of inaction. This section is not a threat; it is an honest assessment of what the business risk landscape looks like if the proposed investment is not made. For security-related investments, this typically involves referencing industry incident data and the organization's specific exposure profile. For operational improvements, it involves quantifying the ongoing cost of the current state.

The cost of inaction section is frequently the most persuasive element of an IT business case because it reframes the decision from 'should we spend money on this?' to 'what is the cost of not spending money on this?' When the cost of inaction exceeds the cost of the proposed investment as it frequently does for end-of-

life systems, security improvements, and operational efficiency tools the business case essentially makes itself.

11.6 IT Portfolio Management and Reporting

Establishing the IT Steering Committee

The IT Steering Committee is the governance body that provides strategic direction for the IT portfolio, makes resource allocation decisions, approves major projects, and resolves cross-project conflicts. In energy companies, this committee should include representation from IT leadership (CIO or equivalent), operations leadership (VP of Operations or Operations Director), finance (CFO or Controller), compliance (Compliance Director or General Counsel), and the business units that are the primary consumers of IT services.

A well-functioning steering committee is one of the most valuable governance structures available to energy IT organizations. It provides IT with the organizational authority to make decisions that cross functional boundaries without having to escalate every cross-functional issue through informal channels. It also provides visibility and accountability: IT leadership must present portfolio status, resource consumption, and project outcomes to a diverse group of senior stakeholders, which both improves the quality of IT's own oversight and builds organizational confidence in IT's management capability.

The RAG Status and Its Honest Application

The Red-Amber-Green (RAG) status system is the most widely used project reporting framework in IT organizations, and also the most widely abused. The common failure mode is 'green-washing' reporting projects as green when they are actually amber, or amber when they are actually red, to avoid uncomfortable conversations with leadership. This behavior is understandable in the short term and destructive in the long

term: when a green project suddenly becomes a failed project with no warning, leadership loses confidence in the entire reporting system and begins demanding more detailed oversight, which is exactly the opposite of what the PM was trying to achieve.

Honest RAG application requires clear, shared definitions: Green means the project is on schedule and within budget with no significant risks. Amber means the project has identified risks or minor schedule or budget variances that are being managed leadership should be aware but no decision is required yet. Red means the project has a significant issue that requires leadership attention, a decision, or intervention. A project should move to red the moment the PM concludes that the issue cannot be resolved within the project team not after weeks of hoping it will resolve itself.

11.7 Vendor and Contract Management in Energy IT

Energy sector IT projects frequently involve third-party vendors: software vendors, implementation partners, managed service providers, hardware suppliers, and specialized consultants. Managing these relationships effectively getting the best performance from vendors while protecting the organization's interests is a distinct project management skill that is often underemphasized in IT project management training.

Contract Essentials for Energy IT

IT contracts in energy environments should include provisions that reflect the sector's specific requirements. Key clauses that energy IT teams should require in vendor contracts include: service level agreements with specific, measurable uptime and response time commitments; data protection provisions specifying how the vendor handles any data they access

(particularly important for vendors with access to operational data or BES-adjacent systems); right-to-audit provisions allowing the energy company to audit the vendor's compliance with security and data protection requirements; incident notification obligations requiring the vendor to report any security incident affecting the energy company within a defined timeframe; and intellectual property provisions clarifying ownership of any custom configurations, integrations, or code developed during the engagement.

For vendors who access NERC CIP-scope systems or data, supply chain risk management requirements under CIP-013 apply. CIP-013 requires entities to implement a documented supply chain risk management plan that addresses procurement of hardware and software used in BES Cyber Systems. IT project managers whose projects involve procuring technology for BES Cyber Systems must ensure that the CIP-013 process is completed before the procurement is finalized.

Managing Vendor Performance

Vendor performance management begins at contract signing, not when a vendor first misses a milestone. Establish the reporting cadence, communication channels, and escalation process at the start of the engagement. Weekly check-in calls with the vendor project manager, a shared issue log, and a clear escalation path to vendor executive contacts create the structure for identifying and resolving problems before they become critical path issues.

When a vendor misses a milestone, the first response is a direct conversation not an email with the vendor project manager to understand the cause and assess the impact. Document the conversation. If the vendor's explanation is credible and the recovery plan is realistic, update the project schedule and continue. If the vendor is evasive, the recovery plan is unrealistic, or this is the second missed milestone, escalate to the vendor's executive contact immediately. In energy

environments where project delays have operational consequences, vendor escalation should happen faster than most PMs are comfortable with.

CASE STUDY | Windows 11 Migration Enterprise IT Project in a Large Pipeline Company Composite Scenario

Background

A large natural gas pipeline company undertook a Windows 11 migration covering approximately 6,200 endpoints across 4 tiers of sites, with an 18-month project timeline. The project PM was an experienced IT professional new to the energy sector, and the first six months of the project revealed several energy-specific challenges that required significant plan revision.

Stakeholder Engagement Failure and Recovery

The initial project plan scheduled field site deployments in Q2 without consulting operations teams. When the deployment schedule was shared with site supervisors in March, three of them reported that the Q2 window coincided with their annual compressor maintenance season a period when IT work was effectively prohibited at those sites due to contractor presence and heightened operational activity. The deployment schedule had to be revised by approximately eight weeks for the affected sites. The lesson was integrated into the revised project plan as a mandatory pre-scheduling consultation step for all remaining site tiers.

NERC CIP Discovery

During the execution phase, the compliance team flagged that five workstations at two processing facilities were in the NERC CIP BES Cyber System inventory. The Windows 11 migration for those five systems required the CIP-010 configuration change process, which added approximately three weeks of documentation and review time per site. This discovery mid-project caused a four-week schedule variance for those sites. The post-project lessons learned document recommended adding the compliance pre-screen checklist as a mandatory initiation deliverable for all future IT

projects.

Communication Improvement

Midway through the project, the PM introduced a structured operations notification email template sent 48 hours before each field site deployment window and again on the morning of deployment. After implementing this template, the number of deployment-day calls from site supervisors asking 'what is IT doing today?' dropped from an average of 3.5 per deployment window to 0.4. Operations satisfaction with the project improved noticeably in the mid-project survey.

Outcome

The project completed on month 22 four months later than the original 18-month plan, primarily due to the initial stakeholder engagement failure and NERC CIP discovery. The lessons learned document was incorporated into the IT project management framework as a permanent reference. The PM's experience was that energy IT project management is approximately 50 percent technical delivery and 50 percent stakeholder and operations relationship management a ratio that would have surprised them before the project.

PRACTITIONER PERSPECTIVE | IT Program Manager | Large Upstream Energy Company (Anonymous)

"What is the biggest professional difference between project management in energy versus other industries?"

The operations relationship. In every other industry I worked in, 'stakeholders' meant the people who use the system. In energy, stakeholders also include people who do not use the system but whose work could be affected if the system goes down during deployment. That is a completely different category of stakeholder, and managing that relationship building trust with operations teams, communicating in their language, respecting their production calendar is a skill set that takes real time to develop.

The PMs who struggle in energy IT are almost always the technically excellent ones who underestimate the relationship side. The technology is rarely the hard part. The people who keep the pipeline running are both your most important constraint and your most important partner.

11.8 Lessons Learned and Continuous Improvement

The project closure phase includes a lessons-learned exercise that is frequently rushed or skipped in energy IT organizations, depriving future projects of the institutional knowledge they need to avoid repeating the same mistakes. A structured lessons-learned process does not need to be time-consuming a two-hour facilitated retrospective with the project team, producing a one-page document that captures: what went well and should be repeated, what went poorly and should be changed, and what the team would do differently if starting over.

Lessons learned are only valuable if they are accessible. A lessons-learned document filed in a personal SharePoint library and never referenced again provides zero organizational value. Build a lessons-learned repository in a centrally accessible location the IT project management SharePoint site or the ServiceNow knowledge base and require that every new project plan reference the relevant lessons from similar past projects. Over time, this repository becomes one of the most valuable assets in the IT project management practice: a living record of what the organization has learned about delivering IT change in an energy environment.

Chapter Summary

- IT project management in energy companies requires navigating the production-first culture: operations coordination before every deployment, communication in operational language, and schedule design that respects energy operational cycles.
- The five-phase lifecycle (Initiation, Planning, Execution, Deployment, Closure) includes energy-specific gates: regulatory pre-screen at initiation, operational blackout period mapping at planning, and formal operations sign-off before deployment.
- Stakeholder communication requires different formats and cadences for different audiences: executive one-page summaries monthly, operations notifications 48 hours before deployments, steering committee dashboards monthly, and weekly standups for the project team.
- The risk register for energy IT projects must include two energy-specific risks that rarely appear in other industries: operational impact risk and NERC CIP compliance risk. Both must have named owners and specific mitigation strategies.
- IT business cases for energy leadership must translate technical requirements into operational and financial language. The cost of inaction framing quantified in dollars and risk terms is frequently the most persuasive element of an IT business case.
- Portfolio reporting through a monthly RAG dashboard builds leadership confidence when done honestly. Green-washing reporting projects as healthier than they are destroys the trust that honest reporting builds.
- Vendor contracts for energy IT must include SLAs, data protection provisions, right-to-audit clauses, incident notification requirements, and for BES-adjacent

procurements, CIP-013 supply chain risk management compliance.

- Lessons learned must be documented, centrally accessible, and actively referenced by future projects not filed and forgotten.

Chapter 11 Checklist: IT Project Management Readiness

☐	Project initiation includes a compliance pre-screen checklist identifying NERC CIP, SOX, and other regulatory touchpoints
☐	Operations stakeholder map is built at initiation; operations contacts are identified and engaged before planning begins
☐	Project schedule is validated against energy operational calendars; blackout periods are built in before commitments are made
☐	Risk register includes Operational Impact and NERC CIP Compliance as explicit risks with named owners and mitigation plans
☐	Communications plan includes a separate section for operations stakeholder communication with 48-hour advance notification
☐	Weekly status reports are produced throughout execution; issue log and decision log are maintained
☐	Operations notification template is used for all deployment windows sent 48 hours before and morning of
☐	Executive status reports are one page, include RAG status, and end with an explicit decision ask if applicable

☐	RAG status definitions are documented and shared with the team; honest reporting is enforced
☐	IT Steering Committee receives monthly portfolio dashboard; gate review presentations are scheduled
☐	Business cases include: business problem, expected outcome, cost, return/ROI, cost of inaction, top risks, and explicit decision ask
☐	Technical requirements in business cases are translated into operational and financial language
☐	Vendor contracts include SLAs, data protection, right-to-audit, incident notification, and IP provisions
☐	CIP-013 supply chain risk management process is invoked for any procurement involving BES Cyber Systems
☐	Vendor performance check-in meetings are scheduled at contract signing; escalation contacts are identified
☐	Lessons-learned document is produced at project closure and stored in the centrally accessible repository
☐	New projects reference relevant lessons-learned documents from similar past projects

References and Further Reading

Project Management

Project Management Institute. A Guide to the Project Management Body of Knowledge (PMBOK Guide), 7th Edition. PMI, 2021.

Kotter, John P. Leading Change. Harvard Business Review Press, 1996. (On organizational change management.)

Prosci. ADKAR Model for Individual Change Management. prosci.com. Continuously updated.

Energy Sector IT and Compliance

NERC. CIP-013-2: Cyber Security Supply Chain Risk Management. nerc.com. Continuously updated.

NERC. CIP-010-4: Cyber Security Configuration Change Management and Vulnerability Assessments. nerc.com. Continuously updated.

Business Communication

Minto, Barbara. The Pyramid Principle: Logic in Writing and Thinking. Pearson Education, 2002. (On structured executive communication.)

IBM Security. Cost of a Data Breach Report 2022. ibm.com/security/data-breach. 2022.

The Future of IT in the Energy Sector

Navigating Five Technology Forces While Keeping the Lights On

The energy sector does not have the luxury of moving fast and breaking things. But it also cannot afford to move slowly and miss the technology capabilities that will define operational excellence in the decade ahead. The energy IT professional who navigates this tension well will be one of the most valuable people in the industry.

Chief Information Officer, Large Integrated Energy Company

12.1 Looking Forward from the Foundation We Have Built

The preceding eleven chapters have established a comprehensive foundation for energy sector IT practice: the unique characteristics that make energy IT distinctive, the endpoint and mobile management architectures that serve a geographically dispersed workforce, the identity and security controls that protect critical infrastructure, the regulatory compliance frameworks that govern the sector, the application

lifecycle and collaboration tools that enable the business, and the field operations and project management disciplines that deliver technology in a production-first environment.

This final chapter looks forward. The technology forces reshaping energy IT are significant and accelerating artificial intelligence and machine learning, the Industrial Internet of Things, OT/IT convergence, the energy transition's new infrastructure demands, and the maturation of cloud-native and Zero Trust architectures. Each of these forces creates both opportunity and risk for energy IT professionals, and each intersects with the sector's unique constraints in ways that require thoughtful, deliberate navigation rather than the rapid adoption that other industries might embrace.

This chapter examines each force, assesses its practical implications for energy IT teams over the 2022–2027 horizon, and provides a skills roadmap for IT professionals who want to remain relevant and valuable as the technology landscape evolves. It closes with a perspective on what makes energy IT a uniquely rewarding career domain a perspective earned through the experience of navigating the challenges this book has described.

12.2 Five Technology Forces Reshaping Energy IT

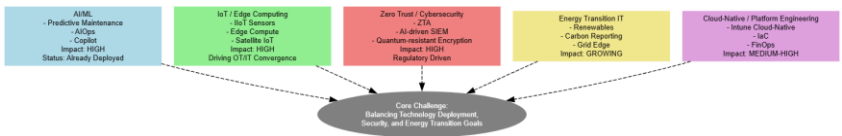


Figure 12.1 Five technology forces reshaping energy IT over the 2022–2027 horizon. Impact ratings reflect the assessment as of 2022; all five forces are accelerating. Energy IT's core challenge is harnessing these

forces while maintaining the operational reliability and compliance posture that energy infrastructure demands. The constraint is not the technology it is the unique operational context in which energy IT must be practiced.

These five forces do not operate independently. AI depends on IoT data; IoT convergence with OT creates new cybersecurity requirements; the energy transition brings new asset types that require both cloud-native management and OT security principles; Zero Trust architecture is the prerequisite for safely enabling both cloud-native operations and OT/IT convergence. Understanding how these forces interact and sequencing investments to build each capability on the foundation of the previous one is a more sophisticated and more durable approach than pursuing each force individually as a separate initiative.

12.3 Artificial Intelligence in Energy IT: Opportunity and Constraint

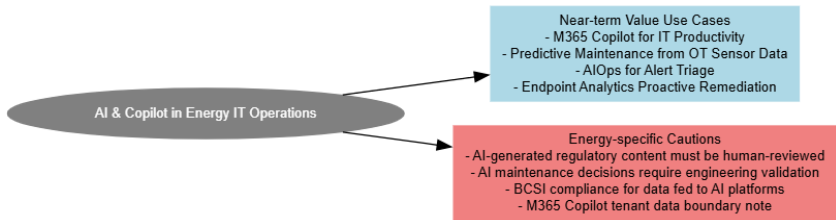


Figure 12.2 AI and Copilot use cases and energy-specific cautions. The most immediately practical AI value for energy IT teams is in productivity augmentation (Copilot for drafting, summarizing, and scripting) and predictive maintenance (ML on OT sensor data). Both require energy-specific guardrails: AI-generated regulatory content must be reviewed by humans before use, and any OT data fed to AI platforms must be

evaluated for NERC CIP-011 BCSl compliance before connection. Source: IBM Cost of a Data Breach 2022; energy IT practice.

AI-Assisted Tools: Emerging Value for Energy IT Teams

AI-assisted productivity tools are beginning to emerge as practical utilities for enterprise IT teams. For energy IT professionals, early AI writing assistance and automation tools provide benefits that reduce time spent on documentation and administrative tasks creating capacity for higher-value work.

Early AI-assisted tools for IT professionals including natural language script generation assistants and documentation aids can help generate first drafts, summarize long email threads, and create knowledge base articles from troubleshooting notes. These emerging capabilities are beginning to reduce administrative burden for IT teams, though they require human review for accuracy in all operational contexts.

Energy IT teams evaluating AI-assisted tools should establish governance before broad deployment: which systems and data sources the tools can access, how AI-generated content in compliance-sensitive documents is reviewed, and how BCSl and operational data boundaries are maintained. Human review of any AI-generated content used in regulatory filings or compliance evidence is non-negotiable.

AI-Assisted Security Operations

Microsoft Sentinel with AI-driven analytics represents a near-term opportunity for energy IT security teams. Sentinel's machine learning-based anomaly detection and entity behavior analytics can identify threat patterns that would be invisible to rule-based SIEM systems alone particularly the lateral movement, credential abuse, and data exfiltration patterns that

characterize sophisticated intrusions into energy company IT environments.

The practical value of AI-assisted security operations in energy companies is not replacing security analysts but amplifying them. A security team that receives 3,000 alerts per day and can investigate perhaps 50 of them is not operating effectively; a security team that receives 50 AI-prioritized and contextualized incidents from 3,000 raw alerts, with recommended investigation steps and similar incident history, is dramatically more effective. The ROI of Sentinel's AI capabilities is measured in analyst hours recovered for investigation rather than alert processing.

PRACTITIONER TIP: Start Your AI Journey with Internal Productivity Before External Data



The lowest-risk, highest-value starting point for AI adoption in energy IT is Microsoft 365 Copilot for internal IT productivity drafting, summarizing, scripting. This deployment involves no external data, no OT/IT boundary considerations, and no BCSI compliance concerns. It builds organizational familiarity with AI tools and governance requirements in a low-stakes environment. Use this experience to develop the AI governance framework, Copilot policies, and employee communication approach that will be needed when AI is extended to more sensitive use cases such as OT data analysis or customer-facing applications.

12.4 IoT, Edge Computing, and OT/IT Convergence

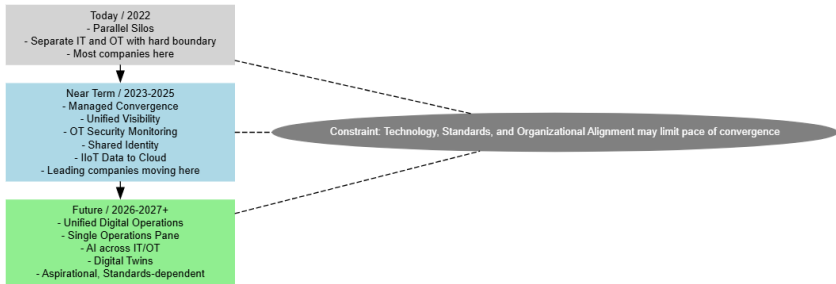


Figure 12.3 OT/IT convergence roadmap for energy companies. The pace of convergence is constrained by NERC CIP regulatory boundaries (which define separation requirements for BES Cyber Systems), OT vendor ecosystem maturity (many OT vendors are only beginning to support modern authentication and network protocols), and safety requirements (which demand extreme caution in any change to OT environments). Organizations that attempt full convergence faster than these constraints allow create both compliance and operational risk. Source: Microsoft Azure hybrid operations documentation; energy sector OT security practice.

The Industrial Internet of Things in Energy

The Industrial Internet of Things (IIoT) is already transforming energy operations at leading companies. Smart sensors on pipelines, compressors, pumps, and electrical equipment generate continuous streams of operational data pressure, temperature, vibration, flow rate, power consumption that, when aggregated and analyzed, enable predictive maintenance, operational optimization, and safety monitoring at a scale and precision that was previously impossible.

For energy IT teams, IIoT creates a new infrastructure management challenge: thousands of connected devices at field sites, each requiring management, security, and data

connectivity. These devices are not traditional IT endpoints they run embedded firmware rather than Windows, they are deployed in harsh physical environments, they communicate using industrial protocols (Modbus, MQTT, OPC-UA) rather than standard TCP/IP applications, and they have lifecycles measured in decades rather than years.

Managing IIoT infrastructure effectively requires IT teams to develop new capabilities: understanding of industrial networking protocols and topologies, experience with edge computing platforms that aggregate and process IIoT data locally before transmitting to the cloud, and familiarity with IoT device management platforms (Azure IoT Hub, for example) that provide device enrollment, configuration, and monitoring at scale. These capabilities sit at the intersection of IT and OT exactly the convergence point that the energy sector is navigating.

Edge Computing: Bringing Intelligence to the Field

Edge computing is the deployment of compute capability at or near the physical location where data is generated at a field site, a compressor station, or a wind turbine rather than transmitting all data to a central cloud for processing. In energy environments, edge computing addresses a fundamental constraint: satellite and cellular connectivity at remote sites is insufficient to transmit the continuous, high-resolution sensor data that modern analytics requires. Processing data at the edge and transmitting only results, aggregates, and exceptions is the architectural pattern that makes IIoT viable at remote energy sites.

Azure IoT Edge and similar platforms allow IT teams to deploy containerized analytics workloads to edge devices at field sites, where they run continuously regardless of connectivity state and synchronize results to the cloud when connectivity is available. This offline-first design principle ensure the edge device functions correctly without connectivity, then synchronize when

connected is the same principle that makes Autopilot pre-provisioning and OneDrive offline sync valuable for field workers. It is the architectural thread that connects field IT operations and IIoT edge computing.

12.5 The Energy Transition: New IT Infrastructure for a Changing Energy Mix

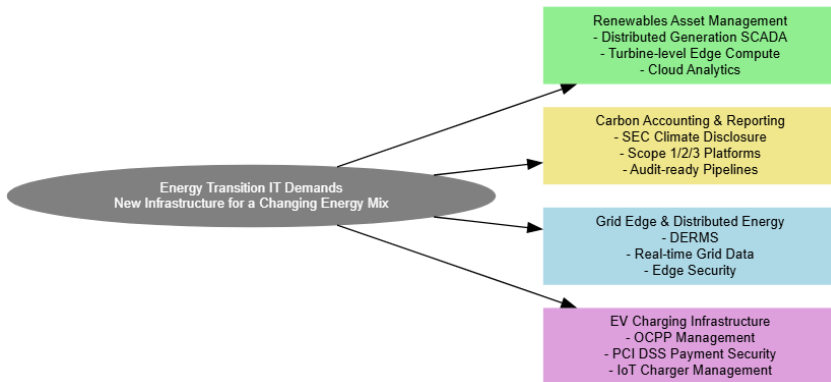


Figure 12.4 Energy transition IT demands. The energy transition from fossil fuels toward renewables, distributed generation, and electrification is creating new IT infrastructure requirements across four domains. Each domain requires IT capabilities that are distinct from traditional energy IT: renewables require distributed SCADA and edge analytics; carbon reporting requires data integration platforms; grid edge requires real-time IoT management; EV charging requires consumer-grade reliability and payment security. Source: Energy sector technology practice; SEC proposed climate disclosure requirements; 2022.

Carbon Reporting as an IT Requirement

Proposed SEC climate disclosure rules and voluntary reporting frameworks such as the Task Force on Climate-related Financial

Disclosures (TCFD) and GRI Standards are creating growing IT requirements for energy companies. Scope 1 emissions (direct emissions from owned or controlled sources), Scope 2 emissions (indirect emissions from purchased electricity), and Scope 3 emissions (all other indirect emissions in the value chain) must be calculated, tracked, reported, and in some cases externally assured requirements that are operationally complex for companies with large, geographically dispersed asset portfolios.

Carbon accounting platforms dedicated software for emissions data collection, calculation, and reporting are a rapidly growing category of enterprise software that energy IT teams will increasingly be asked to implement and manage. These platforms require integration with operational data systems (to extract fuel consumption, equipment runtime, and production data), financial systems (to allocate emissions costs), and external reporting frameworks. The IT skill set for implementing and governing these platforms combines enterprise application management (covered in Chapter 8) with data integration capabilities and the emerging domain knowledge of carbon accounting standards.

12.6 Zero Trust Maturity: Where Energy IT Needs to Be

Zero Trust Architecture (ZTA) the security model based on the principle of 'never trust, always verify' is the security framework that most directly addresses the threat landscape facing energy sector IT. The Colonial Pipeline breach, described in the introduction, exemplified the failure mode that ZTA is designed to prevent: an attacker who compromises credentials gains unrestricted access to systems across the network because implicit trust is granted to authenticated users regardless of what they do or where they connect from.

Chapters 4, 5, and 6 covered the individual components of Zero Trust in practice: Conditional Access policies that verify device compliance before granting access to cloud resources, Windows Hello for Business passwordless authentication that eliminates the password attack surface, Privileged Identity Management that removes standing privileged access, Defender for Endpoint's behavioral detection that identifies threats that have bypassed perimeter controls, and Azure Sentinel's SIEM capabilities that correlate signals across the entire environment.

The maturity model for Zero Trust in energy companies tracks the progressive application of these controls: starting with identity (MFA for all users, Conditional Access for cloud resources, PIM for privileged accounts), expanding to endpoints (device compliance as a condition of access, EDR on all managed endpoints, LAPS for local admin credentials), extending to data (sensitivity labels and DLP for sensitive information, BCSI protection), and ultimately reaching the network level (micro-segmentation, lateral movement prevention, OT network security monitoring). Energy companies entering 2023 are typically at the identity and endpoint stages of this maturity progression the network and data stages represent the work of the next five years.

Quantum Computing and Post-Quantum Cryptography

Quantum computing represents a long-term but increasingly concrete threat to the cryptographic foundations of modern IT security. Sufficiently powerful quantum computers will be capable of breaking the public key cryptography algorithms (RSA, ECC) that protect the majority of today's encrypted communications and digital signatures including the TLS used to secure SCCM and Intune communications, the Kerberos and certificate-based authentication used in Windows Hello for Business, and the VPN and network encryption used to protect energy company communications.

The U.S. National Institute of Standards and Technology (NIST) is actively developing post-quantum cryptography standards through its ongoing standardization process, with candidate algorithms under evaluation for replacing current public key cryptography. While the timeline for quantum computers capable of breaking current encryption is uncertain estimates range from 10 to 20 or more years the concept of 'harvest now, decrypt later' attacks (where adversaries collect encrypted traffic today with the intention of decrypting it when quantum capability arrives) means that organizations with long-lived sensitive data including energy companies with decades-long asset records and operational data should begin post-quantum planning now.

For energy IT professionals, the practical near-term action is awareness and inventory: know where your organization uses public key cryptography, understand which vendors have committed to post-quantum algorithm support timelines, and begin engaging with your security and compliance teams about a post-quantum migration roadmap. This is a five-to-ten-year journey, but organizations that begin planning now will be positioned to migrate systematically rather than reactively.

12.7 The Future Energy IT Workforce

The Changing Role of the Energy IT Professional

The role of the energy IT professional is evolving in two directions simultaneously: upward, into more strategic and cross-functional territory as technology becomes more central to energy operations; and outward, into domains that were previously separate OT, data science, AI governance, carbon accounting as the boundaries between IT and these adjacent disciplines erode.

The upward evolution is driven by the increasing operational importance of technology in energy companies. As predictive maintenance, remote operations, and digital collaboration

become core to operational performance, the IT team's work becomes more visible to operations leadership and more scrutinized. IT professionals who can speak the language of operations, quantify the business value of technology investments, and navigate the regulatory landscape have a significantly larger professional opportunity than those who remain purely in the technical domain.

The outward evolution is driven by OT/IT convergence and the energy transition. Energy IT professionals who develop familiarity with industrial protocols, OT security principles, and operational data analysis are positioned to play a central role in the convergence journey that every energy company is navigating. Those who develop knowledge of carbon accounting platforms, renewable energy management systems, and grid-edge technology are positioned for roles in the fastest-growing segment of the energy industry.

Continuous Learning in an Accelerating Technology Environment

The technology environment for energy IT is accelerating not in the breakneck fashion of consumer technology, but faster than the sector has historically experienced. Microsoft releases major Intune and Defender for Endpoint capabilities monthly; Azure IoT and Edge services are evolving rapidly; AI capabilities are expanding rapidly; NERC CIP standards continue to be updated to address emerging threats (CIP-015 INSM is under development, with additional updates for cloud systems under discussion). Staying current requires deliberate, structured learning not occasional conference attendance or reading when convenient.

Practical continuous learning strategies for energy IT professionals include: maintaining at least one active Microsoft certification (Intune and Identity are most relevant for the core capabilities covered in this book), engaging with the Microsoft Tech Community and energy-sector-specific forums where

practitioners share real-world experience, reading the NERC compliance news and enforcement postings quarterly to stay current on emerging regulatory expectations, and connecting with peers at other energy companies through industry groups such as E-ISAC and NERC working groups.

CASE STUDY | Building an OT/IT Security Operations Capability Composite Scenario

Background

A large electric utility operating generation, transmission, and distribution assets undertook a multi-year initiative to build a unified IT/OT security operations capability motivated by NERC CIP-015's new internal network security monitoring (INSM) requirements and by a broader strategic decision to move from reactive to proactive security operations.

Phase 1: IT Security Operations Foundation

The first 18 months focused entirely on IT: deploying Microsoft Sentinel as the SIEM, onboarding Azure Active Directory, Defender for Endpoint, and Microsoft 365 as log sources, training two security analysts on Sentinel KQL query writing, and establishing a 24-hour security monitoring coverage model through a managed security service provider for overnight hours. By the end of Phase 1, the team was responding to an average of 12 prioritized Sentinel incidents per day, down from an unmanageable 2,000+ raw alerts per day.

Phase 2: OT Visibility Integration

Months 19-36 extended monitoring into the OT environment carefully, in read-only mode, with explicit approval from operations and compliance. Network taps and passive monitoring sensors were deployed in the Electronic Security Perimeters of high-impact BES Cyber Systems. The traffic was forwarded to a separate, isolated Sentinel workspace (physically and logically separated from the IT Sentinel workspace to maintain CIP-005 ESP integrity). OT-specific analytics rules were built based on NERC CIP-015

INSM requirements.

Phase 3: Unified Visibility Correlation Without Co-mingling

By month 42, the team had achieved unified visibility: IT security analysts could see correlated alerts from both IT and OT monitoring sources, with clear labeling of which alerts originated in the IT environment versus the OT monitoring sensor network. A suspicious login to an IT workstation adjacent to an OT network boundary could be automatically correlated with unusual OT network traffic observed within 30 minutes of that login providing the threat hunting capability that the NERC CIP-015 standard was designed to enable, without violating the ESP boundary.

Key Outcomes

The initiative demonstrated that OT/IT security convergence is achievable without compromising compliance boundaries if architected carefully. The separation of IT and OT Sentinel workspaces, with correlation at the alert layer rather than the data layer, satisfied both the ESP isolation requirements of NERC CIP-005 and the INSM requirements of CIP-015. The compliance team cited the initiative as a model for how cloud-based security operations can satisfy NERC CIP requirements.

PRACTITIONER PERSPECTIVE | **Senior IT Architect** | *Large Midstream Energy Company (Anonymous)*

"What advice would you give to a mid-career IT professional who wants to build a long-term career in energy sector IT?"

Learn the operations side of the business. Not deeply you are an IT professional, not an engineer but enough to understand what a compressor station does, why a planned maintenance window matters, and what happens when a pipeline goes offline. When I started in energy IT, I spent a week at field sites just shadowing operators and asking questions. That week changed how I do my job. I understood why the operations team pushes back on IT changes during certain seasons. I could explain IT initiatives in

terms that resonated with field supervisors. And I made connections with people who, years later, are my best allies when I need operations cooperation for a project. The technical skills you can learn from documentation and certification. The operational credibility has to be earned in person. Get out to the field. It is the most valuable professional investment you will make.

12.8 A Practitioner's Forward Look

This book has documented the state of IT in the energy sector as of 2022 a moment of significant transition. The sector is moving from purely on-premises management to hybrid cloud architectures; from password-based to passwordless authentication; from reactive to proactive security operations; from siloed IT and OT to managed convergence; and from a workforce that could ignore technology to one where technology capability is a core operational differentiator.

The IT professionals who navigate this transition most successfully will be those who combine deep technical capability with genuine operational credibility. They will understand why a field supervisor at a compressor station cares about an IT change window in a way that a pure technologist does not. They will be able to explain a Zero Trust initiative to a CFO in terms of breach cost reduction, and explain the same initiative to an operations team in terms of what changes for them and what does not. They will know which NERC CIP standards apply to their environment and which do not, and they will build their IT architecture around that knowledge from the beginning rather than discovering compliance implications after the fact.

The energy sector will continue to be one of the most challenging, most consequential, and most professionally rewarding domains for IT practice. The infrastructure that the people in this industry operate pipelines, refineries, power

plants, transmission lines, now wind farms and solar installations is the physical foundation of modern society. The IT teams that support this infrastructure are not a cost center; they are an operational capability that is increasingly inseparable from operational performance. The work described in this book is meaningful work. Do it well.

Chapter Summary

- Five technology forces are reshaping energy IT over the 2022-2027 horizon: AI/Machine Learning, IoT and Edge Computing, Zero Trust and Advanced Cybersecurity, Energy Transition IT Demands, and Cloud-Native and Platform Engineering. All five are accelerating; all five intersect with the energy sector's unique operational constraints.
- Microsoft 365 Copilot provides near-term AI productivity value for IT teams in drafting, summarizing, and scripting tasks. Energy-specific cautions apply: AI-generated content in regulatory filings must be human-reviewed, and OT data fed to AI platforms must be evaluated for BCSI compliance before connection.
- IIoT sensor data and edge computing are enabling predictive maintenance and operational optimization at leading energy companies. IT teams must develop new capabilities in industrial protocols, edge platforms, and IoT device management to support this infrastructure.
- OT/IT convergence follows a three-stage roadmap: parallel silos (most companies today) to managed convergence (leading companies in 2023-2024) to unified digital operations (aspirational, 2026+). The pace is constrained by NERC CIP boundaries, OT vendor ecosystem maturity, and safety requirements.
- The energy transition is creating four new IT infrastructure domains: renewables asset management,

carbon accounting and reporting, grid edge and DERMS, and EV charging infrastructure. Each requires capabilities distinct from traditional energy IT.

- Zero Trust maturity in energy companies typically progresses from identity (MFA, Conditional Access, PIM) to endpoints (EDR, device compliance, LAPS) to data (sensitivity labels, DLP, BCSI protection) to network (micro-segmentation, OT monitoring). Most companies are at the identity and endpoint stages.
- Post-quantum cryptography preparation should begin now for energy companies with long-lived sensitive data. NIST is actively developing post-quantum standards; the migration journey is 5-10 years but harvest-now-decrypt-later attacks mean planning cannot wait for quantum computers to arrive.
- The future energy IT professional combines enduring technical foundations (endpoint, identity, security, networking) with emerging technical skills (AI/ML basics, OT/IT integration, IaC, cloud security), domain knowledge (NERC CIP, energy operations vocabulary), and human skills (stakeholder communication, change management, operations relationships).
- Operational credibility earned by understanding the energy business, spending time at field sites, and communicating in the language of operations is the differentiating capability that converts good IT professionals into great energy IT professionals. It cannot be learned from documentation; it must be earned in person.

Chapter 12 Forward-Looking Checklist: Preparing for 2022-2027

☐	AI governance policy for Microsoft 365 Copilot is documented: data access scope, review requirements for AI-generated compliance content, BCSI boundary assessment
☐	Microsoft Sentinel is deployed or planned; AI-driven analytics rules are configured for energy-specific threat patterns
☐	IIoT and edge computing strategy is documented: which assets, which data, which edge platform, which connectivity approach
☐	OT/IT convergence roadmap is defined: current state assessed, target state agreed with operations and compliance, timeline established
☐	NERC CIP-015 INSM compliance plan is in place for applicable high-impact BES Cyber Systems
☐	Energy transition IT portfolio assessment completed: which renewables, carbon reporting, grid edge, or EV charging IT demands apply to your organization
☐	Carbon accounting platform evaluation or implementation is underway; SEC climate disclosure readiness is assessed
☐	Zero Trust maturity is assessed: identity and endpoint stages are complete; data and network stage roadmap is defined
☐	Post-quantum cryptography inventory has been started: where does the organization use public key cryptography, which systems are highest priority for post-quantum migration
☐	IT skills development plan includes: at least one active Microsoft certification path per team member, quarterly NERC CIP regulatory update review, AI/ML fundamentals training

- IT professionals have visited field sites in the past 12 months and have established relationships with operations contacts
- Technology roadmap is reviewed with operations leadership annually to ensure alignment with operational priorities

References and Further Reading

Artificial Intelligence and Copilot

Microsoft. *Microsoft AI and Automation Tools for Enterprise*. microsoft.com/en-us/ai. 2022.

Microsoft. *Microsoft Sentinel Machine Learning and AI*. learn.microsoft.com/azure/sentinel/machine-learning-overview. Continuously updated.

IBM Security. *Cost of a Data Breach Report 2022*. ibm.com/security/data-breach. 2022.

OT/IT Convergence and IIoT

NERC. *CIP-015-1: Cyber Security Internal Network Security Monitoring (INSM)*. nerc.com. Proposed under NERC review.

Microsoft. *Azure IoT Edge Documentation*. learn.microsoft.com/azure/iot-edge. Continuously updated.

Microsoft. *Azure Arc Overview*. learn.microsoft.com/azure/azure-arc. Continuously updated.

ISA/IEC 62443-3-3: *Security for Industrial Automation and Control Systems*. isa.org. 2013.

Energy Transition and Carbon Reporting

SEC. *Proposed Enhancement and Standardization of Climate-Related Disclosures for Investors*. SEC, 2022.

GRI. *GRI Standards for Sustainability Reporting*. globalreporting.org. Continuously updated.

Cybersecurity and Post-Quantum

*NIST. Post-Quantum Cryptography Standardization Project.
nist.gov/pqcrypto. 2022 (standards in development).*

Microsoft. Zero Trust Guidance Center. learn.microsoft.com/security/zero-trust. Continuously updated.

CONCLUSION

The Energy IT Practitioner: Competence, Credibility, and Consequence

Technology does not make pipelines safe. Technology does not keep the lights on. People do. But increasingly, those people depend on technology to do their jobs and the IT professionals who support that technology carry a responsibility that is easy to underestimate from the outside.

Author's Note

This book began with the Colonial Pipeline incident not as a cautionary tale about what happens when IT fails, but as an illustration of the stakes that define the energy sector's relationship with information technology. Energy infrastructure is not a commercial service that users can switch off and come back to tomorrow. It is the physical foundation of modern life, and the people who maintain it operate in an environment where consequences are measured not just in dollars and downtime, but in safety, economic stability, and public trust.

Across twelve chapters, we have built a comprehensive picture of what it means to practice IT in this environment: the unique characteristics that shape every technology decision, from the consequence asymmetry that makes reliability non-negotiable to

the production-first culture that makes stakeholder communication as important as technical skill. We have covered endpoint management, mobile device management, identity, security, compliance, application lifecycle, collaboration, field operations, and project management not as abstract frameworks, but as specific, actionable practices adapted to the energy sector's distinctive requirements.

What emerges from this journey is a picture of IT practice that is both more demanding and more meaningful than IT in most other industries. More demanding because the regulatory environment is genuinely complex, the operational stakes are genuinely high, and the geographic and connectivity challenges are genuinely difficult. More meaningful because the technology an energy IT professional deploys every day the endpoint management that keeps field laptops running at compressor stations, the security controls that protect pipeline control systems, the collaboration tools that connect remote workers across vast geographies supports infrastructure that the entire economy depends on.

What This Book Has Covered

The twelve chapters of this book form an integrated framework for energy IT practice. Each builds on the preceding chapters, and together they describe a coherent approach to IT in this environment:

- Chapters 1–2 established the context and the foundational endpoint management architecture the SCCM/Intune co-management model that serves as the backbone of enterprise endpoint management in large energy companies.
- Chapters 3–4 covered the mobile and identity infrastructure MDM/MAM for field devices, Active Directory and Entra ID for hybrid identity, Group Policy and Windows Hello for Business for security hardening.

- Chapters 5–7 addressed the security and compliance imperatives the threat landscape, NERC CIP, TSA, CISA, SOX, and the governance frameworks that translate regulatory requirements into operational practice.
- Chapters 8–9 covered the application and collaboration layers from application packaging and lifecycle management to Microsoft 365 governance, Exchange Online, Teams for field workers, and SharePoint data protection.
- Chapters 10–11 addressed the operational and project management disciplines field site IT operations, the depot model, IT/OT boundary management, project lifecycle in a production-first culture, and stakeholder communication.
- Chapter 12 looked forward to the five technology forces reshaping the sector over the 2022–2027 horizon: AI and Copilot, IoT and edge computing, Zero Trust maturity, energy transition IT demands, and the skills evolution required for the next decade.

Five Principles That Run Through Every Chapter

Certain principles appear and reappear across the chapters of this book because they are fundamental to effective IT practice in energy environments.

1. Operations First, Technology Second

Every IT decision in an energy company must be filtered through an operations lens. The IT professional who coordinates with operations proactively earns the trust that makes future projects easier. The one who deploys first and asks forgiveness later will spend more time managing relationships than managing technology. This principle applies to patch deployment windows,

software rollouts, infrastructure changes, and every other IT activity that intersects with the operational environment.

2. Documentation Is Not Bureaucracy It Is Evidence

In regulated industries, the difference between a compliant organization and a non-compliant one is often not the quality of the security controls it is the quality of the documentation. NERC CIP auditors do not assume that controls are working; they require evidence that controls worked throughout the audit period. The documentation discipline described throughout this book is not administrative overhead. It is the proof of work that protects the organization and the practitioner.

3. Field Complexity Is the Measure of True IT Capability

Any IT architecture looks elegant at corporate headquarters with high-bandwidth connectivity and on-site support staff. The real measure of IT capability is how that architecture performs at a Tier 4 satellite-connected field site with no IT staff and limited connectivity. The field-first design principle designing IT systems to function reliably in the most constrained environment they will serve produces architectures that work well everywhere rather than architectures that work perfectly in the data center and fail at the field sites where the energy is actually produced.

4. Compliance Is a System, Not an Event

Organizations that treat regulatory compliance as a pre-audit event will always be reactive, always be stressed, and never fully confident in their compliance posture. Organizations that build compliance into their operational processes experience audits as confirmation of what they already know rather than as exposures of what they do not. The transformation from reactive

to continuous compliance is one of the highest-leverage improvements available to energy IT organizations.

5. The Technology Is Rarely the Hard Part

The practitioner perspectives collected across this book share a common theme: experienced energy IT professionals consistently identify the human, organizational, and operational dimensions of IT work as the primary determinants of success. The technology works. The challenge is deploying it in an environment where operations leadership has legitimate authority to say no, where compliance frameworks constrain the approach, and where a deployment that causes operational disruption will be remembered long after the technology benefit is forgotten. Mastering the technology is necessary but not sufficient. Mastering the human context is what makes an energy IT professional truly effective.

A Final Word on the Work

This book was written from the perspective of a practitioner who has lived the challenges it describes. The specific experiences behind this book shaped its emphasis on practical application over theoretical frameworks, on the field worker's reality over the data center architect's ideal, and on the human dimensions of IT work over the purely technical ones.

The energy sector is at a genuinely interesting inflection point. The technology forces described in Chapter 12 AI, IIoT, OT/IT convergence, the energy transition are active deployments at leading organizations today. The IT professionals who position themselves at the intersection of these technologies and the sector's unique operational and regulatory context will find themselves in some of the most consequential and rewarding roles in the technology industry.

The work described in this book matters. Do it with rigor, do it with care, and do it with a genuine understanding of what is at stake when the infrastructure you support serves the energy that powers modern life.

APPENDICES

Appendix A: Glossary of Key Terms

The following glossary defines the key technical and regulatory terms used throughout this book.

Term	Definition
AdminStudio	Flexera software for application packaging, repackaging, and quality assurance. Supports MSI, MSIX, App-V, and web application packaging.
ADE (Apple Device Enrollment)	Apple's zero-touch enrollment for supervised iOS/macOS devices. Previously called DEP (Device Enrollment Program).
App-V	Microsoft Application Virtualization. Packages applications in isolated virtual containers that run without modifying the base OS, enabling application conflict resolution.
Autopilot	Windows Autopilot. Cloud-based zero-touch provisioning service that deploys Windows devices to users without requiring IT presence.
Azure Arc	Microsoft service extending Azure management to on-premises and multi-cloud resources, enabling unified governance through the Azure portal.
BCSI	BES Cyber System Information. Under NERC CIP-011, information that could be used to gain unauthorized access or pose a security risk to BES Cyber Systems if disclosed.
BES (Bulk Electric System)	The portion of the North American electrical grid operating at 100 kV

	or above, including generation, transmission, and interconnection facilities.
BeyondTrust EPM	Endpoint Privilege Management software implementing least-privilege controls, allowing specific applications to run with elevated privileges without full admin rights.
CISA	Cybersecurity and Infrastructure Security Agency. U.S. federal agency responsible for protecting critical infrastructure cybersecurity.
CIRCIA	Cyber Incident Reporting for Critical Infrastructure Act of 2022. Requires covered entities to report significant cyber incidents to CISA within 72 hours.
CMG (Cloud Management Gateway)	SCCM feature extending management to internet-based devices via an Azure-hosted proxy, without requiring VPN.
Co-management	Simultaneous management of Windows devices by both SCCM and Intune, enabling gradual workload migration to the cloud.
Conditional Access	Microsoft Entra ID feature enforcing access policies based on device compliance, user risk, location, and application sensitivity.
CIP (Critical Infrastructure Protection)	The NERC CIP standards: cybersecurity requirements for organizations owning or operating Bulk Electric System assets.
DLP (Data Loss Prevention)	Policies that detect and prevent unauthorized sharing of sensitive information across email, Teams, SharePoint, and endpoints.
Distribution Point (DP)	SCCM server role hosting software content for client device downloads. Can be on-premises or cloud-based.
E-ISAC	Electricity Information Sharing and Analysis Center. NERC-operated center for sharing cyber threat intelligence among electric sector

	participants.
Entra ID	Microsoft's cloud identity platform (formerly Azure Active Directory). Provides authentication, authorization, and identity governance for M365 and Azure services.
ESP (Electronic Security Perimeter)	Under NERC CIP-005, the logical border around a network to which BES Cyber Assets are connected, protecting them from external unauthorized access.
GPO (Group Policy Object)	A Windows configuration container applied through Active Directory enforcing settings on computers and users within a domain.
Hybrid Azure AD Join	Device state where a Windows device is joined to both on-premises AD and Microsoft Entra ID, enabling access to both on-premises and cloud resources.
IIoT (Industrial Internet of Things)	IoT devices and sensors deployed in industrial environments for monitoring, control, and data collection from physical assets.
Intune	Microsoft Intune. Cloud-based endpoint management service providing MDM, MAM, and PC management as part of Microsoft Endpoint Manager.
IT/OT Boundary	The logical and/or physical separation between Information Technology (IT) networks and Operational Technology (OT) networks in industrial environments.
KFM (Known Folder Move)	OneDrive feature automatically redirecting Windows Desktop, Documents, and Pictures folders to OneDrive for Business, providing automatic cloud backup.
LAPS	Local Administrator Password Solution. Automatically manages and rotates local administrator account passwords on domain-

	joined or Entra ID-joined devices.
MAM (Mobile Application Management)	Intune capability managing applications on devices without full MDM enrollment; focuses on app-level data protection for BYOD scenarios.
MECM / SCCM	Microsoft Endpoint Configuration Manager (formerly System Center Configuration Manager). On-premises management for Windows devices, software deployment, and patching.
MDM (Mobile Device Management)	Platform for remotely managing mobile devices including enrollment, policy enforcement, app deployment, and remote wipe.
MSIX	Microsoft's modern application packaging format providing clean installation/removal, auto-updates, and native Intune deployment support.
NERC	North American Electric Reliability Corporation. Nonprofit regulatory authority for the reliability of the Bulk Electric System in North America.
OT (Operational Technology)	Hardware and software that detects or causes changes through direct monitoring and control of industrial equipment, assets, and processes.
PIM (Privileged Identity Management)	Microsoft Entra ID Premium P2 feature providing just-in-time privileged access with time-limited activation and approval workflows.
Purdue Model	Hierarchical model for industrial control system network segmentation (Levels 0–5), defining zones from physical process to enterprise IT.
RODC (Read-Only Domain Controller)	Active Directory DC hosting a read-only AD database copy, suitable for field sites with limited physical security.
Sensitivity Labels	Microsoft Purview labels applied to

	documents, emails, and Teams content to enforce encryption and access restrictions based on data classification.
SOX	Sarbanes-Oxley Act. U.S. federal law requiring publicly traded companies to attest to internal controls over financial reporting, including IT General Controls (ITGCs).
Tenant Attach	SCCM feature uploading device inventory to the Endpoint Manager portal, enabling cloud-based device visibility and remote actions for SCCM-managed devices.
TSA	Transportation Security Administration. U.S. agency issuing cybersecurity directives for critical pipeline and aviation infrastructure.
WHfB (Windows Hello for Business)	Enterprise passwordless authentication using biometric or PIN credentials backed by asymmetric cryptography.
Zero Trust Architecture	Security model based on 'never trust, always verify' requiring continuous verification for all users, devices, and applications regardless of network location.
ZTP (Zero Touch Provisioning)	Device deployment approach where a device configures itself automatically when connected to the internet, without IT staff present.

Appendix B: NERC CIP Standards Quick Reference for IT Professionals

The following summarizes NERC CIP standards most relevant to IT professionals. Always consult your compliance team for authoritative guidance.

Standard	Name	What IT Must Do
CIP-002	BES Cyber System Categorization	IT must ensure new systems added to networks adjacent to BES infrastructure are assessed for BES Cyber Asset classification. Changes to IT infrastructure affecting BES boundaries trigger a CIP-002 review.
CIP-003	Security Management Controls	IT must support a documented security management program including policies, leadership accountability, and an exception process for transient cyber assets.
CIP-004	Personnel and Training	IT staff with BES Cyber System access must complete annual security awareness training, background checks, and maintain access authorization documentation.
CIP-005	Electronic Security Perimeters	IT manages the IT network adjacent to the ESP. All ESP access points must be controlled; remote access requires MFA. IT must document the ESP boundary.
CIP-006	Physical Security	IT staff must follow physical access procedures at BES Cyber System locations. Physical Access Control Systems managed by IT must comply with CIP-006.

CIP-007	System Security Management	IT's most operationally demanding standard. Requires: port minimization, patch management within 35 days (or documented exceptions with compensating controls), security event logging, malware prevention.
CIP-008	Incident Reporting and Response	IT must notify E-ISAC within 1 hour of identifying a reportable Cyber Security Incident. IR plans must be tested every 15 months.
CIP-009	Recovery Plans	IT must support documented recovery plans for BES Cyber Systems including backup procedures and recovery time objectives. Plans must be tested annually.
CIP-010	Configuration Management	IT must maintain documented baseline configurations for BES Cyber Assets and manage changes through formal change management. Unauthorized deviations from baseline are a finding.
CIP-011	Information Protection	IT must implement controls to protect BCSI including access controls, encryption, and handling procedures. Applies to any cloud storage of BCSI.
CIP-013	Supply Chain Risk	For BES Cyber

	Management	System procurement, IT must implement a documented supply chain risk management plan addressing hardware and software integrity and authenticity.
--	------------	---

Appendix C: Master IT Readiness Checklist Energy Sector

This master checklist consolidates the chapter-level checklists into a single reference for annual self-assessment, new IT leader onboarding, or pre-audit gap analysis.

ENDPOINT MANAGEMENT (Chapter 2)

☐	SCCM/MECM primary site is current and receiving monthly security updates
☐	Co-management is enabled; Intune workloads are being progressively migrated
☐	Cloud Management Gateway (CMG) is deployed; internet-based devices managed without VPN
☐	Tenant Attach is enabled; Intune console shows current SCCM device inventory
☐	Windows 10/11 migration is complete or actively in progress with a defined completion date
☐	BeyondTrust EPM or equivalent least-privilege controls are deployed to all endpoints
☐	Application packaging follows a documented standard; AdminStudio or equivalent is in use

☐	Maintenance windows are defined per site tier; patch compliance is measured monthly
--------------------------	---

MOBILE DEVICE MANAGEMENT (Chapter 3)

☐	Android Zero Touch or Apple ADE is configured for corporate-owned device enrollment
☐	MAM (App Protection Policies) is configured for BYOD/unmanaged devices accessing M365
☐	Per-app VPN is configured for mobile access to internal resources
☐	Device compliance policies are defined; non-compliant devices are blocked from corporate resources
☐	Mobile device lifecycle (enrollment, refresh, retirement) process is documented

IDENTITY AND AD (Chapter 4)

☐	Active Directory OU structure reflects site and device taxonomy
☐	Entra Connect is configured; all users are synchronized to Entra ID
☐	Hybrid Azure AD Join is complete for all corporate Windows devices
☐	Windows Hello for Business is deployed (Cloud Kerberos Trust preferred)
☐	Windows LAPS is deployed; local admin passwords rotate automatically
☐	Tiered administration model is implemented; Tier 0 accounts are restricted

CYBERSECURITY (Chapter 5)

☐	Microsoft Defender for Endpoint is deployed to all managed endpoints
☐	ASR (Attack Surface Reduction) rules are configured and monitored
☐	Immutable backup solution is implemented (3-2-1-1 rule; Azure Backup with immutability)
☐	Incident response plan is current and has been tested within the past 15 months
☐	E-ISAC 1-hour notification procedure is documented and known to the IR team
☐	Ransomware-specific controls: network segmentation, controlled folder access, backup isolation
☐	Security awareness training is delivered annually to all staff

CLOUD AND AZURE (Chapter 6)

☐	Cloud adoption maturity stage is assessed; roadmap is documented
☐	Conditional Access policies enforce device compliance for cloud resource access
☐	PIM is configured for Global Admin and other privileged Entra ID roles
☐	Azure Backup with immutable vault policy protects critical on-premises workloads
☐	Azure Cost Management has budget alerts and tagging policy configured

COMPLIANCE AND GOVERNANCE (Chapter 7)

☐	Regulatory applicability assessment is complete (NERC CIP, TSA, CISA/CIRCA, SOX)
☐	NERC CIP asset inventory is current; BES Cyber Assets are categorized

	(high/medium/low)
☐	Patch exception documentation is created at time of exception (not retrospectively)
☐	Access reviews are conducted quarterly for all in-scope systems; results are filed
☐	Compliance evidence repository is organized by framework, standard, and time period
☐	IT governance policy library is current: InfoSec Policy, AUP, Change Management Policy
☐	Internal compliance review is conducted semi-annually

APPLICATION LIFECYCLE (Chapter 8)

☐	Formal application intake process exists; every new application requires a ServiceNow ticket
☐	Every application has a named, current business owner confirmed within the last 12 months
☐	Application catalog is current and reconciled against SCCM/Intune software inventory
☐	UAT environment simulates production hardware and field site bandwidth constraints
☐	Written UAT sign-off from application owner is required before production deployment
☐	Annual application portfolio review is conducted; retirement process is documented

M365 AND COLLABORATION (Chapter 9)

☐	Exchange anti-phishing, Safe Attachments, Safe Links, and DMARC are configured
--------------------------	--

☐	Exchange retention policies are tiered and aligned with regulatory requirements
☐	Teams creation is restricted; naming policy and sensitivity label requirement are enforced
☐	Teams retention policies are configured and aligned with email retention schedule
☐	SharePoint sensitivity labels with auto-labeling are configured for BCSI and Confidential content
☐	Known Folder Move is deployed via Intune for all managed Windows devices
☐	M365 Apps update channel strategy assigns Semi-Annual Enterprise Channel to field/regional users

FIELD IT OPERATIONS (Chapter 10)

☐	Site tier taxonomy is defined and applied to all sites in the fleet
☐	Remote control solution (Quick Assist or equivalent) is deployed to all managed field devices
☐	Regional depots are stocked with pre-imaged, Autopilot-enrolled spare devices
☐	IT/OT boundary is documented for all Tier 2 and above sites
☐	Bandwidth throttling and delivery optimization are configured for Tier 3 and Tier 4 site collections
☐	Site IT records are maintained in a centrally accessible system

PROJECT MANAGEMENT (Chapter 11)

☐	Compliance pre-screen checklist is completed at project initiation
--------------------------	--

☐	Operations stakeholder map is built at initiation; contacts are engaged before planning begins
☐	Risk register includes Operational Impact and NERC CIP risks with named owners
☐	Operations notification template is used 48 hours before each deployment window
☐	IT Steering Committee receives monthly portfolio dashboard
☐	Lessons-learned documents are stored in the centrally accessible repository

FUTURE READINESS (Chapter 12)

☐	AI and automation governance policy is documented for any AI-assisted tools in use
☐	OT/IT convergence roadmap is defined with operations and compliance agreement
☐	CIP-015 (INSM) monitoring strategy is documented in advance of standard finalization
☐	Zero Trust maturity is assessed; identity and endpoint stages are complete
☐	IT skills development plan includes active certification path and AI/ML fundamentals training

Appendix D: Recommended Resources and Further Reading

The following resources are recommended for energy IT professionals seeking to deepen their knowledge in specific areas.

Microsoft Documentation (learn.microsoft.com)

Microsoft Intune: learn.microsoft.com/intune Authoritative, continuously updated reference for all Intune capabilities.

Microsoft Endpoint Configuration Manager:

learn.microsoft.com/configmgr Complete SCCM/MECM documentation including CMG, co-management, and cloud services.

Microsoft Entra ID: learn.microsoft.com/entra Identity platform including Conditional Access, PIM, and Hybrid Join.

Microsoft Security Documentation: learn.microsoft.com/security Covers Defender, Sentinel, Zero Trust, and Purview compliance tools.

Microsoft Tech Community (techcommunity.microsoft.com):

Practitioner blogs, configuration guides, and community Q&A. The Intune, Security, and M365 communities are particularly active.

NERC and Regulatory Resources

NERC CIP Standards: [nerc.com/pa/Stand/Pages/CIPStandards.aspx](https://www.nerc.com/pa/Stand/Pages/CIPStandards.aspx)
Full text of all standards, guidance documents, and FAQs.

NERC Public Penalty Postings:

[nerc.com/pa/comp/CE/Pages/Penalties.aspx](https://www.nerc.com/pa/comp/CE/Pages/Penalties.aspx) Published compliance findings and penalties. One of the most valuable resources for understanding real-world audit findings.

E-ISAC: eisac.com Threat intelligence and security alerts for electric sector participants.

CISA: cisa.gov/topics/critical-infrastructure Federal guidance, advisories, and resources for energy sector cybersecurity.

Professional Certifications

MD-102: Microsoft Certified: Endpoint Administrator Associate Covers Intune, SCCM co-management, and Windows deployment. Directly relevant to Chapters 2, 3, and 4.

SC-300: Microsoft Certified: Identity and Access Administrator Associate Covers Entra ID, Conditional Access, and PIM. Directly relevant to Chapters 4 and 6.

SC-200: Microsoft Certified: Security Operations Analyst Associate

Covers Defender for Endpoint, Sentinel, and security operations. Relevant to Chapters 5 and 12.

AZ-104: Microsoft Certified: Azure Administrator Associate Covers Azure core services, identity, and governance. Relevant to Chapter 6.

PMP (Project Management Professional): Industry-standard project management certification. Relevant to Chapter 11.

Industry Organizations

NERC Working Groups: NERC convenes working groups on compliance, standards development, and cybersecurity. Participation provides early visibility into evolving requirements.

E-ISAC Portal: eisac.com Threat intelligence and incident reports for registered electric sector participants.

Microsoft Tech Community Intune Blog: techcommunity.microsoft.com Monthly feature announcements and configuration guidance from the Intune product team.

American Gas Association (AGA) Cybersecurity Committee: Cybersecurity guidance and advocacy for natural gas industry participants.

Appendix E: About the Author

Vilas Shewale is a Lead IT Specialist with more than twenty years of enterprise information technology experience, with deep specialization in endpoint management, cybersecurity, and digital transformation in the energy sector.

Currently serving as Lead Specialist at a major midstream energy company headquartered in Houston, Texas, Vilas leads endpoint management strategy and implementation across a large, geographically dispersed device fleet. His work encompasses Microsoft Endpoint Configuration Manager (SCCM/MECM), Microsoft Intune, BeyondTrust Endpoint Privilege Management, Windows Hello for Business, Microsoft Entra ID, Azure cloud services, and enterprise application lifecycle management.

Prior to his current role, Vilas held senior IT positions at VLink/ConocoPhillips, Morgan Stanley in Mumbai, JP Morgan Chase in Singapore, and TD Ameritrade building a career that spans financial services, energy, and technology sectors across three continents. This diverse background informs his approach to energy IT: understanding that the operational priorities, regulatory requirements, and organizational cultures of the energy sector are genuinely distinct, and that IT professionals serve their organizations best when they understand and respect that context.

Vilas is a published author whose earlier work, *Cybersecurity in the Modern World*, addressed enterprise cybersecurity for a broad business audience. *IT in the Energy Sector* builds on that foundation with sector-specific depth drawn from direct operational experience.

Beyond his practitioner role, Vilas is a contributing author and technology commentator whose work bridges enterprise IT practice and industry education. He brings cross-sector experience spanning financial services, technology, and energy to his writing.

Vilas holds multiple Microsoft certifications and is based in the Houston, Texas metropolitan area.

IT in the Energy Sector: Managing Infrastructure, Security, and Digital Transformation in Critical Energy Environments

By Vilas Shewale | © 2022 Vilas Shewale. All rights reserved.

The Definitive Practitioner's Guide to IT in the Energy Sector

Energy sector IT is unlike IT anywhere else. The stakes are higher, the regulations are stricter, the environments are harsher, and the operational culture demands a level of credibility that technical skills alone cannot deliver. This book was written by a practitioner who has lived these challenges across pipelines, processing facilities, and remote field sites for an audience of IT professionals who face them every day.

INSIDE THIS BOOK

- ▶ Complete SCCM/Intune co-management architecture for energy IT
- ▶ NERC CIP compliance from an IT practitioner's perspective
- ▶ Field site IT operations: depot model, IT/OT boundary, rugged hardware
- ▶ Microsoft 365 governance with BCSI and CIP-011 data protection
- ▶ Zero Trust implementation roadmap for regulated environments
- ▶ AI, IoT, and OT/IT convergence the 2022–2027 horizon
- ▶ Project management in a production-first organizational culture
- ▶ 75-point master IT readiness checklist across all 12 chapters

ABOUT THE AUTHOR

Vilas Shewale is a Lead IT Specialist with over twenty years of enterprise IT experience, specializing in endpoint management, cybersecurity, and digital transformation in the energy sector. He is the author of *Cybersecurity in the Modern World* and is based in Houston, Texas.

COMPUTERS / Information Technology / Energy Sector

© 2022 Vilas Shewale | All rights reserved | Printed in the United States of America

The Definitive Practitioner's Guide to IT in the Energy Sector

Energy sector IT is unlike IT anywhere else. The stakes are higher, the regulations are stricter, the environments are harsher, and the operational culture demands a level of credibility that technical skills alone cannot deliver. This book was written by a practitioner who has lived these challenges across pipelines, processing facilities, and remote field sites for an audience of IT professionals who face them every day.

INSIDE THIS BOOK

- ▶ Complete SCCM/Intune co-management architecture for energy IT
- ▶ NERC CIP compliance from an IT practitioner's perspective
- ▶ Field site IT operations: depot model, IT/OT boundary, rugged hardware
- ▶ Microsoft 365 governance with BCSI and CIP-011 data protection
- ▶ Zero Trust implementation roadmap for regulated environments
- ▶ AI, IoT, and OT/IT convergence the emerging technology horizon
- ▶ Project management in a production-first organizational culture
- ▶ 75-point master IT readiness checklist across all 12 chapters

ABOUT THE AUTHOR

Vilas Shewale is a Lead IT Specialist with over twenty years of enterprise IT experience, specializing in endpoint management, cybersecurity, and digital transformation in the energy sector. He is the author of *Cybersecurity in the Modern World* and is based in Houston, Texas.

COMPUTERS / Information Technology / Energy Sector

© 2022 Vilas Shewale | All rights reserved | Printed in the United States of America

